Astana IT University

Software Engineering

Development of a Digital Legacy Platform with a Hybrid Activation Mechanism Based on Shamir's Secret Sharing

Project Documentation

Pre-defense 1 — final version

Team: Alisher Medebaev (SE-2414), Aibyn Samat (SE-2415)

Supervisor: Tutkyshbayeva Sh.S.

Repository: github.com/alishermede/Development-of-a-Digital-Legacy-Platform-with-a-Hybrid-Activation-Mechanism

Version: tags pre-defense-1 and prob-period-1, 24.10.2026

Astana, 2026

Contents

Project Links **5**

1. Project Proposal **6**

1.1 Title 6
1.2 Team and supervisor 6
1.3 Problem statement 6
1.4 Target users 7
1.5 Aim 7
1.6 Objectives 7
1.7 Expected outcomes 8
1.8 Scope 8
1.9 Engineering complexity 9

2. Evidence of Relevance **10**

2.1 What was done 10
2.2 Limitations of the sample 10
2.3 Findings 10
2.4 Status of assumptions from the interview guide 11
2.5 Impact on requirements and other documents 11
2.6 Next steps 12

3. Literature Review **13**

3.1 Scope and selection 13
3.2 Cryptography and activation protocols 13
3.3 Digital legacy, usable security and Kazakhstan law 15
3.4 Analysis table 16
3.5 Comparison of approaches 17
3.6 Research gap and how the project addresses it 18
3.7 Limitations of this review 18
References 19

4. Existing System Comparison **21**

4.1 Systems and criteria 21
4.2 Comparison table 21
4.3 Reading the table 22
4.4 Gap 23
4.5 Limitations 23
4.6 Verification of the cryptographic criteria (DIP-11) 24
References 24

5. Technology Comparison **26**

5.1 Server platform 26
5.2 Data storage 26
5.3 Cryptographic libraries 27
5.4 Component interaction 29
5.5 Summary of decisions 30
5.6 Frontend framework 31
5.7 Notification services (SMS, Telegram, email) 32
References 34

6. Requirements Specification **36**

6.1 Functional requirements — Cryptographic core (FR-CRY) 36
6.2 Functional requirements — Hybrid activation (FR-ACT) 37
6.3 Functional requirements — Invitation and identity of trusted persons and recipients (FR-INV) 39

6.4 Non-functional requirements — Security, reliability, performance....39
6.5 Functional requirements — Owner cabinet (FR-OWN)....40
6.6 Functional requirements — Trusted person and recipient interface: bot and Mini App (FR-TRU)....41
6.7 Functional requirements — Notifications (FR-NOT)....42
6.8 Non-functional requirements — Usability and localization (NFR-USE, NFR-L10N)....44
6.9 Constraints....45
7. Architecture and Diagrams....46
7.1 System context....46
7.2 Use cases....48
7.3 Components (draft)....51
7.4 Trust boundaries and data protection....52
7.5 Activation state machine....54
8. UX Prototype and API Examples....56
8.1 Mockup scenarios....56
8.2 API examples....59
9. Verification and Evaluation Plan....61
9.1 Test levels and tools....61
9.2 Outcome metrics....61
9.3 Baseline solution....63
9.4 Evaluation scenarios and measurement conditions....63
9.5 Usability evaluation....65
10. Project Management....68
10.1 Team and responsibilities....68
10.2 Milestones....70
10.3 Risk register....70
10.4 Task dependencies....72
10.5 Maintenance of this document....75
11. Supervisor Feedback....76
11.1 How feedback is recorded....76
11.2 Feedback log....76
11.3 Communication log....77
11.4 Original comments (Russian)....77
12. Kazakhstan Legal Requirements and Design Decisions....79
12.1 Scope and evidence....79
12.2 Norm-to-design traceability....79
12.3 Hosting decision....80
12.4 Consent and the first invitation....80
12.5 Risk and completion status....81
References....81
13. Notification Reliability Specification....82
13.1 Event, channel and fallback matrix....82
13.2 What confirmation means....82
13.3 Retries and recovery....83
13.4 Fail-closed state guards....84
13.5 Acceptance and test cases....84
13.6 Operations and alerting....85
Appendix A. Interview Guide....86
1. Purpose....86
2. Format....86
3. Respondent profiles....87

4. Consent text....87
5. Interview script....87
6. Note template....89
7. Storage and anonymity....90
8. Check against DIP-4 acceptance criteria....90
Appendix A. Russian wording used in the messenger interviews....90
Appendix B. Interview Notes....93
I-01....93
I-02....95
I-03....97
Appendix C. Design-Model Results (M1b and notification guards)....100
C. M1b: paired sensitivity experiment....100
C. Notification guard model checks....100
C. Unexecuted implementation evidence....100
Appendix D. Mockup Screens....102
Appendix E. Pre-defense 1 Submission Summary....107
Completed work....107
Known limitations....108
Outstanding tasks....108

Project Links

All links point to the repository version tagged `prob-period-1`; this report is built from that version.

Material	Link
Repository at tag prob-period-1	https://github.com/alishermede/Development-of-a-Digital-Legacy-Platform-with-a-Hybrid-Activation-Mechanism/tree/prob-period-1
Interactive prototype (Figma)	https://www.figma.com/design/TUcjm1m3MKVUpHNSPEMRR0/Mura?node-id=6-2&t=i2iZQjowyfeHM3Ev-1
Interactive prototype (Figma Make)	https://www.figma.com/make/4u0Ub4pIQ9f5iPrhTgmakU/Capsule?t=KBUNM5ZIrf0FA1Tj-1
Mockup exports (PNG)	https://github.com/alishermede/Development-of-a-Digital-Legacy-Platform-with-a-Hybrid-Activation-Mechanism/tree/prob-period-1/prototype/mockups
Editable diagram sources (PlantUML)	https://github.com/alishermede/Development-of-a-Digital-Legacy-Platform-with-a-Hybrid-Activation-Mechanism/tree/prob-period-1/diagrams/src
Diagram exports (PNG, SVG)	https://github.com/alishermede/Development-of-a-Digital-Legacy-Platform-with-a-Hybrid-Activation-Mechanism/tree/prob-period-1/diagrams/export
OpenAPI draft	https://github.com/alishermede/Development-of-a-Digital-Legacy-Platform-with-a-Hybrid-Activation-Mechanism/blob/prob-period-1/prototype/api/openapi.yaml
Interview materials	https://github.com/alishermede/Development-of-a-Digital-Legacy-Platform-with-a-Hybrid-Activation-Mechanism/tree/prob-period-1/docs/02-relevance-evidence
Usability test materials	https://github.com/alishermede/Development-of-a-Digital-Legacy-Platform-with-a-Hybrid-Activation-Mechanism/tree/prob-period-1/docs/usability
Simulation model	https://github.com/alishermede/Development-of-a-Digital-Legacy-Platform-with-a-Hybrid-Activation-Mechanism/blob/prob-period-1/tests/simulation/pre-defense-model.cjs
Pull requests and reviews	https://github.com/alishermede/Development-of-a-Digital-Legacy-Platform-with-a-Hybrid-Activation-Mechanism/pulls?q=is%3Apr
YouTrack project	https://diplom-digital-legacy.youtrack.cloud/projects/DIP

1. Project Proposal

1.1 Title

- **EN:** Development of a Digital Legacy Platform with a Hybrid Activation Mechanism Based on Shamir's Secret Sharing
- **RU:** Разработка платформы цифрового наследия с гибридным механизмом активации на основе схемы разделения секрета Шамира
- **KZ:** Шамирдің құпияны бөлу схемасына негізделген гибридті іске қосу механизмі бар цифрлық мұра платформасын әзірлеу

1.2 Team and supervisor

Member	Group	Role
Alisher Medebaev	SE-2414	Backend, cryptographic core, hybrid activation mechanism, architecture
Aibyn Samat	SE-2415	Frontend and platform: user cabinets, check-ins, notifications, user research

Supervisor: Tutkyshbayeva Sh.S.

1.3 Problem statement

A modern person owns a large number of digital assets: accounts in email, social networks and government services, cloud files and photos, subscriptions, domains, hosting and business accounts. Much of this information exists only in the owner's memory or on their devices. If the owner dies or becomes incapacitated, relatives often cannot access important data, cancel paid subscriptions, recover family photos or keep a small business running.

Existing solutions address this problem only partially:

- **Platform tools** work only within their own ecosystem. Google Inactive Account Manager shares selected Google data with up to 10 contacts after 3–18 months of inactivity. Apple Legacy Contact requires an access key and a death certificate and does not transfer passwords.
- **Password managers** cover only stored credentials. Bitwarden Emergency Access lets **any single** trusted contact obtain the vault after a waiting time that the owner can interrupt; 1Password has no built-in emergency access and relies on a printed Emergency Kit.
- **Dedicated digital legacy services** usually rely on a single trigger (missed check-ins or one person's claim). This leads either to **false activation**, when the owner simply forgot to respond, or to **abuse by one trusted person**. Many of them also require trust in the provider, which can technically read the data.
- **A notarial will** is not designed for passwords and frequently changing digital data, and it puts the data at risk of disclosure.

In addition, no such service is localized for Kazakhstan (Kazakh and Russian interface, local inheritance and personal data legislation).

None of these solutions combines **activity check-ins, confirmation by several independent people (*k* of *n*) and a cancellable waiting period**, while keeping the data unreadable for the provider. Therefore, there is a need for a platform that transfers digital data **only when the event is actually confirmed**, does

not depend on trust in the provider, lets the owner decide how many people must confirm the event, and stays resistant to false activations.

The relevance of the problem will be confirmed by user interviews (`docs/02-relevance-evidence/`) and the comparison of existing systems (`docs/04-existing-systems.md`).

1.4 Target users

Role	Description	Needs
Owner	Adult with many online accounts; small business owner with business accounts	Leave data and instructions to specific people, keep data private while alive, avoid false transfer
Trusted person	Relative or close friend chosen by the owner	Simple, free way to confirm the event without technical knowledge and without registration (Telegram only)
Recipient	Person who receives a capsule after activation	Clear access to the data and messages intended for them, without registration (Telegram only)

1.5 Aim

To develop a digital legacy platform that transfers the owner's encrypted data to chosen recipients only after a confirmed event, without trust in the provider and with protection against false activation.

How the aim is reached (client-side encryption, hybrid activation with *k*-of-*n* confirmation by Shamir's Secret Sharing, waiting period with cancellation) is described by objectives 3–5, and how it is checked by objective 7.

1.6 Objectives

#	Objective	Responsible	Reviewer	Measurable result / evidence
1	Analyse digital legacy solutions and literature on secret sharing, encryption and activation.	Aibyn Samat	Alisher Medebaev	Critical comparison, sources and limitations in sections 3-5 (DIP-7/8/9/10; cryptographic verification DIP-11 by Alisher).
2	Collect and trace requirements through 3-5 user interviews and expert input where available.	Aibyn Samat	Alisher Medebaev	I-01 to I-03 and findings-to-requirements table; missing expert interview explicitly recorded (DIP-4/5/6).
3	Design the cryptographic protocol, key lifecycle and threat model.	Alisher Medebaev	Aibyn Samat	Protocol, trust boundaries and adversarial test cases; owner/recipient key-authentication limits stated (DIP-14/18).
4	Implement client-side AES-256-GCM, Argon2id, threshold sharing and owner recovery.	Alisher Medebaev	Aibyn Samat	M2/M4/M5; k-share recovery and rejection with fewer than k shares; implementation evidence remains pending.
5	Implement hybrid activation as a state machine with check-ins, k distinct confirmations, cancellable waiting period and per-capsule release.	Alisher Medebaev	Aibyn Samat	E1-E11 and audited valid/invalid transitions; notification policy is a separate objective 9.
6	Develop the owner web application and Telegram bot/Mini App with Kazakh and Russian interfaces.	Aibyn Samat	Alisher Medebaev	Scenarios S1-S8; SUS >= 70 and task/time targets in section 9.5; live implementation and evaluation remain pending.
7	Evaluate false activation, confidentiality, performance and usability against a timer-only baseline.	Alisher Medebaev (protocol/performance); Aibyn Samat (usability)	Each reviews the other's results	M1: no false releases in specified honest-trustee living-owner cases; M1b: 1,000 synthetic lives per assumption cell with paired baseline/system percentages; M2: every k-1 subset for 2 <= k <= n <= 5 plus stolen DB; M5: zero canary leaks; M10: 10 MB encryption/sharing median <= 3 s; M11: Argon2id median <= 2 s, 10 runs and recorded devices.
8	Analyse Kazakhstan personal-data and inheritance-law requirements and	Aibyn Samat	Alisher Medebaev	DIP-26: norm-to-design table, Kazakhstan hosting Must decision, consent/transfer gates and expert-interview

#	Objective	Responsible	Reviewer	Measurable result / evidence
	decide data placement.			limitation in section 12, prepared 24.10.2026.
9	Specify and verify notification reliability independently from the activation algorithm.	Aibyn Samat (specification); Alisher Medebaev (M6/M8/M12 integration tests)	Each reviews the other's results	DIP-27: event/channel/fallback matrix, acknowledgement semantics, 3 transient retries, persistent jobs and all-channel failure cases NR-01 to NR-08 in section 13.

Current deadline for the legal-analysis and reliability **documents**: 24.10.2026, 18:00 Asia/Qyzylorda (UTC+5). Working-system measurements are future implementation evidence and are not represented as completed by this deadline.

1.7 Expected outcomes

- A working web application for owners and a Telegram bot with Mini App for trusted persons and recipients.
- A cryptographic core: client-side encryption, Shamir key splitting, encrypted share delivery and recovery.
- A hybrid activation mechanism with configurable *k*, *n*, check-in interval and waiting period.
- Protocol specification and threat model.
- Test and evaluation results compared with the baseline solution.
- Project documentation and the diploma thesis.

1.8 Scope

In scope

- Data types: account credentials, text instructions, files and photos, personal messages, business access (domain, hosting, business social media).
- Separate capsules for different recipients.
- Client-side encryption: the server stores only ciphertext.
- *k*-of-*n* confirmation by trusted persons using Shamir's Secret Sharing (owner chooses *k*, default 2).
- Trusted persons and recipients without registration: invitation by SMS and Telegram, interaction through a Telegram bot and Mini App.
- Check-ins via SMS and Telegram; notifications via SMS, Telegram and email.
- Waiting period with notifications and owner cancellation.
- Kazakh and Russian interface.
- Consideration of Kazakhstan legislation on inheritance and personal data storage.

Out of scope

- Banking access and cryptocurrency wallets.
- Legal transfer of property and replacement of a notarial will.
- Native mobile applications (responsive web application and Telegram Mini App only).
- Interaction for trusted persons and recipients through messengers other than Telegram.
- Development of new cryptographic algorithms (only proven libraries are used).

- Integration with government services (e.g. automatic death registry check).
- Data recovery without the service (offline tools, printed key shares).

1.9 Engineering complexity

1. **Zero-knowledge architecture.** All encryption and decryption happen in the browser; the server must work correctly without ever seeing plaintext or a complete key.
2. **Threshold cryptographic protocol.** Splitting the key with Shamir's Secret Sharing, securely delivering each share to a trusted person (encrypted under their own key) and reconstructing the key only when k shares are submitted.
3. **Keys without registration.** Trusted persons and recipients have no account: their key pairs are generated inside a Telegram Mini App and kept in the phone's secure storage, so the protocol must handle lost devices, identity verification by phone number and the fact that a Telegram bot cannot write to a user first.
4. **Hybrid activation state machine.** Combining time-based triggers, confirmations from several independent people and a cancellable waiting period, while correctly handling edge cases (owner returns, trusted person unavailable, repeated confirmations).
5. **Reliable multi-channel notifications.** Timely delivery through SMS, Telegram and email, since a missed notification can lead to false activation.
6. **Key recovery.** The owner may forget the master password; access must be recoverable with a recovery key without letting the provider read the data.
7. **Threat modelling.** Protection against a compromised server, a single malicious trusted person, collusion of fewer than k persons, a lost phone or hijacked Telegram account of a trusted person, and false triggers.

2. Evidence of Relevance

Task: DIP-6. Status: draft based on three interviews (I-01…I-03).

2.1 What was done

Three interviews were conducted in a messenger following the script in interview-guide.md. Notes: I-01, I-02, I-03. Interviews were in Russian; quotes in the notes are given in the original with an English translation.

2.2 Limitations of the sample

- 3 respondents, all adults 40+, living in Kazakhstan.
- No domain expert (lawyer, notary, IT security specialist). An expert interview remains planned.
- Messenger format: answers are short, follow-up questions were rarely asked, pairs of questions were sent together (12 and 13, 14 and 15).
- One value (the amount in I-01) has no payment period; I-03 has no amount and no answer about current payments.
- Status rule: a finding is marked verified if at least two interviews support it, otherwise assumption. Because the sample is small, verified means "preliminarily confirmed".

2.3 Findings

Requirement IDs refer to 06-requirements.md.

ID	Finding	Evidence	Status	Requirements
F-01	Respondents faced a situation where access to another person's data was needed and the person could not give it (hospital, death). Without preparation it takes time and effort	I-01 (Q3), I-02 (Q3), I-03 (Q3)	verified	FR-ACT-01…13, FR-CRY-04…07
F-02	Without a service people keep data on the phone and either memorize passwords or write them on paper. There is no systematic way to pass access	I-01 (Q2, Q6), I-02 (Q2, Q6)	verified	FR-ACT-01…13, FR-CRY-04…07
F-03	Respondents named 2–4 closest people as trusted persons (wife and children, children, daughter and sister). This fits $1 \le n \le 5$ and the default $k = 2$	I-01 (Q9), I-02 (Q9), I-03 (Q9)	verified	FR-ACT-04, FR-CRY-04
F-04	A trusted person is ready to confirm the event and pass the key, but not to take responsibility for serious decisions, keep complex passwords or go through someone's archives. Note that FR-CRY-10 asks trusted persons to periodically open the Mini App to check their key	I-02 (Q10), I-03 (Q10)	verified	FR-ACT-08, FR-CRY-06, FR-CRY-10, FR-INV-01
F-05	SMS is acceptable for check-ins for every respondent. Telegram is named by one, WhatsApp by one. One respondent rules out email because she may not open it for a week	SMS: I-01, I-02, I-03. Telegram: I-03. WhatsApp: I-02. Email rejected: I-03	verified for SMS, assumption for Telegram and WhatsApp	FR-ACT-02, FR-ACT-09, FR-INV-02
F-06	The desired check-in frequency differs: weekly (I-02), monthly (I-03). The configurable range of 1–180 days with a 30-day default covers both	I-02 (Q11), I-03 (Q11)	verified (the interval must be configurable)	FR-ACT-01
F-07	Time without an answer before an alarm: 2 days (I-01), about 7 days (I-02), about 10 days (I-03). Pause after confirmation: 2 days, about a month, about 5 days. The spread is large. FR-ACT-05 (1–60 days, default 7) covers all three; FR-ACT-03 fixes the escalation at day 0, 2 and 3 and is not configurable	I-01 (Q11), I-02 (Q11), I-03 (Q11)	verified that the waiting period must be configurable. The default of 7 days remains an assumption	FR-ACT-03, FR-ACT-05
F-08	Respondents want data opened only in part: the necessary data, or in	I-01 (Q12), I-	verified	FR-ACT-14, FR-

ID	Finding	Evidence	Status	Requirements
	stages	02 (Q5), I-03 (Q12)		ACT-15, FR-OWN-03, FR-OWN-04 (separate recipients and release delays per capsule)
F-09	A false activation is seen as unpleasant but not critical. A failed activation is called "the worst" by I-03. I-02 calls both bad	I-02 (Q12, Q13), I-03 (Q12, Q13)	assumption	FR-ACT-07, FR-ACT-10, NFR-REL-01, NFR-REL-02
F-10	The ability to cancel the release during the waiting period is wanted	I-02 (Q12)	assumption	FR-ACT-10
F-11	Two respondents are uneasy about who can see data stored by a service, or consider storage unsafe. One respondent who uses a password manager and 2FA trusts strong encryption	I-01 (Q7), I-02 (Q7), I-03 (Q7)	assumption	FR-CRY-01, FR-CRY-02, NFR-SEC-01, NFR-SEC-02
F-12	Respondents pay little or nothing for similar services. The expected price is about 1000 KZT (period not stated) or 500–1000 KZT per month, provided the service is simple, secure and anonymous	I-01 (Q14), I-02 (Q14)	verified (preliminarily)	Outside the requirements (business model)
F-13	For users without a technical background, encryption and key splitting are hard to understand. A clear instruction is needed	I-02 (Q8, Q15)	assumption	FR-INV-04, NFR-USE (DIP-15)
F-14	An existing solution is in real use: one respondent uses Google "Inactive Account Manager". Others do not know of such services	I-03 (Q3, Q8), I-01 (Q7), I-02 (Q6)	assumption	DIP-10 (existing systems comparison)
F-15	One respondent suggests a separate code for force-majeure situations. The meaning is unclear	I-01 (Q13)	assumption	To clarify, possibly related to FR-ACT-10
F-16	Trusted persons and recipients take part only through Telegram (bot and Mini App). Respondents named SMS most often, and one named WhatsApp rather than Telegram. A relative without Telegram could not take part	I-01 (Q11), I-02 (Q11), I-03 (Q11)	assumption	FR-INV-01, FR-INV-02, CON-04

2.4 Status of assumptions from the interview guide

ID	Assumption	Result
A-01	No working way to pass access	Supported by I-01, I-02. I-03 found her own way after a painful experience
A-02	People do not trust services to store data	Partly: I-01 and I-02 are concerned, I-03 trusts strong protection
A-03	2–5 trusted persons	Supported by all three
A-04	A 7-day waiting period is acceptable	Not confirmed as a single value: 2, about 5 and about 30 days were named. 7 days is inside the configurable range of FR-ACT-05
A-05	SMS and Telegram are acceptable	SMS confirmed, Telegram by one respondent, WhatsApp appeared as a new channel
A-06	False and failed activation are judged differently	Supported only by I-03
A-07	Some people are willing to pay	Supported by I-01, I-02 at the level of 500–1000 KZT

2.5 Impact on requirements and other documents

The following decisions are reflected in the merged requirements and design documents (PRs #9, #11 and #18). They are design decisions based on a small sample, not implementation or validation results.

- **FR-ACT-03 (escalation).** Resolved in PR #11: keep day 0, +2 and +3; show total silence as the check-in interval plus 3 days. The default and schedule still need evaluation.

- **Staged or partial release (F-08).** Resolved: one process per owner (FR-ACT-14), separate recipients per capsule (FR-OWN-03), and a release delay of 0–365 days after the waiting period (FR-ACT-15, raised to Must in PR #18).
- **FR-CRY-10.** Resolved in PR #11: one tap every 180 days, counted automatically when the Mini App is opened, with a reminder after 7 days without a response.
- **SMS check-in without login.** Resolved in FR-ACT-16: a single-use link and an explicit button press; it cannot cancel the waiting period.
- **Usability (F-13).** Covered by NFR-USE-03, NFR-USE-04 and FR-TRU-10; understanding is evaluated in section 9.5.
- **WhatsApp (F-05).** Considered in section 5.7.4 and excluded from this version (FR-NOT-11).
- **Existing systems (F-14).** Google Inactive Account Manager is included in section 4.
- **Sample risk.** Recorded as R-01 in section 10.3; an expert interview and younger respondents remain planned for M7.
- **Dependence on Telegram (F-16, CON-04).** Still open for user validation: check whether the selected relatives can participate. SMS notifications do not replace the Mini App for cryptographic operations.
- **Requirements with source ASM.** FR-CRY-08, FR-CRY-09, FR-ACT-12, FR-ACT-13, FR-INV-06, NFR-SEC-06, NFR-REL-01, NFR-REL-02, NFR-PERF-01, NFR-PERF-02 and NFR-CAP-01 are not covered by the interviews and remain assumptions. NFR-SEC-06 (2FA) is only indirectly supported, since I-03 uses 2FA herself.

2.6 Next steps

- An interview with a notary or an IT security specialist, using the additional questions of the interview guide.
- 1–2 more respondents of a younger age group (P1, P3).

3. Literature Review

This section reviews the literature behind the Digital Legacy Platform. It covers secret sharing, key derivation, zero-knowledge encryption, recovery protocols and dead man's switches (DIP-7), then digital legacy, usable security and the law of Kazakhstan (DIP-8). The last parts compare the approaches, state the research gap and list the limits of the review (DIP-9). Web sources were accessed on 22.10.2026, and section 3.7 records the review's limits.

Section	Responsible
3.1 Scope and selection, 3.2 Cryptography and activation protocols (DIP-7)	Aibyn Samat
3.3 Digital legacy, usable security, Kazakhstan law (DIP-8)	Aibyn Samat
3.4 Analysis table, 3.5 Comparison of approaches, 3.6 Research gap, 3.7 Limitations (DIP-9)	Aibyn Samat

3.1 Scope and selection

The review has 20 sources: 16 scientific works (peer-reviewed papers, book chapters, a dissertation and preprints), 2 standards and 2 legal texts. Eighteen of the 20 are not legal texts. Nine of those 18 were published in 2021 or later, and the rest are foundational works (Shamir 1979, the Argon2 paper) or standards that are still in force. Sources were chosen when they bear on a decision already written into the proposal or the requirements, and the table in section 3.4 names the requirement each one touches. Legal sources are official texts of the Republic of Kazakhstan. Sources are cited in IEEE style and numbered in the order they first appear.

Searches were conducted in English and Russian. No scientific source in Kazakh was found, which is noted in section 3.7.

3.2 Cryptography and activation protocols

3.2.1 Secret sharing

Shamir's scheme [1] hides a secret as the constant term of a random polynomial of degree k−1 over a finite field. Each share is one point on the polynomial. Any k points fix the polynomial and reveal the secret, while k−1 points leave every possible secret equally likely. The guarantee holds against an attacker with unlimited computing power, which is why the proposal builds on it. Two limits matter for us. The dealer, here the owner's browser, must be honest and bug free, because a share cannot be checked against the secret it came from. And with k = 1 the polynomial is a constant, so splitting does nothing, which is the reason FR-CRY-04 handles k = 1 by encrypting the capsule key separately for each trusted person.

Beimel's survey [2] covers schemes for access structures more general than "any k of n". As the survey describes, general structures need much larger shares than a plain threshold, where each share can be as small as the secret itself. The platform needs only the threshold case, so this cost does not apply, and a rule such as "two relatives, or one relative and a lawyer" is out of scope for the same reason.

Herzberg et al. [3] address a different problem: shares that stay in place for years while an attacker slowly breaks into shareholders one by one. Their proactive scheme refreshes all shares periodically without ever rebuilding the secret, so the attacker needs k shares inside a single period. The refresh is an interactive protocol between the shareholders. Our trusted persons are relatives with a Telegram account, and asking them to run a protocol together is unrealistic. FR-CRY-08 takes the simpler route:

the owner re-splits the key and issues new shares. That route works only while the owner is alive and active, so a share stolen after the process has started cannot be refreshed. The threat model has to say this openly.

3.2.2 Key derivation and authenticated encryption

The Argon2 paper [4] describes a memory-hard function, the winner of the Password Hashing Competition, designed so that a large amount of memory slows down cracking on GPUs and custom hardware. RFC 9106 [5] turns it into a standard and recommends the Argon2id variant as the default for password hashing. This is the function the owner's master password goes through (FR-CRY-02). The RFC lists parameter sets for different memory budgets. The large set is not realistic for a phone browser, so final values will be chosen by measurement against NFR-PERF-02 (2 s on a mid-range smartphone) and written down. Memory hardness raises the price of each guess and does nothing for a weak password, so the interface still has to push the owner toward a strong one.

NIST SP 800-38D [6] specifies AES-GCM, the mode used for capsules (FR-CRY-01). The standard requires a unique initialization vector for every encryption under one key and limits how many encryptions one key may protect when the vectors are random. A fresh 256-bit key per capsule keeps the platform far from that limit. The one place to watch is editing: FR-OWN-05 says an edit creates new ciphertext, and if that happens under the same capsule key, the vector must be new each time.

3.2.3 What zero-knowledge claims are worth

Scarlata et al. [7] tested the "zero-knowledge encryption" claim of three cloud password managers against a fully malicious server. They report 12 attacks on Bitwarden, 7 on LastPass and 6 on Dashlane, and most of them recover passwords. The attacks fall into four groups: abuse of key escrow used for account recovery and single sign-on, missing integrity of the vault as a whole, flaws in the sharing features, and old cryptographic code kept for backward compatibility. The paper concerns password managers, so it does not say our protocol is broken. It does show where systems of the same kind failed, and three of the four groups touch our design directly: recovery (FR-CRY-09), sharing between people (FR-CRY-05, FR-CRY-06) and integrity of stored ciphertext (FR-CRY-01).

Applied to our case, a malicious server could hand the owner's browser a wrong public key for a trusted person and so receive a share it can decrypt. FR-INV-05 checks the person's phone number, but the requirements do not say how the owner's browser learns that the public key it encrypts to really belongs to that person. FR-CRY-11 now requires out-of-band safety-code comparison, and metric M3 tests substitution detection when that comparison is performed. This mitigates key substitution; it does not establish security against every malicious-server attack, and skipped comparisons remain a threat-model limitation (NFR-SEC-03).

3.2.4 Recovery by trusted people, and the waiting period

Guardian-based recovery in Web3 wallets is the closest working analogue of the *k*-of-*n* confirmation and the cancellable waiting period. The wallet owner names guardians, a threshold of them can approve a change of key, and the change takes effect only after a delay in which the owner can object. Chatzigiannis et al. [8] systematize such recovery mechanisms, and the same group's later paper [9] gives a framework for analysing how recovery mechanisms combine; later work cites it for the choice of the delay parameter.

The analogy is useful and has a limit. In a wallet the delay is a window for the living owner to veto a wrong recovery, and the tension is always the same: the delay must be long enough for the owner to

notice and short enough for a real recovery to be useful. Our waiting period (FR-ACT-05, 7 days by default) has the same tension. The difference is who is absent. Wallet guardians act when the key is lost, while our trusted persons act when the owner may be dead, so a missing veto is the expected outcome and not a warning sign. This is why FR-ACT-16 forbids the SMS check-in link from stopping a running waiting period: otherwise anyone holding the owner's phone could stop a real activation.

3.2.5 Dead man's switch

Banerjee et al. [10] treat the dead man's switch as a cryptographic primitive for the first time, by their own statement. They define two modes, release and delete, prove the construction in the universal composability framework and build it on proactive secret sharing with a changing committee of holders. Release goes to designated recipients through a public key infrastructure and multi-recipient encryption. This is the nearest formal work to the platform's aim. Two things limit its use for us. It is a preprint on ePrint. Its abstract describes how the secret is kept and released but does not detail how the death of the keeper is established or whether it addresses false triggers. The platform's contribution is exactly that part, the human confirmation and the cancellable delay.

3.2.6 Recovery codes in practice

Höltervennhoff et al. [11] surveyed 281 users of an end-to-end encrypted email service and analysed 197 support requests. Most participants kept the recovery code and found six ways to store it, the commonest being a password manager. They valued the security of the code and found its usability poor: codes were lost, some did not work, and users held misconceptions, for example that the provider could restore their data. This bears on FR-CRY-09, where the owner's recovery key is shown once and may be printed, and on NFR-USE-03, which asks that encryption be explained in plain language. The study covers one email provider and self-selected users, so the percentages should not be carried over to our owners.

3.3 Digital legacy, usable security and Kazakhstan law

3.3.1 Digital legacy as a research topic

Brubaker et al. [12] interviewed 20 people who had lost someone and managed their online accounts afterwards. They argue that managing a dead person's data is closer to stewardship than to inheritance: the people who handle it carry responsibilities and relationships, and there is no single owner to hand things to. The study is about social network accounts, mostly Facebook, and it describes the people who stayed behind, not those who plan ahead.

Holt et al. [13] ran two workshops with users of password managers and found what they call a post-mortem privacy paradox. People see the value of planning and avoid doing it. The security habits recommended in life, such as a strong master password known only to oneself, work against giving anyone access after death. The authors recommend designs that encourage planning while keeping those habits. The sample is small and the workshops were held in the United Kingdom, so the paradox is a hypothesis for our interviews and not a settled fact. It supports the proposal's main choice: access after death should not depend on telling someone the master password.

Edwards and Harbinja [14] argue from the legal side that the privacy interests of the deceased deserve recognition. The article is built on United States and United Kingdom law. For us it supports one design point, that capsule content should stay unreadable to everyone, including the provider, until the release.

3.3.2 Usable security

Whitten and Tygar [15] tested whether people could use PGP 5.0 and found that the interface did not match what users understood about public and private keys. The system is old and the test was small. The result still applies to a product where a relative has to hold a private key without knowing what one is. FR-TRU-10 (a help section of at most 3 short screens) and NFR-USE-05 (accept in 5 taps, confirm in 3 steps) answer this directly.

The System Usability Scale [16] is a ten-item questionnaire that gives one score from 0 to 100. The project uses it for the target of NFR-USE-01 (SUS of at least 70). The scale measures overall impression, so it cannot show which screen is the problem. The usability plan (DIP-22) therefore adds task success and time on task.

3.3.3 Law of Kazakhstan

The Civil Code, Special Part [19], regulates inheritance in section 6. Article 1040 says the estate consists of the property of the deceased and of rights and obligations that do not end with death. Rights and obligations inseparable from the person are excluded. A capsule is not a will and does not transfer property, which matches the out-of-scope list in the proposal. The reviewed sources do not settle whether an online account is part of the estate. Zakirov and Khayarova [18] state, for Russian law, that civil legislation does not regulate the legal regime of an account, and Russian law is not Kazakh law, so this point serves only as a sign that the question is open in neighbouring systems. Zhanabilova's dissertation [17] has a chapter on the regulation of digital assets in Kazakhstan and one on inheriting particular kinds of them. A careful reading is still needed before the proposal says anything about the legal status of accounts.

The Law on Personal Data and Their Protection [20] says in Article 12 that personal data is stored by the owner, the operator or a third party in a database located in the territory of Kazakhstan. The platform stores the names and phone numbers of trusted persons and recipients, so this applies to those fields. NFR-LAW-01 is a Should requirement, and given the text of the article it may need to be a Must for the stored personal data; this is raised for the supervisor and for the risk register. Two further questions are not answered by the reviewed sources: whether the owner may enter a trusted person's phone number before that person has agreed, and how the transfer of a number to an SMS provider or to the email provider outside Kazakhstan is treated (section 5.7.2 already notes the email case). Both require a legal opinion and remain unanswered here. Prg.kz shows the text of the law as amended on 12.07.2026; the current edition must be checked on adilet.zan.kz before the defense.

3.4 Analysis table

#	Source	Type, year	Finding relevant to the project	Limitation	Requirements
1	Shamir [1]	Paper, 1979	k of n shares rebuild a secret; k−1 reveal nothing, even to an unlimited attacker	Honest dealer assumed; shares cannot be verified; k = 1 is degenerate	FR-CRY-04, FR-ACT-04
2	Beimel [2]	Survey chapter, 2011	General access structures cost much more than a threshold	General survey; no implementation advice	FR-CRY-04
3	Herzberg et al. [3]	Paper, 1995	Periodic share refresh defeats a slow, gradual attacker	Needs interaction between shareholders	FR-CRY-08, NFR-SEC-03
4	Biryukov et al. [4]	Paper, 2016	Memory-hard function for password hashing	Memory hardness does not help weak passwords	FR-CRY-02, NFR-PERF-02
5	RFC 9106 [5]	Standard, 2021	Argon2id recommended as the default; parameter sets given	Large memory sets unrealistic on phones	FR-CRY-02, NFR-PERF-02
6	NIST SP 800-38D	Standard, 2007	GCM needs a unique initialization vector	Does not cover key	FR-CRY-01, FR-

#	Source	Type, year	Finding relevant to the project	Limitation	Requirements
	[6]		per encryption	management	OWN-05
7	Scarlata et al. [7]	Paper, 2026	Zero-knowledge claims failed against a malicious server in all three managers tested	Password managers, not legacy services	NFR-SEC-01, NFR-SEC-03, FR-CRY-05, FR-CRY-09
8	Chatzigiannis et al. [8]	Preprint (SoK), 2023	Systematizes guardian and delay based recovery	Preprint (SoK)	FR-ACT-08, FR-ACT-10
9	Chatzigiannis et al. [9]	Paper, 2025	Framework for analysing wallet recovery, including the delay	Blockchain wallets	FR-ACT-05
10	Banerjee et al. [10]	Preprint, 2026	Formal dead man's switch with release and delete modes	Preprint; trigger mechanism not fully described	FR-ACT-06, FR-ACT-08
11	Höltervennhoff et al. [11]	Paper, 2024	Recovery codes are valued for security and weak in usability	One email provider; self-selected users	FR-CRY-09, NFR-USE-03
12	Brubaker et al. [12]	Paper, 2014	Post-mortem data handling is stewardship, with responsibilities and relationships	Social network accounts; bereaved people, not planners	FR-OWN-02, FR-OWN-03
13	Holt et al. [13]	Paper, 2021	People value legacy planning and avoid it; life-time security habits conflict with post-mortem access	Two workshops, United Kingdom	FR-OWN-02, NFR-USE-04
14	Edwards and Harbinja [14]	Law article, 2013	The deceased have privacy interests worth protecting	United States and United Kingdom law	NFR-SEC-01
15	Whitten and Tygar [15]	Paper, 1999	Key concepts confuse users of public key tools	Old system, small test	FR-TRU-10, NFR-USE-05
16	Brooke [16]	Chapter, 1996	Ten-item scale giving one usability score	One overall score, no diagnosis	NFR-USE-01
17	Zhanabilova [17]	Dissertation, 2025	Covers digital asset regulation and inheritance, including Kazakhstan	Extensive document, specific chapters apply	proposal scope, risk register
18	Zakirov and Khayarova [18]	Paper, 2023	Civil legislation does not regulate the regime of a social network account (Russian law)	Russian law, not Kazakh	proposal scope
19	Civil Code, Special Part [19]	Law, current edition	Estate includes rights that outlive the person; capsule is not a will	Article text checked through secondary pages	proposal scope
20	Law on Personal Data [20]	Law, current edition	Personal data is stored in a database located in Kazakhstan	Edition to be rechecked on adilet.zan.kz	NFR-LAW-01

3.5 Comparison of approaches

Who decides that the event happened

The sources and the systems in section 4 give four answers. A timer alone is the plainest dead man's switch, and the formal treatment [10] and the tools in section 4 (Cipherwill, Just In Case) follow it. Its weakness is the one in the proposal: a long holiday looks the same as a death. One contact deciding alone is the Bitwarden model and, in practice, Google's and Apple's, and the whole safeguard is that single person. Guardian recovery [8][9] asks a threshold of people, but in wallets the guardians help a living owner who has lost a key, so the question "is the owner dead" never comes up. Our design joins the timer and the threshold: silence only starts the process, and release needs k confirmations and an unchallenged waiting period. No source was found that evaluates this combination for ordinary people, and the evaluation in DIP-21 against a simple dead man's switch is meant to supply that evidence.

Where trust sits

The password manager study [7] shows that a vendor's statement about zero knowledge says little about a malicious server. Its attack classes are the ones a legacy platform has too, because recovery, sharing

and stored ciphertext all exist there. The platform's answer is to keep every private key off the server (FR-CRY-03, FR-CRY-03a) and to verify tamper-evidence through AES-GCM tags (FR-CRY-01). Public-key authentication is addressed by FR-CRY-11 and tested by M3, subject to the comparison and threat-model limits described in section 3.2.3.

How shares are kept and renewed

Dealer-based Shamir sharing [1] is simple, runs once in the owner's browser and needs nothing from the shareholders. Proactive and evolving-committee schemes [3][10] hold up better over decades and need shareholders that stay online and cooperate. For relatives with a Telegram account the dealer-based choice is the realistic one. Its price is that shares go stale when a phone is lost, which the platform meets with periodic key checks (FR-CRY-10) and re-splitting (FR-CRY-08), both of which need the owner. If the owner has died and a trusted person's phone is lost, the remaining trusted persons must still reach k, so *n* greater than *k* is the only protection. FR-OWN-13 already recommends it.

Recovery for the owner

Recovery codes [11] work for a single user who keeps one secret in one place. Trusted-person recovery [8][9] spreads the risk but adds people the owner must trust. The platform uses a recovery key for the owner (FR-CRY-09, a Should requirement) and the trusted persons only for release. The study's findings on lost and non-working codes suggest the recovery key should be tested at registration, for example by asking the owner to enter part of it. This is proposed for the owner's wizard (NFR-USE-04); it is a suggestion and not something the study evaluated.

3.6 Research gap and how the project addresses it

In the reviewed sources, three things are missing together.

First, no work evaluates a consumer digital legacy service that combines check-ins, confirmation by several independent people and a cancellable waiting period. The closest formal work [10] handles the cryptography of release and deletion, and the closest working designs [8][9] handle guardians and delay for wallets. The platform's activation state machine (FR-ACT-06) and its evaluation against a dead man's switch baseline (objective 7 in the proposal) address this.

Second, there is little usable security evidence for people who hold a key without an account. The usability studies [11][13][15] concern users who sign up for a service, or planners with a password manager. Trusted persons and recipients here have no registration, and their keys sit in Telegram SecureStorage on a phone (CON-02, CON-03). The SUS target and the task tests in DIP-22 will give first data, with the caveat that five participants are a small sample.

Third, no scientific work was found on digital legacy tools for Kazakhstan, in either Russian or Kazakh, and the legal sources do not answer how accounts and personal data of third parties are treated. The proposal already limits the scope to a technical transfer of data and not a legal transfer of property, and the legal questions in 3.3.3 go to the supervisor and into the risk register (DIP-23).

3.7 Limitations of this review

Search engines and publisher pages were used to select sources that bear on decisions already in the proposal, so important work may be missing, especially in the older literature on timed release and on legacy services.

Two sources, [8] and [10], are preprints. Source [10] is from 2026 and has had little time to be tested. The papers on usability [11][13] come from Germany and the United Kingdom, and their users may differ from users in Kazakhstan. No source in Kazakh was found, and the Russian scholarship [17][18] is on Russian law with Kazakh material only in part. No court practice of Kazakhstan was reviewed. Full-text analysis of [7], [8] and [10], requested in the review of PR #14, remains to be documented; the summaries here must not be treated as a completed full-text verification.

References

1. A. Shamir, "How to share a secret," *Commun. ACM*, vol. 22, no. 11, pp. 612–613, Nov. 1979, doi: 10.1145/359168.359176.
2. A. Beimel, "Secret-sharing schemes: A survey," in *Coding and Cryptology (IWCC 2011)*, Lecture Notes in Computer Science, vol. 6639. Berlin, Germany: Springer, 2011, pp. 11–46.
3. A. Herzberg, S. Jarecki, H. Krawczyk, and M. Yung, "Proactive secret sharing or: How to cope with perpetual leakage," in *Advances in Cryptology – CRYPTO '95*, Lecture Notes in Computer Science, vol. 963. Berlin, Germany: Springer, 1995, pp. 339–352.
4. A. Biryukov, D. Dinu, and D. Khovratovich, "Argon2: New generation of memory-hard functions for password hashing and other applications," in *Proc. IEEE Eur. Symp. Security and Privacy (EuroS&P)*, 2016, pp. 292–302, doi: 10.1109/EuroSP.2016.31.
5. A. Biryukov, D. Dinu, D. Khovratovich, and S. Josefsson, "Argon2 memory-hard function for password hashing and proof-of-work applications," IETF, RFC 9106, Sep. 2021. [Online]. Available: https://www.rfc-editor.org/info/rfc9106 (accessed 22.10.2026).
6. M. Dworkin, "Recommendation for block cipher modes of operation: Galois/Counter Mode (GCM) and GMAC," NIST, Gaithersburg, MD, USA, Spec. Publ. 800-38D, Nov. 2007.
7. M. Scarlata, G. Torrisi, M. Backendal, and K. G. Paterson, "Zero knowledge (about) encryption: A comparative security analysis of three cloud-based password managers," in *Proc. 35th USENIX Security Symp.*, Philadelphia, PA, USA, USENIX Association, Aug. 2026. Full version: IACR Cryptol. ePrint Arch., Paper 2026/058. [Online]. Available: https://eprint.iacr.org/2026/058 (accessed 22.10.2026).
8. P. Chatzigiannis, K. Chalkias, A. Kate, E. V. Mangipudi, M. Minaei, and M. Mondal, "SoK: Web3 recovery mechanisms," IACR Cryptol. ePrint Arch., Paper 2023/1575, 2023. [Online]. Available: https://eprint.iacr.org/2023/1575 (accessed 22.10.2026).
9. P. Chatzigiannis, K. C. Wang, S. S. Arora, and M. Minaei, "A composability analysis framework for Web3 wallet recovery mechanisms," in *Proc. IEEE Symp. Security and Privacy (SP)*, San Francisco, CA, USA, IEEE, May 2025, pp. 1531–1546, doi: 10.1109/SP61157.2025.00158.
10. S. Banerjee, A. Bozhko, R. Heitjohann, and A. Rupp, "Dead man's switch cryptography," IACR Cryptol. ePrint Arch., Paper 2026/1352, 2026. [Online]. Available: https://eprint.iacr.org/2026/1352 (accessed 22.10.2026).
11. S. Höltervennhoff, N. Wöhler, A. Möhle, M. Oltrogge, Y. Acar, O. Wiese, and S. Fahl, "A mixed-methods study on user experiences and challenges of recovery codes for an end-to-end encrypted service," in *Proc. 33rd USENIX Security Symp.*, Philadelphia, PA, USA, 2024, pp. 7267–7284. [Online]. Available:

https://www.usenix.org/conference/usenixsecurity24/presentation/h%C3%B6ltervennhoff (accessed 22.10.2026).

12. J. R. Brubaker, L. S. Dombrowski, A. M. Gilbert, N. Kusumakaulika, and G. R. Hayes, "Stewarding a legacy: Responsibilities and relationships in the management of post-mortem data," in *Proc. SIGCHI Conf. Human Factors in Computing Systems (CHI '14)*, Toronto, ON, Canada, 2014, pp. 4157–4166.
13. J. Holt, J. Nicholson, and J. D. Smeddinck, "From personal data to digital legacy: Exploring conflicts in the sharing, security and privacy of post-mortem data," in *Proc. Web Conf. (WWW '21)*, 2021, pp. 2745–2756. [Online]. Available: https://nrl.northumbria.ac.uk/id/eprint/45486 (accessed 22.10.2026).
14. L. Edwards and E. Harbinja, "Protecting post-mortem privacy: Reconsidering the privacy interests of the deceased in a digital world," *Cardozo Arts & Entertainment Law J.*, vol. 32, no. 1, pp. 83–129, 2013.
15. A. Whitten and J. D. Tygar, "Why Johnny can't encrypt: A usability evaluation of PGP 5.0," in *Proc. 8th USENIX Security Symp.*, Washington, DC, USA, 1999, pp. 169–184.
16. J. Brooke, "SUS: A 'quick and dirty' usability scale," in *Usability Evaluation in Industry*, P. W. Jordan, B. Thomas, B. A. Weerdmeester, and I. L. McClelland, Eds. London, U.K.: Taylor & Francis, 1996, pp. 189–194.
17. А. Б. Жанабилова, «Наследование цифровых активов», дис. … канд. юрид. наук, Санкт-Петербургский государственный университет, Санкт-Петербург, 2025. [Online]. Available: https://disser.spbu.ru/files/2025/disser_zhanabilova.pdf (accessed 22.10.2026).
18. Р. Ю. Закиров и Э. А. Хаярова, «Перспектива включения аккаунта в социальной сети в наследственную массу», *Юридический вестник Дагестанского государственного университета*, т. 46, № 2, с. 99–104, 2023, doi: 10.21779/2224-0241-2023-46-2-99-104.
19. Гражданский кодекс Республики Казахстан (Особенная часть) от 1 июля 1999 года № 409-I, раздел 6 «Наследственное право», ст. 1040 (accessed 22.10.2026). [Online]. Available: https://adilet.zan.kz/rus/docs/K990000409_
20. Закон Республики Казахстан от 21 мая 2013 года № 94-V «О персональных данных и их защите», ст. 12 (accessed 22.10.2026). [Online]. Available: https://adilet.zan.kz/rus/docs/Z1300000094/z13094.htm

4. Existing System Comparison

This section compares five existing tools that pass a person's digital data to other people after death or long inactivity. The aim is to see what each tool covers, what it leaves open, and where the Digital Legacy Platform can do something different. Every statement comes from a source listed at the end, read on 22.10.2026.

Section	Responsible
4.1 Systems and criteria, 4.2 Comparison table, 4.3 Reading the table, 4.4 Gap, 4.5 Limitations	Aibyn Samat (DIP-10)
Verification of the cryptographic criteria (rows 3 and 6 of the table)	Alisher Medebaev (DIP-11)

4.1 Systems and criteria

The five systems are Google Inactive Account Manager, Apple Legacy Contact, Bitwarden Emergency Access, Cipherwill and Just In Case. They fall into three groups. Google and Apple work only inside their own accounts. Bitwarden is a password manager with a built-in handover. Cipherwill and Just In Case were built only for digital legacy.

The ten criteria come from the proposal (`docs/01-proposal.md`) and the requirements (`docs/06-requirements.md`). Each one is a decision the platform has to make for itself: what starts the release, how many people must agree, whether the key is split, whether there is a waiting period the owner can stop, how the owner is checked on, who can read the data, what the receiver needs, what can be passed on, what it costs and which languages it speaks. The criteria are the same for every system. Where a source says nothing, the cell says "not stated" and nothing is guessed.

The name "Just In Case" belongs to several products. This section uses the iOS app "Just In Case: Digital Legacy" from the App Store. It is not the will-writing site Just In Case Estates and not LegacyApp. Everything about it comes from the store listing, so it is the developer's own description and not an independent source.

4.2 Comparison table

Criterion	Google Inactive Account Manager	Apple Legacy Contact	Bitwarden Emergency Access	Cipherwill	Just In Case
1. What starts the release	The whole Google Account is inactive for 3, 6, 12 or 18 months [1][2]	A contact files a request with the access key and the death certificate [4] [5]	The trusted contact asks for access; nothing starts automatically [9]	No login for the chosen interval, 3 months by default, from weekly to annual [14]	Inactivity, then a five-level chain: email, SMS, AI phone call, cooling period, delivery [18]
2. Confirmation by several people (FR-ACT-04, FR-ACT-08)	No. Up to 10 contacts are notified and each gets the download link [2]	No. Any one Legacy Contact can decide alone, including deleting the data [4]	No. One contact is enough; the number of contacts is not limited [9]	No confirmation by people found; release follows the timeline [14]	Not stated [18]
3. Key split between trustees (FR-CRY-04)	No. The provider holds the data (see row 6)	Partly. The key is split into two parts: Apple stores an encrypted packet and the contact keeps an AES key; neither part alone reveals the key. This is a two-party split between the	No. The grantor's User Symmetric Key is encrypted with each grantee's RSA public key separately, so the whole key goes to one contact [9]	Not described. The home page mentions "pre-sharded contingency decryption keys" without saying how they are created or who holds the shards, and does not mention Shamir's scheme	Not stated [18]

Criterion	Google Inactive Account Manager	Apple Legacy Contact	Bitwarden Emergency Access	Cipherwill	Just In Case
		provider and one contact, not *k* of *n* trusted persons, and the contact's part does not include the iCloud Keychain key [4] [20]		[13]; the documentation describes a time-capsule key plus the beneficiary's public key and a timelock based on public random beacons [15]	
4. Waiting period the owner can stop (FR-ACT-05, FR-ACT-10)	No separate period. The inactivity time is the delay; the owner can edit or turn off the plan [1]; contacts have 3 months to download [2]	No waiting period. The only delay is Apple's review of the request [4] [6]; the owner can remove a contact while alive [7]	Yes. Wait time is set per contact, at least one day; the owner can approve or reject at any moment, and access opens by itself when the time ends [9][10]	Reminders at day 3, 30 and 90, key release at day 100 by default; any activity resets the countdown [14]	A "cooling period" is level 4 of the chain; its length and how to cancel are not stated [18]
5. Owner check-ins and channels (FR-ACT-02, FR-ACT-03)	No separate check-in; activity in Google services counts as presence [1]	None described [4]	None. The owner gets an email when the contact asks [9]	Yes. Free plan: email only; Premium adds calls, SMS and WhatsApp [13] [14]	Yes. Email, SMS and an AI phone call [18]
6. Provider can read the data (NFR-SEC-01)	Yes, by the look of it: Google sends the chosen data itself, so it holds it in readable form (my inference from [2])	By default yes. End-to-end encryption needs the optional Advanced Data Protection, and Mail, Contacts and Calendar are never covered [8]; how Legacy Contact access works together with Advanced Data Protection is not described in the security guide [20]	No, against an honest server. Zero-knowledge; the vault key reaches the contact encrypted with their public key [9]; the master key never leaves the client [21]. A study of a fully malicious server found 12 attacks on Bitwarden ([7] in section 3)	No, as claimed: two layers, a time-capsule key in the browser (AES-256-GCM) and the beneficiary's public key (ECDH on secp256k1) [15]. "Independently third-party audited" is claimed without naming the auditor [13]	No, as claimed by the developer: AES-256-GCM, SRP-6a login [18]. Not verified
7. What the receiver needs (FR-INV-01)	An email with a download link; whether a Google account is needed is not stated [2]	No Apple Account or Apple device is needed to file the request; after approval the contact gets a special Apple Account [4][5]	A Bitwarden account on the same server [9]	A beneficiary dashboard; registration is not stated [13]	Not stated [18]
8. What can be passed on	Chosen data of Google services only [2]	iCloud data. Not Keychain passwords, purchases or payment data [6]	The whole vault, including passwords and attachments [9]	Passwords, seed phrases, notes, files up to 1 GB on Premium [13]	Passwords, documents, crypto keys, notes [18]
9. Price	No fee stated [1]	No fee stated [4]	The owner needs Premium, $19.80 a year [9][12]; the contact can use a free account [9]	Free for 5 beneficiaries; Premium $40 a year [13]	Free in the App Store; in-app purchases not checked [17]
10. Kazakh and Russian interface (NFR-L10N-01)	The Google Account offers both [3]; the Inactive Account Manager page itself was not checked	Russian support pages exist [7]; Kazakh not found	Russian yes, Kazakh no [11]	English only according to a third-party listing [16]	English only [17]

4.3 Reading the table

Google and Apple fit the person who keeps everything inside one ecosystem. In both, one company holds the data and one contact is enough. Google starts on inactivity and mails a download link to every contact on the list. Apple starts on a death certificate and an access key, and any single Legacy Contact can even delete the data permanently. Neither passes on passwords for other services; Apple states this

for the Keychain explicitly. Neither asks the owner whether they are still around before releasing anything.

Bitwarden is the closest in cryptography and in the waiting period. The vault stays unreadable for the provider, and the owner can reject a request during a wait time of at least one day. Three things still limit it. The owner has to pay for Premium, the contact needs a Bitwarden account, and nothing checks on the owner: the process starts when a contact asks. My reading is that one contact who asks while the owner is on a long trip without email ends up with the whole vault, because nobody else has to agree.

Cipherwill and Just In Case went the other way. They check on the owner with email, SMS or phone calls and encrypt on the device, but the release depends on silence alone. A long holiday, a lost phone or a broken laptop look the same to the timer as a death, and no second person is asked. Cipherwill softens this with a long timeline, 100 days by default, and Just In Case with a cooling period, but in both cases the owner is the only safeguard. Cipherwill's SMS and phone check-ins sit behind the paid plan. Just In Case is a young app by one developer, and none of its security claims could be confirmed.

One more product points the same way. LegacyApp lets the owner add Trusted Friends, and access opens as soon as at least one of them confirms [19]. That is closer to the idea of human confirmation, but it is still one person, not *k* of *n*.

4.4 Gap

In the sources read for this section, none of the five combines the three things the proposal builds on: confirmation by several independent people, a waiting period the owner can stop, and data the provider cannot read. Each has at most two of them. Bitwarden has the waiting period and zero-knowledge encryption (against an honest server, see section 4.6) but needs only one contact. Cipherwill and Just In Case have zero-knowledge claims and check-ins but no human confirmation. Google and Apple have a single contact or inactivity as the trigger and a provider that can read the data. A false release is therefore only guarded by the owner's own reaction, and a malicious or mistaken single contact or timer is enough to start it.

The second gap is local. None of the five offers a Kazakh interface, and Russian is available only in the large ecosystems and in Bitwarden. None of them mentions Kazakhstan inheritance or personal data rules. The proposal's claim that no such service is localized for Kazakhstan holds for these five.

This is the gap the Digital Legacy Platform targets: missed check-ins start the process, *k* of *n* trusted persons must confirm with key shares split by Shamir's scheme, the owner can cancel during the waiting period, and the server stores only ciphertext. It adds a Kazakh and Russian interface and works for trusted persons and recipients without registration through Telegram.

4.5 Limitations

The cryptographic rows (3 and 6) rest on vendor documentation and marketing pages. Claims marked "as claimed" were not tested; they were checked against the vendors' security documentation in DIP-11 (section 4.6). The statement that Google can read the data is the authors' inference from how the feature works, not a quote from Google. The Google security blog post dates from 2021, so the current settings screen should be rechecked before the defense. The Bitwarden price comes from press coverage of its January 2026 change, not from a plan page. The row for Just In Case comes only from the App Store listing. Prices and plans were read on 22.10.2026 and can change.

4.6 Verification of the cryptographic criteria (DIP-11)

Rows 3 and 6 were checked on 22.10.2026 against the vendors' own security documentation rather than marketing pages.

System	Source checked	Result
Google Inactive Account Manager	Help page [1]	No security description is published; row 6 remains an inference from how the feature works
Apple Legacy Contact	Apple Platform Security guide [20]	Row 3 corrected: the access key is split between Apple and the contact (two parts, both needed), not shared among several people. Row 6 refined: the guide does not say how Legacy Contact access interacts with Advanced Data Protection
Bitwarden Emergency Access	Help pages [9] [10], Security Whitepaper [21]	Confirmed: the User Symmetric Key is wrapped with each grantee's RSA public key; no key splitting; minimum wait time of one day, the owner can approve or deny. The whitepaper confirms that the master password and the stretched master key are never sent to the server: the client sends a hash of the master key, which the server hashes again (PBKDF2-SHA256, 600,000 iterations). The platform follows the same model for owner login (FR-CRY-12). Zero-knowledge holds against an honest server only: Scarlata et al. ([7] in section 3) report 12 attacks by a malicious server, which is why the platform adds key verification (FR-CRY-11)
Cipherwill	Cascade encryption page [15], home page [13]	Confirmed that splitting is not described; refined with the two encryption layers and the timelock; the audit claim names no auditor
Just In Case	App Store description [18]	No technical documentation exists beyond the store listing; row 6 stays "as claimed"

The comparison in section 4.4 is unchanged and becomes more precise: even the system with a split key (Apple) divides it between the provider and a single contact, while none of the five requires several independent people to confirm the event.

References

1. Google, "About Inactive Account Manager" (accessed 22.10.2026). https://support.google.com/accounts/answer/3036546?hl=en
2. Google Security Blog, "Google Protects Your Accounts – Even When You No Longer Use Them", 5 October 2021 (accessed 22.10.2026). https://security.googleblog.com/2021/10/google-protects-your-accounts-even-when.html
3. Google, account sign-up page with the list of interface languages (accessed 22.10.2026). https://accounts.google.com/SignUp?hl=lv
4. Apple, "How to add a Legacy Contact for your Apple Account" (accessed 22.10.2026). https://support.apple.com/102631
5. Apple, "Request access to an Apple Account as a Legacy Contact" (accessed 22.10.2026). https://support.apple.com/en-gb/102678
6. Apple, "Data that a Legacy Contact can access", published 16 April 2026 (accessed 22.10.2026). https://support.apple.com/en-sg/103128

7. Apple, "Remove a Legacy Contact from your Apple Account", Russian-language support page (accessed 22.10.2026). https://support.apple.com/ru-ru/126507
8. BleepingComputer, "Apple rolls out end-to-end encryption for iCloud backups" (accessed 22.10.2026). https://www.bleepingcomputer.com/news/apple/apple-rolls-out-end-to-end-encryption-for-icloud-backups/
9. Bitwarden, "About Emergency Access" (accessed 22.10.2026). https://bitwarden.com/help/emergency-access/
10. Bitwarden, "Add & Manage Trusted Emergency Contacts" (accessed 22.10.2026). https://bitwarden.com/help/add-and-manage-trusted-emergency-contacts/
11. Bitwarden, "Localization" (accessed 22.10.2026). https://bitwarden.com/help/localization/
12. AlternativeTo, "Bitwarden enhances Premium and Families plans with more security features & raises prices", January 2026 (accessed 22.10.2026). https://alternativeto.net/news/2026/1/bitwarden-enhances-premium-and-families-plans-with-more-security-features-and-raises-prices/
13. Cipherwill, home page with plans and security overview (accessed 22.10.2026). https://www.cipherwill.com/
14. Cipherwill, "Will Execution Timeline" (accessed 22.10.2026). https://www.cipherwill.com/i/how-execution-timeline-works
15. Cipherwill, "Cascade Encryption" (accessed 22.10.2026). https://www.cipherwill.com/i/cascade-encryption
16. Software Finder, "Cipherwill", third-party listing (accessed 22.10.2026). https://softwarefinder.com/legal/cipherwill
17. App Store (US), "Just In Case: Digital Legacy", listing with price and language (accessed 22.10.2026). https://apps.apple.com/us/app/just-in-case-digital-legacy/id6759258331
18. App Store (CA), "Just In Case: Digital Legacy", developer description (accessed 22.10.2026). https://apps.apple.com/ca/app/just-in-case-digital-legacy/id6759258331
19. LegacyApp, "How are my notes in LegacyApp passed to my Beneficiary?" (accessed 22.10.2026). https://legacy.app/en/help-center/how-are-my-notes-in-legacyapp-passed-to-my-beneficiary
20. Apple, "Legacy Contact security", Apple Platform Security guide (accessed 22.10.2026). https://support.apple.com/guide/security/secebf027fb8/web
21. Bitwarden, "Bitwarden Security Whitepaper", sections "Hashing, key derivation, and encryption" and "Emergency access" (accessed 23.10.2026). https://bitwarden.com/help/bitwarden-security-white-paper/

5. Technology Comparison

Each key decision compares 2–3 alternatives against criteria derived from the requirements (`docs/06-requirements.md`). Scores: 1 (poor) – 5 (excellent).

Section	Responsible
5.1–5.5 Server platform, data storage, cryptographic libraries and key storage, component interaction, summary	Alisher Medebaev (DIP-12)
5.6–5.7 Frontend framework, notification services	Aibyn Samat (DIP-13)

5.1 Server platform

Criterion	Related requirements	Java + Spring Boot	Node.js + NestJS (TypeScript)	Python + FastAPI
Transaction management for state machine transitions	FR-ACT-06, FR-ACT-08	5 (Spring `@Transactional`)	3	3
Security framework (authentication, 2FA, rate limiting)	NFR-SEC-04…06	5 (Spring Security, Bucket4j)	4	3
Reliable persistent scheduling	FR-ACT-03, NFR-REL-01	5 (Quartz)	4	3
Strong static typing and long-term maintainability	—	5	4	3
Development speed for a 2-person team	—	3	5	4
Team experience	—	4	4	3
Total		**27**	24	19

Decision: Java 21 with Spring Boot 4.1.

Rationale: under the zero-knowledge architecture (NFR-SEC-01) all encryption happens in the browser, so the server language does not need cryptographic libraries. The server's main job is to run the activation state machine reliably. Its correctness depends on transactions, persistent timers and security, which are the strengths of Spring (Spring Data JPA, Spring Security, Quartz). The difference in languages between frontend and backend is covered by generating a TypeScript client from the OpenAPI specification.

Version: Spring Boot 3.5 reached the end of open-source support on 30 June 2026, so the project starts on Spring Boot 4.1, the current stable line recommended for new projects. Spring Boot 4 requires Java 17 or later; Java 21 (LTS) is used.

5.2 Data storage

Capsules mostly contain credentials, instructions, messages and a limited number of photos and documents (up to 50 MB per capsule, NFR-CAP-01). All files are encrypted in the browser before upload.

Criterion	Related requirements	PostgreSQL only (encrypted files in `bytea`)	PostgreSQL + encrypted files on the server file system	PostgreSQL + S3-compatible object storage
ACID transactions for state machine transitions	FR-ACT-06, FR-ACT-08	5	5	5
File and its metadata	FR-ACT-10	5	2	2

Criterion	Related requirements	PostgreSQL only (encrypted files in `bytea`)	PostgreSQL + encrypted files on the server file system	PostgreSQL + S3-compatible object storage
saved or deleted atomically				
Storage of encrypted files up to 50 MB per capsule	NFR-CAP-01	4	5	5
One backup covers all data	—	5	3	2
No extra infrastructure, no cost	—	5	4	2 (extra service or paid cloud)
All data on one server in Kazakhstan	NFR-LAW-01	5	5	3
Scalability to large volumes	—	2	3	5
Total		**31**	27	24

Decision: PostgreSQL only: metadata, encrypted shares, activation state, scheduler jobs and encrypted capsule files.

Rationale: for capsules limited to 50 MB, storing encrypted files in the database keeps every change transactional (for example, deleting a capsule removes its files in the same transaction), needs one backup and no extra service or cost. Object storage scales better but is not needed at this volume. File access is hidden behind a `FileStorage` interface, so an S3-compatible storage can be added later without changing the rest of the system. Only ciphertext is stored (NFR-SEC-01).

5.3 Cryptographic libraries

All operations run in the browser (NFR-SEC-01); only established implementations are allowed (NFR-SEC-02).

a) Symmetric encryption of capsules (FR-CRY-01)

Criterion	WebCrypto API (AES-256-GCM)	libsodium.js (XChaCha20-Poly1305)	node-forge / SJCL
Built into browsers, no extra code	5	2	2
Performance on large files	5	4	2
Non-extractable keys	5	2	1
Maintenance status	5	5	2
Total	**20**	13	7

b) Key derivation from the master password (FR-CRY-02)

Criterion	libsodium.js `crypto_pwhash` (Argon2id, `libsodium-wrappers-sumo`)	argon2-browser (WASM)	PBKDF2 (WebCrypto)
Memory-hard algorithm (resistance to GPU brute force)	5	5	1
Already used for other operations (one dependency)	5	2	4

Criterion	libsodium.js `crypto_pwhash` (Argon2id, `libsodium-wrappers-sumo`)	argon2-browser (WASM)	PBKDF2 (WebCrypto)
Maintenance status	5	3	5
Total	**15**	10	10

Note: `crypto_pwhash` is included only in the sumo build of libsodium.js (`libsodium-wrappers-sumo`), so this build is used.

c) Public-key encryption of shares (FR-CRY-03, FR-CRY-05, FR-CRY-06)

Criterion	libsodium.js sealed boxes (X25519)	WebCrypto ECDH + AES-GCM	OpenPGP.js
Ready primitive for "encrypt to a public key"	5	2	4
Consistent support in browsers and Telegram WebView	5	4 (X25519 in all major browsers since 2025, missing in older versions)	5
Simplicity, small risk of misuse	5	2	3
Total	**15**	8	12

d) Shamir's Secret Sharing (FR-CRY-04)

Criterion	`shamir-secret-sharing` (Privy)	`secrets.js-grempe`	Own implementation over GF(256)
Independent security audit	5 (audited by Cure53 and Zellic)	1	1
Dependencies	5 (none)	4	5
Maintenance status	4	2	—
Compliance with NFR-SEC-02	yes	yes	**no**
Total	**14**	7	excluded

Note: the selected library requires at least 2 shares and a threshold of at least 2, which is standard for Shamir's scheme (with $k = 1$ the polynomial is a constant, so every share equals the secret). Therefore $k = 1$ is handled without splitting: the capsule key is encrypted separately for each trusted person (FR-CRY-04).

Decision: WebCrypto API for AES-256-GCM; libsodium.js (`libsodium-wrappers-sumo`) for Argon2id and X25519 sealed boxes; `shamir-secret-sharing` for key splitting when $k \geq 2$.

Rationale: the browser's native AES-GCM is the fastest option and keeps keys non-extractable. libsodium covers the operations that WebCrypto lacks or supports unevenly. The Shamir library is the only option with a public independent audit. An own implementation is excluded by NFR-SEC-02; known implementation pitfalls (for example, a zero leading coefficient reducing the effective threshold) are another argument against writing it ourselves.

e) Storage of the private key of trusted persons and recipients (FR-CRY-03a, FR-INV-01)

Trusted persons and recipients have no account, so their private key cannot be protected by a password-derived key as for the owner.

Criterion	Telegram SecureStorage (Keychain / Keystore)	Telegram CloudStorage	Telegram DeviceStorage	Browser IndexedDB in a separate web cabinet
Key stays on the user's device	5	1 (stored on Telegram servers)	5	5
Hardware-backed protection at rest	5	1	2	2
Works without registration in our system	5	5	5	1
Survives reinstall / device change	2 (restore only on the same device)	5	1	1
Client support	3 (mobile clients; desktop to be verified)	5	4	5
Total	**20**	17	17	14

Decision: Telegram SecureStorage.

Rationale: it is the only option where the key stays on the device in hardware-backed storage and no registration is needed. CloudStorage would let Telegram hold the keys, which breaks the zero-knowledge property. The weak point — loss of the key when the phone is replaced — is covered by periodic key checks and re-creation of shares (FR-CRY-10, FR-CRY-08).

5.4 Component interaction

a) Client–server API

Criterion	Related requirements	REST + OpenAPI	GraphQL	tRPC
Simple to document and demonstrate (API examples)	DIP-20	5	3	2
Per-endpoint rate limiting	NFR-SEC-05	5	2	4
Binary upload of encrypted files	FR-CRY-01	5	2	3
Independent of client technology (web application, Telegram bot and Mini App)	FR-INV-01, FR-ACT-02	5	4	1
Support in Java / Spring	—	5 (Spring Web, springdoc-openapi)	4	1
Total		**25**	15	11

Decision: REST API described with OpenAPI (springdoc-openapi); the TypeScript client for the frontend is generated from the specification.

Rationale: REST is the easiest to document, secure per endpoint and use from different clients (web application, Telegram bot and Mini App). tRPC is excluded because it requires TypeScript on both sides.

b) Timers and background jobs (check-ins, escalation, waiting period, notifications)

Criterion	Related requirements	Quartz Scheduler (JDBC JobStore in PostgreSQL)	JobRunr	Spring `@Scheduled`
Jobs survive server restart	NFR-REL-01	5	5	1
Transactional with state changes (same database and transaction)	FR-ACT-06	5	3	2
Retries for failed notifications	NFR-REL-02	4	5	1

Criterion	Related requirements	Quartz Scheduler (JDBC JobStore in PostgreSQL)	JobRunr	Spring `@Scheduled`
Maturity and documentation	—	5	4	5
No extra infrastructure	—	5	5	5
Total		**24**	22	14

Decision: Quartz Scheduler with JDBC JobStore in the same PostgreSQL database.

Rationale: when Quartz uses the application's data source, it takes part in Spring-managed transactions. A timer is therefore created or cancelled in the same transaction as the activation state change, and a restart cannot lose or duplicate a step. JobRunr is more convenient for retries, but it does not provide the same transactional coupling.

c) Client for trusted persons and recipients (FR-INV-01…05)

Criterion	Related requirements	Telegram bot + Mini App	Separate web cabinet with registration	Telegram bot messages only (no Mini App)
No registration required	FR-INV-01	5	1	5
Client-side cryptography possible (WebCrypto, libsodium)	FR-CRY-03a, FR-CRY-06	5	5	1
Secure on-device key storage	FR-CRY-03a	5 (SecureStorage)	3	1
Phone number verification	FR-INV-05	5 (contact sharing)	3 (SMS code)	5
Familiarity for users in Kazakhstan	—	5	3	5
Total		**25**	15	17

Decision: Telegram bot (Telegram Bot API) for invitations, check-ins and notifications, and a Telegram Mini App for all cryptographic operations of trusted persons and recipients.

Rationale: bot messages alone cannot run cryptography on the device, and a separate web cabinet requires registration. The Mini App runs the same web cryptography code as the owner's web application. Limitation: a bot cannot write first (CON-01), so invitations are sent by SMS and optionally by the owner from their own Telegram account.

5.5 Summary of decisions

Decision	Choice
Server platform	Java 21 + Spring Boot 4.1
Data storage	PostgreSQL (Spring Data JPA), encrypted files in `bytea` behind a `FileStorage` interface
Capsule encryption	WebCrypto API (AES-256-GCM), in the browser
Key derivation	libsodium.js `libsodium-wrappers-sumo` (Argon2id), in the browser
Share encryption	libsodium.js sealed boxes (X25519), in the browser and Mini App
Secret sharing	`shamir-secret-sharing` (audited by Cure53 and Zellic) for $k \geq 2$; no splitting for $k = 1$
Key storage of trusted persons and recipients	Telegram SecureStorage
Client for trusted persons and recipients	Telegram bot + Telegram Mini App

Decision	Choice
Client–server API	REST + OpenAPI (springdoc-openapi), generated TypeScript client
Background jobs	Quartz Scheduler (JDBC JobStore)
Rate limiting	Bucket4j
Frontend framework	React with TypeScript, built with Vite as a single-page application; the Telegram Mini App is a second entry point of the same code base
Notification services	SMS: SMSC.kz (HTTP API); email: Resend (SMTP via Spring Mail); Telegram: Bot API with the TelegramBots library (webhook); WhatsApp not used in this version

5.6 Frontend framework

The frontend has two entry points built from one code base: the owner web application and the Telegram Mini App for trusted persons and recipients (section 5.4c). Both run all cryptography in the browser (NFR-SEC-01).

Criterion	Related requirements	React + Vite (single-page application)	Next.js (React)	Vue 3 + Vite
One code base for the owner web application and the Mini App	FR-CRY-06, FR-CRY-07, FR-INV-01	5	3	5
Tooling for Telegram Mini Apps	FR-CRY-03a, FR-INV-01	5 (official React template, SDK package and TelegramUI component library) [17][18]	4 (same React libraries, but the official template does not target Next.js)	3 (official Vue binding of the SDK, no UI kit found) [16]
No server-side JavaScript inside the trust boundary	NFR-SEC-01, NFR-SEC-07	5 (static files only)	3 (server rendering needs a Node server; a static export removes the benefit of Next.js)	5
Browser-only crypto libraries (WebCrypto, libsodium WASM)	FR-CRY-01…07	5	3 (must be kept out of server rendering)	5
Kazakh and Russian localization	NFR-L10N-01, NFR-L10N-02	5 (react-i18next)	5 (next-intl)	5 (vue-i18n)
Responsive and accessible components	NFR-USE-07, NFR-USE-08	5	5	4
Deployment	—	5 (static files behind any web server)	3 (Node runtime or static export)	5
Familiarity of the team	—	4	4	3
Total		**39**	30	35

Decision: React with TypeScript, built with Vite as a single-page application. The Mini App is a second entry point of the same code base and uses the Telegram Mini Apps SDK for React and the TelegramUI components.

Rationale: the application has no public pages that need search indexing, and every sensitive operation happens in the browser. Server rendering therefore adds a Node server to the trust boundary and a rule that crypto code must never run on it, without giving anything back. A single-page application is a set of static files, so the Spring Boot backend stays the only server component. React has the most complete tooling for Mini Apps among the three options. The TypeScript API client is generated from the OpenAPI specification (section 5.4a).

Limitations: the first page load needs JavaScript, which is acceptable for an application behind a login. The component library for the owner web application is chosen at the implementation stage; TelegramUI is used only in the Mini App. The score for team familiarity is the authors' own judgement.

5.7 Notification services (SMS, Telegram, email)

The notification catalogue is in section 6.7 (FR-NOT-01). SMS and Telegram carry check-ins and invitations (FR-ACT-02, FR-INV-02), email carries owner notifications (FR-ACT-09). Every provider is hidden behind an interface (`SmsGateway`, `EmailGateway`, `TelegramGateway`), so it can be replaced without changing the activation logic.

5.7.1 SMS gateway

A message to a phone number in Kazakhstan costs far less through a local provider. SMSC.kz lists prices per message including VAT of 12.10 to 23.50 tenge at the lowest volume plan, depending on the operator and the type of traffic [10]; Twilio lists $0.3382 per segment [21]. Infobip and Sinch are not compared: a secondary source lists them at $0.20–0.24 per segment [20], which is again several times the local price.

Criterion	Related requirements	SMSC.kz	Twilio
Price per SMS to numbers in Kazakhstan	F-12 (willingness to pay)	5 (12.10–23.50 tenge)	1 ($0.3382 per segment)
Starting without registering an own sender name	FR-INV-02, FR-ACT-02	5 (common sender names SMSC.KZ, INFORM and InfoSMS are free) [10]	2 (alphanumeric sender ID is pre-registered, about 3 weeks; a dynamic sender ID is not preserved) [12]
Payment in tenge, invoices with VAT	—	5	2
API and delivery reports	NFR-REL-02, FR-ACT-09	4 (HTTP and JSON API, delivery status by request, available for one day) [11]	5 (mature SDKs, status callbacks)
Kazakh and Russian text	NFR-L10N-03	4 (UTF-8, 70 characters per message, 67 when split) [11]	4 (UCS-2 supported, segment length not stated) [12]
Total		**23**	14

Decision: SMSC.kz through its HTTP API, with the free common sender name at the start. An own sender name costs a monthly fee per operator (14,500 tenge for K'cell, 17,500 for Beeline, 20,800 for Tele2 and Altel) [10] and takes about three weeks to register [12], so it is left for the production stage.

Cost estimate: with the default check-in interval of 30 days, an owner generates 12 check-in SMS per year, plus up to 5 invitations. At the highest listed price of 23.50 tenge this is about 400 tenge per owner per year, far below the 500–1000 tenge per month that respondents named (F-12, preliminary). If the owner is silent, a full activation adds 3 check-ins and about one SMS per day of the waiting period.

Limitations: the prices are for the lowest volume plan and were read on 22.10.2026. SMS in Kazakhstan has a 70-character limit per Cyrillic message, so templates are kept short (NFR-L10N-03). Where the provider stores logs, and whether this conflicts with NFR-LAW-01, is not confirmed and goes into the risk register.

5.7.2 Email service

Email carries only owner notifications, such as the confirmation of registration and the waiting-period alerts (FR-ACT-09). It is not a check-in channel (FR-ACT-02), because one respondent may not open email for a week (F-05). The volume is small.

Criterion	Related requirements	Resend	Amazon SES	Own mail server (Postfix)
Cost at the expected volume	—	5 (free plan: 3,000 emails per month) [15]	4 ($0.10 per 1,000 emails, no free plan) [15]	3 (server and time)
Setup and maintenance effort	—	5	3	1 (SPF, DKIM, DMARC, IP reputation)
Delivery to common mailboxes	FR-ACT-09	4	4	2
Standard SMTP access from Spring	NFR-REL-02	5	5	5
Data stays in Kazakhstan	NFR-LAW-01	2	2	5
Total		**21**	18	16

Decision: Resend, used through standard SMTP from Spring Mail, so SES or an own server can be connected by changing the configuration.

Rationale: it is the cheapest and fastest option to set up. The messages contain no capsule data, keys or titles (FR-NOT-07), only the owner's email address and a short text.

Limitations: the email address of the owner passes through a provider outside Kazakhstan, which is recorded as a risk for NFR-LAW-01 (a Should requirement). The daily sending limit of the free plan must be checked before the demo.

5.7.3 Telegram bot integration

Telegram has no cost for the bot. A bot can send about 30 messages per second to different users, and no more than one message per second to one chat [13]. This is enough for the planned volume, but the integration must handle HTTP 429 and retry (NFR-REL-02).

Criterion	Related requirements	TelegramBots library with Spring Boot webhook starter	Direct Bot API calls from Spring	Separate Node.js bot service (grammY)
Same runtime and one deployment as the backend	—	5	5	2
Same transaction and scheduler as the activation state machine	FR-ACT-06, NFR-REL-01	5	5	2 (calls between two services)
Effort for commands, buttons, contact sharing	FR-INV-04, FR-INV-05	5	2 (own types and update parsing)	4
Webhook support	NFR-REL-01	5 (webhook module and starter) [19]	4	5
Dependency risk	NFR-SEC-02	3 (community library)	5 (no extra dependency)	4
Total		**23**	21	17

Decision: the TelegramBots library with its Spring Boot webhook starter, behind a `TelegramGateway` interface.

Rationale: the bot needs no secrets of its own: keys stay in the Mini App (section 5.3e), and the bot only sends messages and receives button presses. Running it inside the backend keeps timers, state changes and notifications in one transaction.

Limitations: compatibility of the library with Spring Boot 4.1 is not checked yet and is the first task of the prototype. If it fails, the fallback is direct Bot API calls behind the same interface. A bot cannot write first (CON-01), so the first contact is always an SMS invitation.

5.7.4 WhatsApp as an additional channel

One respondent named WhatsApp for check-ins (F-05), and trusted persons without Telegram would be unable to take part (F-16). Two options are compared.

Criterion	Related requirements	Telegram and SMS only	Add the WhatsApp Business Platform
Trusted persons can store a key on the device and decrypt	FR-CRY-03a, FR-CRY-06	5 (Mini App with SecureStorage)	1 (no equivalent of the Mini App)
Cost	F-12	4 (Telegram free, SMS 12–24 tenge)	2 (each delivered template message is charged; Kazakhstan is a separate price market since 1 October 2026) [14]
Setup effort	—	4	2 (business-initiated messages need approved templates) [14]
Reach of owners who prefer WhatsApp	F-05	3 (SMS reaches all three respondents)	4
Total		**16**	9

Decision: Telegram and SMS only. WhatsApp stays in the list of future improvements (FR-NOT-11, priority Won't) and may be reconsidered for owner notifications, where no key storage is needed.

Limitations: the rate for Kazakhstan was not read, because the page links to rate cards instead of listing figures [14]. A relative without Telegram cannot take part in this version. The cabinet warns the owner and recommends *n* greater than *k* (FR-OWN-13).

5.7.5 Summary

Channel	Used for	Receivers	Provider and integration
SMS	Invitations, check-ins, fallback notifications	Owner, trusted persons, recipients	SMSC.kz, HTTP API
Telegram	Check-ins, confirmation requests, notifications, Mini App	Owner, trusted persons, recipients	Bot API, TelegramBots library with webhook
Email	Registration, waiting-period alerts	Owner	Resend through SMTP
WhatsApp	Not used in this version	—	Future work

References

1. Cure53, "Audit report: Privy SSS library." https://cure53.de/audit-report_privy-sss-library.pdf
2. `shamir-secret-sharing` package. https://www.npmjs.com/package/shamir-secret-sharing
3. Privy, "Shamir secret sharing deep dive." https://privy.io/blog/shamir-secret-sharing-deep-dive
4. Privy, "Zero leading coefficients." https://privy.io/blog/zero-leading-coefficients-cryptography

5. `shamir-secret-sharing` README (constraints and audits). https://unpkg.com/shamir-secret-sharing@0.0.4/README.md
6. libsodium.js README (standard and sumo builds). https://cdn.jsdelivr.net/npm/libsodium-wrappers-sumo@0.8.4/README.md
7. Telegram, "Telegram Mini Apps" (SecureStorage, CloudStorage, DeviceStorage). https://core.telegram.org/bots/webapps
8. HeroDevs, "Spring Boot versions, EOL dates and latest releases." https://www.herodevs.com/blog-posts/spring-boot-versions-eol-dates-and-latest-releases-april-2026
9. J. Fernández, "Can I use Secure Curves in the Web Platform?" Igalia. https://blogs.igalia.com/jfernandez/?p=1913
10. SMSC.kz, "Tariffs" (accessed 22.10.2026). https://smsc.kz/tariffs/
11. SMSC.kz, "HTTP API" (accessed 22.10.2026). https://smsc.kz/api/http/?lang=en
12. Twilio, "Kazakhstan SMS guidelines" (accessed 22.10.2026). https://www.twilio.com/en-us/guidelines/kz/sms
13. Telegram, "Bots FAQ" (accessed 22.10.2026). https://core.telegram.org/bots/faq
14. Meta, "Pricing on the WhatsApp Business Platform" (accessed 22.10.2026). https://developers.facebook.com/documentation/business-messaging/whatsapp/pricing.md
15. CostBench, "Amazon SES vs Resend pricing" (accessed 22.10.2026). https://costbench.com/compare/amazon-ses-vs-resend/
16. Telegram Mini Apps documentation, "@telegram-apps/sdk-vue" (accessed 22.10.2026). https://docs.telegram-mini-apps.com/packages/telegram-apps-sdk-vue
17. Telegram Mini Apps, React template (accessed 22.10.2026). https://github.com/Telegram-Mini-Apps/reactjs-js-template
18. Telegram Mini Apps, TelegramUI component library (accessed 22.10.2026). https://github.com/telegram-mini-apps-dev/TelegramUI
19. rubenlagus, TelegramBots Java library (accessed 22.10.2026). https://github.com/rubenlagus/TelegramBots
20. Sent.dm, "Kazakhstan SMS pricing", secondary source (accessed 22.10.2026). https://sent.dm/en/resources/sms-pricing/kazakhstan-sms-pricing
21. Twilio, "SMS pricing for Kazakhstan" (accessed 22.10.2026). https://www.twilio.com/en-us/sms/pricing/kz

6. Requirements Specification

Priority: MoSCoW (Must / Should / Could / Won't)

Source codes: PRP — project proposal; LIT — literature review; LAW — legislation of the Republic of Kazakhstan; ASM — assumption, to be confirmed by interviews (DIP-5, DIP-6); INT — interviews, see 02-relevance-evidence (finding IDs F-xx)

Terms

- **Capsule** — an encrypted set of data (credentials, instructions, files, messages) intended for one or more recipients.
- **Capsule key (CK)** — a random 256-bit key that encrypts one capsule.
- **Share** — one of *n* parts of the capsule key created with Shamir's Secret Sharing; any *k* shares reconstruct the key. When *k* = 1, the key is not split and each trusted person receives an encrypted copy of it.
- **Mini App** — a web application opened inside Telegram; used by trusted persons and recipients, who have no account in the system.
- **SecureStorage** — Telegram Mini App storage backed by the phone's Keychain (iOS) or Keystore (Android).

Section	Responsible
6.1 Cryptographic core, 6.2 Hybrid activation, 6.3 Invitation and identity, 6.4 Security, reliability and performance NFRs, 6.9 Constraints	Alisher Medebaev (DIP-14)
6.5 Owner cabinet, 6.6 Trusted person and recipient interface (bot and Mini App), 6.7 Notifications, 6.8 Usability and localization NFRs	Aibyn Samat (DIP-15)

6.1 Functional requirements — Cryptographic core (FR-CRY)

ID	Requirement	Priority	Source	Acceptance criteria
FR-CRY-01	The system shall encrypt capsule content in the owner's browser with AES-256-GCM using a random 256-bit capsule key before upload.	Must	PRP, LIT	Network traffic and the database contain only ciphertext; modified ciphertext fails to decrypt (authentication tag check).
FR-CRY-02	The system shall derive the owner's key-encryption key from the master password with Argon2id in the browser. The master password shall never be sent to the server.	Must	PRP, LIT	Argon2id parameters are documented; no request contains the master password or a value from which it can be directly obtained.
FR-CRY-03	The system shall generate an X25519 key pair for the owner in the browser; the owner's private key shall be stored on the server only encrypted with the key from FR-CRY-02.	Must	LIT	The stored private key cannot be used without the master password; the database contains no plaintext private keys.
FR-CRY-03a	The system shall generate an X25519 key pair for each trusted person and recipient inside the Telegram Mini App on their device and store the private key only in Telegram SecureStorage. Only the public key is sent to the server.	Must	PRP	The private key never appears in network traffic, in the database or in Telegram CloudStorage; the server holds only the public key.
FR-CRY-04	If $k \geq 2$, the system shall split the capsule key into *n* shares with threshold *k* ($2 \leq k \leq n \leq 5$) using Shamir's Secret Sharing from an audited library. If $k = 1$, the key shall not be split; each of the *n* trusted persons receives the capsule key encrypted for them (FR-CRY-05).	Must	PRP, LIT	For $k \geq 2$, every combination of *k* shares reconstructs the key and no combination of $k-1$ shares produces it; for $k = 1$, any single trusted person's copy restores the key.
FR-CRY-05	The system shall encrypt each share (or, for $k = 1$, each copy of the capsule key) with the public key of the	Must	PRP	The server stores only encrypted shares; a share can be decrypted

ID	Requirement	Priority	Source	Acceptance criteria
	corresponding trusted person before it leaves the owner's browser.			only with the private key of its trusted person.
FR-CRY-06	When confirming the event, the trusted person's Mini App shall decrypt their share with the private key from SecureStorage and re-encrypt it with each recipient's public key.	Must	PRP	The submitted share is readable only by the recipient; the server, Telegram and other trusted persons cannot decrypt it.
FR-CRY-07	After release, the recipient's Mini App shall reconstruct the capsule key from *k* shares and decrypt the capsule locally.	Must	PRP	The recipient sees the original content; decryption happens without sending the key to the server.
FR-CRY-08	The system shall re-split the capsule key and invalidate old shares when the owner changes the trusted persons, *k* or *n*.	Must	ASM	Old shares cannot reconstruct the new key; removed trusted persons lose the ability to participate.
FR-CRY-09	The system shall generate a recovery key at registration that lets the owner regain access if the master password is forgotten. It is shown once and can be printed.	Should	ASM	An owner who lost the password restores access with the recovery key; without the password and the recovery key, access is impossible.
FR-CRY-10	Once every 180 days the system shall check that each trusted person's and recipient's private key is still present in SecureStorage. The check requires one tap: the bot sends a button, the Mini App verifies the key automatically and closes. If the person opened the Mini App during this period, the check is counted automatically. A reminder is sent only if there is no reaction within 7 days. If the key is missing and cannot be restored, the owner is notified and asked to re-create the shares (FR-CRY-08).	Must	PRP, INT (F-04)	No more than one check request per 180 days per person; the check needs no input other than one tap; removing the key from SecureStorage is detected at the next check and the owner is notified.
FR-CRY-11	The system shall let the owner verify that the public key of each trusted person and recipient really belongs to that person. The owner's web application and the person's Mini App shall both show a short safety code derived from the person's public key (for example, 12 digits in groups of 4). The owner compares the codes with the person outside the system (by phone or in person) and marks the person as verified. Until then, the dashboard shows the person as "key not verified".	Must	LIT (section 3.2.3, Scarlata et al.)	A public key replaced on the server produces a different code in the owner's application than in the person's Mini App; the dashboard shows "key not verified" until the owner confirms the comparison.
FR-CRY-12	The owner's browser shall derive two independent keys from the master password: an encryption key that never leaves the browser (FR-CRY-02, FR-CRY-03) and an authentication key used to log in. Both are derived with Argon2id and HKDF with different context labels. The server stores only a slow hash of the authentication key and cannot derive the encryption key from it.	Must	LIT; Bitwarden Security Whitepaper ([21] in section 4)	The login request contains neither the master password nor the encryption key; knowing the authentication key and its stored hash does not allow decrypting the owner's private key.

6.2 Functional requirements — Hybrid activation (FR-ACT)

ID	Requirement	Priority	Source	Acceptance criteria
FR-ACT-01	The owner shall configure the check-in interval from 1 to 180 days (default: 30 days).	Must	PRP, INT (F-06)	Values outside the range are rejected; the next check-in is scheduled according to the saved interval.
FR-ACT-02	Check-ins shall be sent via SMS and Telegram only. The owner shall configure at least one of these channels.	Must	PRP, INT (F-05)	No check-in is sent by email; saving settings without SMS or Telegram is rejected.
FR-ACT-03	If a scheduled check-in is missed, the system shall send a repeated check-in after 2 days, and if that is missed, a final check-in after 1 more day. If the final check-in is missed, the activation process starts. The escalation schedule is fixed; the total time of silence before the process starts is the check-in interval plus 3 days (e.g. 7 + 3 = 10 days), and the owner's settings screen shall show this total.	Must	PRP, INT (F-07)	Given timely confirmed transport and no responses, 3 check-ins are sent (day 0, day 2, day 3); after the final one-hour response window the state changes to AWAITING CONFIRMATION; during a delivery fault FR-NOT-13 suspends escalation; a response at any step returns the state to ACTIVE; the settings screen shows the total silence time.

ID	Requirement	Priority	Source	Acceptance criteria
FR-ACT-04	The owner shall choose from 1 to 5 trusted persons (n) and the number of confirmations required (k), where $1 \le k \le n$. The default value of k is 2 (or 1 if only one trusted person is added).	Must	PRP, INT (F-03)	$n > 5$ or $k > n$ is rejected; a new configuration with two or more trusted persons proposes $k = 2$; the activation requires exactly k distinct confirmations.
FR-ACT-05	The owner shall configure the waiting period from 1 to 60 days (default: 7 days).	Must	PRP, INT (F-07)	Values outside the range are rejected; new owners get 7 days by default.
FR-ACT-06	The system shall implement activation as a state machine with the states NOT ARMED, ACTIVE, CHECK-IN PENDING, AWAITING CONFIRMATION, WAITING PERIOD, RELEASED and CANCELLED, allowing only the transitions defined in section 7.5. NOT ARMED is the initial state until the configuration is ready (FR-INV-07); CANCELLED is recorded in the audit log and immediately returns the process to ACTIVE (FR-ACT-10). After RELEASED, each capsule has its own state: LOCKED, SCHEDULED (release delay running) or AVAILABLE (FR-ACT-15).	Must	PRP	Every invalid transition is rejected; every transition is recorded in the audit log with time and cause; with fewer than k accepted trusted persons the state is NOT ARMED.
FR-ACT-07	Missed check-ins shall only start the process (notification of trusted persons) and shall never release data by themselves.	Must	PRP, INT (F-09)	Given all check-ins missed and 0 confirmations, no capsule is released after any amount of time.
FR-ACT-08	The process shall move to WAITING PERIOD only after confirmations from k different trusted persons.	Must	PRP	With $k-1$ confirmations the state does not change; repeated confirmation by the same person is counted once.
FR-ACT-09	During the waiting period, the system shall notify the owner on all configured channels (SMS, Telegram, email) at its start and every 24 hours.	Must	PRP	Notification log shows delivery attempts on every channel at the start and at least once per day.
FR-ACT-10	The owner shall be able to cancel the process at any state before RELEASED by entering the master password. Cancellation returns the process to ACTIVE, deletes submitted shares and notifies trusted persons.	Must	PRP, INT (F-10)	After cancellation, no submitted shares remain on the server and recipients get no access.
FR-ACT-11	When the waiting period ends without cancellation, the system shall release the submitted shares of each capsule to its recipients after the capsule's release delay (FR-ACT-15) and notify them.	Must	PRP	Recipients receive access only after the waiting period and the capsule's release delay have fully expired.
FR-ACT-12	A trusted person shall be able to withdraw their confirmation before the waiting period starts.	Should	ASM	After withdrawal, the confirmation count decreases and the state is recalculated.
FR-ACT-13	The owner shall see a history of all activation events (check-ins, confirmations, cancellations, notifications).	Should	ASM	All events from FR-ACT-06 are visible to the owner in chronological order.
FR-ACT-14	The system shall run one activation process per owner. Check-ins, trusted persons, k and the waiting period are defined per owner; recipients are defined per capsule.	Must	PRP	An owner with several capsules has exactly one activation state; confirmations from trusted persons apply to all capsules of this owner.
FR-ACT-15	The owner shall be able to set an additional release delay for each capsule from 0 to 365 days (default: 0) that starts when the waiting period ends.	Must	INT (F-08)	A capsule with a 30-day delay becomes available to its recipients 30 days after the waiting period ends; capsules with delay 0 are released immediately.
FR-ACT-16	A check-in sent by SMS shall contain a link that opens without login. The link carries a single-use random token (at least 128 bits) bound to this check-in and valid until the next escalation step. The link opens a page with an "I'm OK" button; the answer is counted only when the button is pressed. The link works only during the check-in stage and cannot stop the waiting period (FR-ACT-10).	Must	PRP, INT (F-05)	Opening the link alone (e.g. by a link preview) does not count as an answer; a used or expired token is rejected; during WAITING PERIOD the link does not change the state.

6.3 Functional requirements — Invitation and identity of trusted persons and recipients (FR-INV)

ID	Requirement	Priority	Source	Acceptance criteria
FR-INV-01	Trusted persons and recipients shall take part without registration in the system, using only the Telegram bot and Mini App.	Must	PRP	No account, password or e-mail is required from a trusted person or recipient.
FR-INV-02	When the owner saves a trusted person or recipient (name and phone number), the system shall send them an SMS with a short explanation and a single-use invitation link to the Telegram bot.	Must	PRP	The SMS is sent within 1 minute after saving; the link opens the bot with the invitation token.
FR-INV-03	The owner shall be able to additionally send the invitation from their own Telegram account as a prepared message with a button that opens the bot.	Should	PRP	The prepared message opens in Telegram with the text and button already filled in; the owner only chooses the contact.
FR-INV-04	After the invited person presses Start, the bot shall send a welcome message explaining who added them, their role, what will be required, that they cannot see the owner's data, that participation is free, and how to decline.	Must	PRP	The welcome message contains all listed points and the buttons Accept / Decline / More.
FR-INV-05	To accept the invitation, the bot shall request the person's phone number through Telegram contact sharing and accept the invitation only if it matches the number entered by the owner.	Must	PRP	An invitation opened from another Telegram account with a different phone number is rejected.
FR-INV-06	Invitation links shall be single-use and expire after 14 days; the owner can resend an invitation.	Should	ASM	A used or expired link is rejected; a resent invitation generates a new link.
FR-INV-07	The owner shall see the status of each invitation (sent, accepted, declined, expired). The activation is armed only when at least *k* trusted persons and every recipient have accepted.	Must	PRP	With fewer than *k* accepted trusted persons the configuration is marked "not ready" and activation is not armed.
FR-INV-08	The welcome message (FR-INV-04) shall ask the invited person for consent to the processing of their name and phone number. Before consent, the name and phone number entered by the owner are used only to send the invitation. If the person declines or does not answer before the invitation expires (FR-INV-06), the name and phone number are deleted within 24 hours and only an anonymous status remains for the owner.	Must	LAW (Law on Personal Data, section 3.3.3)	Accepting requires an explicit consent step; 24 hours after a decline or expiry, the database contains no name or phone number of that person.

6.4 Non-functional requirements — Security, reliability, performance

ID	Category	Requirement	Priority	Source	Metric / acceptance criterion
NFR-SEC-01	Security	Zero-knowledge: the server never receives or stores plaintext content, master passwords, unencrypted private keys or a complete capsule key.	Must	PRP, INT (F-11)	Review of the database dump and API traffic finds none of these values.
NFR-SEC-02	Security	Only established cryptographic implementations are used (WebCrypto API, libsodium, an audited Shamir library); no custom cryptographic primitives.	Must	LIT	Dependency list contains only approved libraries; no own implementations of encryption or key splitting.
NFR-SEC-03	Security	A threat model is documented covering: compromised server, a single malicious trusted person, collusion of fewer than *k* trusted persons, false triggering, a lost phone or hijacked Telegram account of a trusted person or recipient, a forwarded invitation link, suppression of the activation by a person holding the owner's phone (SMS check-in links) and the server-enforced capsule release delay.	Must	PRP, LIT	Each threat has a described countermeasure linked to requirements.

ID	Category	Requirement	Priority	Source	Metric / acceptance criterion
NFR-SEC-04	Security	All traffic uses HTTPS (TLS 1.2+) with HSTS.	Must	LIT	TLS check shows no weaker protocols; HTTP redirects to HTTPS.
NFR-SEC-05	Security	Login, check-in and confirmation endpoints are rate-limited.	Must	LIT	More than 10 failed attempts per minute from one account or IP are blocked.
NFR-SEC-06	Security	Owners can enable two-factor authentication (TOTP).	Should	ASM	With 2FA enabled, login without the second factor is impossible.
NFR-SEC-07	Security	Logs contain no content, keys, shares or passwords.	Must	LIT	Log review finds no sensitive values.
NFR-LAW-01	Compliance	Personal-data storage, replicas, backups and contact-bearing operational copies shall be located in Kazakhstan (section 12, LD-01).	Must	LAW (Article 12), DIP-26	Before a real-data pilot, provider, physical region, backup/replica and recovery locations are documented; foreign personal-data storage fails the gate.
NFR-LAW-02	Compliance	The operator shall document the lawful basis, purpose, minimum fields, consent notice/version, withdrawal and retention for every personal-data operation. Later invitation acceptance shall not be treated as proof of lawful initial collection.	Must	LAW (Articles 7, 8, 18, 25); section 12.4	No real-data invitation without a reviewed initial-processing basis; acceptance without explicit consent is rejected; refusal/expiry deletion is tested under FR-INV-08.
NFR-LAW-03	Compliance	The product shall distinguish technical data delivery from inheritance, legal proof of death and a notarial will.	Must	LAW (Civil Code Articles 1038-1040, 1046, 1050); PRP	Scope and UI contain no claim that trustee confirmation establishes legal heirs, transfers property or replaces a will.
NFR-LAW-04	Compliance	Personal-data transfers to SMS, Telegram, email and their subprocessors shall be assessed before real-data use, with recipients, countries, legal basis and consent scope documented.	Must	LAW (Articles 7(6), 8, 16); section 12.3	Processor/transfer inventory exists; an unassessed route is disabled for real contacts; demonstrations use synthetic data.
NFR-REL-01	Reliability	Check-in, confirmation and waiting-period timers fire no later than 1 hour after the due time and are not lost after a server restart.	Must	ASM	Test with a restart during an active timer shows correct firing within 1 hour.
NFR-REL-02	Reliability	A failure of one notification channel does not block others; failed deliveries are retried at least 3 times.	Must	ASM	With one channel disabled, notifications still arrive through the others; retries are logged.
NFR-PERF-01	Performance	Encrypting and splitting a 10 MB capsule takes ≤ 3 s in the browser.	Should	ASM	Measured in Chrome on a mid-range laptop (median of 10 runs).
NFR-PERF-02	Performance	Key derivation with Argon2id takes ≤ 2 s on a mid-range smartphone.	Should	ASM	Measured in a mobile browser (median of 10 runs).
NFR-CAP-01	Capacity	The total size of encrypted files in one capsule is limited to 50 MB.	Should	ASM	Uploading a capsule larger than 50 MB is rejected with a clear message.

6.5 Functional requirements — Owner cabinet (FR-OWN)

ID	Requirement	Priority	Source	Acceptance criteria
FR-OWN-01	The owner shall register in the web application with an email address and a master password, and confirm the email by a link. The master password is handled as described in FR-CRY-02.	Must	PRP	An account is usable only after email confirmation; the registration request contains no master password (FR-CRY-02).
FR-OWN-02	The owner shall create a capsule with a title and content of the following types: credentials, text instructions, files and photos, personal messages, business access. The content is encrypted in the browser before upload (FR-CRY-01).	Must	PRP, INT (F-01, F-02)	A capsule containing each of the five content types is created and, after reload, decrypted with the same content; the server stores only

ID	Requirement	Priority	Source	Acceptance criteria
				ciphertext.
FR-OWN-03	The owner shall be able to create several capsules and assign one or more recipients to each capsule separately.	Must	INT (F-08)	Two capsules with different recipients: after release, each recipient sees only the capsule assigned to them.
FR-OWN-04	The capsule editor shall have a field for the additional release delay of the capsule defined in FR-ACT-15 (0–365 days after the waiting period, default 0). The activation process is common to the owner (FR-ACT-14).	Should	INT (F-08)	The field is present in the editor; values outside 0–365 are rejected; the saved value is shown after reload.
FR-OWN-05	The owner shall be able to edit and delete a capsule. Deleting a capsule removes its ciphertext and shares in one transaction.	Must	PRP	After deletion, no record of the capsule, its files or its shares remains in the database; editing creates a new ciphertext.
FR-OWN-06	The owner shall add, edit and remove trusted persons and recipients by name and phone number, and set *n* and *k* (FR-ACT-04). Changes trigger re-splitting of the key (FR-CRY-08).	Must	PRP	Entering $n > 5$ or $k > n$ shows an error; after the change, the old shares are invalidated.
FR-OWN-07	The owner shall have a settings page for the check-in interval, the time of day of check-ins (FR-NOT-09), check-in channels, waiting period (FR-ACT-01, 02, 05) and interface language. When the interval changes, the page shows the total time of silence before the process starts (FR-ACT-03).	Must	PRP, INT (F-06, F-07)	Saved values are shown after reload; values outside the ranges of FR-ACT-01 and FR-ACT-05 are rejected with a message; for intervals of 1, 7 and 30 days the page shows about 4, 10 and 33 days.
FR-OWN-08	The owner's dashboard shall show: the current state of the activation process, the date of the last answered check-in, the date of the next check-in, the status of each invitation (FR-INV-07) and whether the configuration is "ready" or "not ready".	Must	PRP	All five items are visible on one screen; the state matches the state machine (FR-ACT-06).
FR-OWN-09	The owner shall cancel an activation process from the dashboard with the master password (FR-ACT-10). The button is available in every state before RELEASED.	Must	PRP, INT (F-10)	In the states AWAITING CONFIRMATION and WAITING PERIOD the cancel button is visible on the dashboard; in RELEASED it is not.
FR-OWN-10	The owner shall be able to view the activation history (FR-ACT-13) and the notification log.	Should	ASM	The page lists check-ins, confirmations, cancellations and notifications with time and result.
FR-OWN-11	The owner shall be able to delete the account. All capsules, shares, public keys and notification contacts are deleted.	Should	LAW	After deletion, the database contains no records linked to the owner; trusted persons and recipients are notified.
FR-OWN-12	The capsule editor shall offer an optional checklist for instructions (for example, "where the documents are", "which subscriptions to cancel", "who to call").	Could	ASM	The editor offers the checklist; leaving it empty does not block saving.
FR-OWN-13	When the owner adds a trusted person or recipient, the cabinet shall warn that participation requires Telegram and recommend choosing *n* greater than *k*. The invitation SMS shall state that Telegram is needed (CON-04).	Should	INT (F-16)	The warning is shown when a person is added; with $n = k$ the recommendation is shown; the SMS text mentions Telegram.

6.6 Functional requirements — Trusted person and recipient interface: bot and Mini App (FR-TRU)

ID	Requirement	Priority	Source	Acceptance criteria
FR-TRU-01	The bot and Mini App shall show the role of the person (trusted person, recipient or both), the name of the owner as entered by the owner, and the status of the invitation.	Must	PRP	After accepting, the Mini App shows the role, the owner's name and the status "accepted".
FR-TRU-02	A trusted person and a recipient shall not see any capsule titles, content or settings of the owner, except the owner's name, before release.	Must	PRP, INT (F-04)	Inspecting the screens and API responses available to a trusted person shows no capsule data.
FR-TRU-03	When the process is in AWAITING CONFIRMATION, the trusted person shall see a confirmation screen with a plain explanation of what is being confirmed, and a "Confirm the event" button (FR-ACT-08, FR-CRY-06).	Must	PRP, INT (F-04)	The screen appears only in AWAITING CONFIRMATION; pressing the button starts the confirmation flow.

ID	Requirement	Priority	Source	Acceptance criteria
FR-TRU-04	Confirmation shall require two steps: pressing the button and an explicit confirmation of the question "Are you sure?" that states the consequence (data will be handed over after the waiting period unless the owner cancels).	Must	INT (F-09)	A single tap does not send a confirmation; the confirmation is sent only after the second step.
FR-TRU-05	A trusted person shall be able to withdraw their confirmation before the waiting period starts (FR-ACT-12).	Should	ASM	The "Withdraw" button is shown until the state changes to WAITING PERIOD.
FR-TRU-06	A trusted person and a recipient shall be able to decline the role at any time from the bot or Mini App. The owner is notified and the configuration becomes "not ready" if fewer than *k* trusted persons remain.	Must	PRP	After declining, the owner receives a notification and the dashboard status changes (FR-OWN-08).
FR-TRU-07	The key check of FR-CRY-10 (once every 180 days) shall take one tap: the bot sends a message with an "Open" button, the Mini App checks the key and closes, and the person sees a short confirmation that the check is done.	Must	INT (F-04)	The check is completed with one tap and no other action; the confirmation is shown after a successful check.
FR-TRU-08	After release, the recipient shall see the list of capsules intended for them and open each available capsule in the Mini App (FR-CRY-07). A capsule that is still under its release delay is shown without a title as unavailable until its date (FR-ACT-15).	Must	PRP	The recipient sees only their capsules and, after opening, the original content; a capsule under delay cannot be opened before its date.
FR-TRU-09	The recipient shall be able to download files from the opened capsule. The content is decrypted in the Mini App and is not kept in Telegram.	Should	PRP	A downloaded file is identical to the original (hash comparison); nothing is stored in CloudStorage.
FR-TRU-10	The Mini App shall contain a help section of at most 3 short screens that explains in plain language: what a key share is, why the server cannot read the data, and what happens if the phone is lost.	Must	INT (F-13)	The help is available from the main screen in one tap and contains no term without explanation (checked in the usability test, NFR-USE-03).

6.7 Functional requirements — Notifications (FR-NOT)

ID	Requirement	Priority	Source	Acceptance criteria
FR-NOT-01	The system shall maintain a catalogue of notifications that defines, for each event, the receiver, the channels and the message template (see the table below).	Must	PRP	Every event in the table has a template in both languages (NFR-L10N-03).
FR-NOT-02	A check-in message shall be an "Are you OK?" question with a single action to answer: a button in Telegram, or a link in SMS that opens a page with an "I'm OK" button (FR-ACT-16).	Must	PRP, INT (F-05)	One tap on the Telegram button, or one tap on the link and one on the page button, is enough to answer; the answer returns the state to ACTIVE (FR-ACT-03).
FR-NOT-03	A check-in link in SMS shall work as specified in FR-ACT-16 (single-use token of at least 128 bits, "I'm OK" button, only during the check-in stage). A used, expired or foreign link shall show a clear message in the user's language.	Must	LIT	Opening the link alone does not change the state (FR-ACT-16); a used or expired link shows a clear message in Kazakh or Russian.
FR-NOT-04	When the process moves to AWAITING CONFIRMATION, every trusted person shall be notified in Telegram. If Telegram delivery fails (for example, the bot is blocked), an SMS is sent instead.	Must	PRP	Given two accepted trusted persons, one with successful Telegram delivery and one whose bot is blocked, both are notified within 5 minutes: Telegram for the first and SMS fallback for the second.
FR-NOT-05	The owner shall be notified on every configured channel when a trusted person confirms, withdraws or declines, and when the key check of a trusted person fails (FR-CRY-10).	Must	PRP	Each of the four events produces a notification in the owner's channels.
FR-NOT-06	Recipients shall be notified when a capsule becomes available to them: after the waiting period for capsules without a delay, and at the end of the delay for the others (FR-ACT-11, FR-ACT-15). The notification contains only the owner's name and a link to the bot.	Must	PRP	The message contains no capsule content, title or key; a capsule with a delay of 30 days produces its notification 30 days after the waiting period ends.
FR-NOT-07	Notifications shall never contain capsule content, capsule titles, keys or shares.	Must	PRP, LIT	Review of all templates finds none of these values.
FR-NOT-08	Notifications to a person shall be sent in the language	Must	PRP	The same event is received in Kazakh

ID	Requirement	Priority	Source	Acceptance criteria
	chosen by that person (see NFR-L10N-02).			by a user with Kazakh selected and in Russian by a user with Russian.
FR-NOT-09	The owner shall choose the time of day for check-ins (default 10:00 in the owner's time zone). The repeated and final check-ins (FR-ACT-03) are sent at the same time of day.	Should	ASM	With 18:00 chosen, the scheduled, repeated and final check-ins are sent at 18:00; with no choice, at 10:00; the schedule of FR-ACT-03 (day 0, +2, +1) does not change.
FR-NOT-10	The owner shall be able to pause check-ins ("vacation mode") for up to 60 days.	Could	INT (F-07)	During the pause no check-in is sent; the process resumes automatically at the end.
FR-NOT-11	WhatsApp as an additional channel for owner check-ins and notifications. Not planned for this version: WhatsApp has no equivalent of the Mini App with protected key storage, so trusted persons and recipients cannot use it. It stays in the list of future improvements; for notifications it is reconsidered in section 5.7 (DIP-13).	Won't	INT (F-05, F-16)	Not applicable in this version.
FR-NOT-12	Each notification attempt shall be persistently recorded with event/process version, pseudonymous receiver, channel, attempt number, times, provider ID and sanitized status. Transport confirmation is final SMS delivery status, successful Telegram Bot API acknowledgement or SMTP acceptance as defined in section 13.2; it is not proof of human reading.	Must	ASM; DIP-27	Pending, failed, stale or unauthenticated callbacks cannot confirm transport; duplicate callbacks cannot advance a process twice; logs contain no contact numbers, tokens, keys or capsule data.
FR-NOT-13	A check-in without transport confirmation on any permitted check-in channel shall not be counted as missed. Freeze the current escalation step, persist the fault, retry at the next configured daily time, and show a cabinet warning; email warns only if available. Recovery restarts that step's response window; a delayed job cannot cause immediate escalation.	Must	ASM; DIP-27	With all check-in channels failing for 60 days, no outage-caused AWAITING CONFIRMATION or release; the existing state and delivery-fault flag persist across restart; no guaranteed email warning is claimed during total outage.
FR-NOT-14	During WAITING PERIOD, failure to confirm the required start/daily owner notice on every permitted owner channel shall pause the release countdown. Recovery delivers a fresh notice and restarts the full configured waiting period; cancellation remains available and every release transaction rechecks the guard.	Must	ASM; DIP-27	NR-03/NR-07: advancing past the old release deadline during total outage never releases; recovery cannot release before a full fresh waiting period; cancellation invalidates stale release jobs.

6.7.1 Delivery reliability

A check-in that never reaches the owner looks the same as a check-in the owner ignored. For this reason the reliability of notifications is treated as a requirement of the activation mechanism, not as a technical detail. The rules are:

- Timers survive a server restart and fire within 1 hour of the due time (NFR-REL-01).
- A failure of one channel does not block the others; every failed delivery is retried at least 3 times (NFR-REL-02).
- Every attempt is logged, and "delivered" has a defined meaning (FR-NOT-12).
- A check-in that was not delivered on any channel is **not** counted as missed (FR-NOT-13). This is a deliberate trade-off: a long failure of all channels delays the start of the process instead of starting it by mistake. The availability trade-off is evaluated in E10/E11; E9 is the separate limitation of an attacker who answers the owner's check-ins.

The complete specification is 13-notification-reliability.md, prepared for DIP-27 on 24.10.2026: event/channel/fallback matrix, transport semantics, retry intervals, persistence, monitoring and NR-01 to NR-08. M6, M8, M12 and E10/E11 define integration checks; live execution is pending. FR-NOT-14 also guards waiting-period release during an outage.

Notification catalogue (FR-NOT-01):

Event	Receiver	Channels
Invitation	Trusted person, recipient	SMS (+ Telegram from the owner, FR-INV-03)
Scheduled check-in, repeated check-in, final check-in	Owner	SMS, Telegram
Process started (AWAITING CONFIRMATION)	Trusted persons	Telegram (SMS if Telegram delivery fails, e.g. the bot is blocked, FR-NOT-04)
Confirmation received, withdrawn, declined; key check failed	Owner	SMS, Telegram, email
Waiting period started and every 24 hours	Owner	SMS, Telegram, email (FR-ACT-09)
Cancellation	Trusted persons	Telegram
Capsule becomes available (after the waiting period or the capsule's release delay)	Recipients	Telegram (SMS if the bot has not been started)
Key check request	Trusted persons, recipients	Telegram

6.8 Non-functional requirements — Usability and localization (NFR-USE, NFR-L10N)

ID	Category	Requirement	Priority	Source	Metric / acceptance criterion
NFR-USE-01	Usability	The overall usability of the owner cabinet, bot and Mini App shall be rated at least 70 on the System Usability Scale (SUS).	Must	PRP, LIT	SUS ≥ 70 in the evaluation with at least 5 participants (DIP-22).
NFR-USE-02	Usability	A new owner shall be able to create the first capsule with two trusted persons without help.	Should	PRP	At least 80% of test participants complete the task in at most 15 minutes.
NFR-USE-03	Usability	Encryption and key splitting shall be explained in plain language at the steps where they appear (capsule creation, adding trusted persons, setting *k*). Technical terms are accompanied by a one-sentence explanation.	Must	INT (F-13)	In the usability test, at least 4 of 5 participants correctly explain in their own words what *k* of *n* means after the setup.
NFR-USE-04	Usability	The initial setup shall be a step-by-step wizard: capsule → trusted persons and *k* → check-in and waiting period settings → review.	Must	INT (F-13)	The wizard has 4 steps with progress shown and the ability to return to a previous step without losing data.
NFR-USE-05	Usability	A trusted person shall accept the invitation in at most 5 taps and confirm an event in at most 3 steps (including the second step of FR-TRU-04).	Must	INT (F-04)	Counted on the prototype for each scenario.
NFR-USE-06	Usability	Irreversible actions (delete capsule, delete account, confirm event, cancel) shall require an explicit confirmation that states the consequence.	Must	INT (F-09)	Each listed action has a confirmation dialog in the prototype and in the application.
NFR-USE-07	Usability	The owner cabinet shall work on screens from 360 px wide.	Should	PRP	Key scenarios are completed on a 360 px viewport without horizontal scrolling.
NFR-USE-08	Usability	Text and controls shall meet WCAG 2.1 level AA contrast.	Should	LIT	Automatic check (for example, Lighthouse) shows no contrast errors on key screens.
NFR-L10N-01	Localization	The owner cabinet, the bot and the Mini App shall be fully available in Kazakh and Russian.	Must	PRP	100% of interface strings exist in both languages; no untranslated strings on key screens.
NFR-L10N-02	Localization	The language is chosen per user and stored. The default comes from the Telegram language or the browser language; Russian is used if neither is Kazakh or Russian.	Must	PRP	A new user with Kazakh Telegram sees Kazakh; the choice is kept after re-login.

ID	Category	Requirement	Priority	Source	Metric / acceptance criterion
NFR-L10N-03	Localization	All SMS, Telegram and email templates shall exist in Kazakh and Russian. An SMS shall fit in at most 2 segments (Cyrillic, 67 characters per segment).	Should	PRP	Every template is available in both languages; test messages are at most 2 segments.
NFR-L10N-04	Localization	Dates and times are shown as DD.MM.YYYY and 24-hour time in the user's time zone (default UTC+5).	Should	ASM	Time of a check-in shown in the cabinet matches the time of the SMS on the owner's phone.
NFR-L10N-05	Localization	Kazakh and Russian texts shall be reviewed by a native speaker.	Should	PRP	Review is recorded in the repository.

6.9 Constraints

ID	Constraint	Impact
CON-01	A Telegram bot cannot send the first message to a user who has never started it.	Invitations are delivered by SMS and, optionally, by the owner from their own Telegram account (FR-INV-02, FR-INV-03); the bot writes only after the person presses Start.
CON-02	Telegram SecureStorage holds up to 10 items per user per bot and can restore a value only on the same device.	One key pair per person; a lost or replaced phone requires re-creating the shares (FR-CRY-08, FR-CRY-10).
CON-03	SecureStorage is documented for the iOS and Android Telegram clients; support in Telegram Desktop and Web must be verified on the prototype.	Trusted persons and recipients are expected to use mobile Telegram.
CON-04	The participation of trusted persons and recipients depends on the availability of Telegram.	The owner is advised to choose n greater than k; SMS remains a fallback for invitations and notifications.

7. Architecture and Diagrams

Section	Responsible
7.1 System context	Alisher Medebaev (DIP-16)
7.2 Use cases	Aibyn Samat (DIP-17)
7.3 Components (draft), 7.4 Trust boundaries and data protection, 7.5 Activation state machine	Alisher Medebaev (DIP-18)

7.1 System context

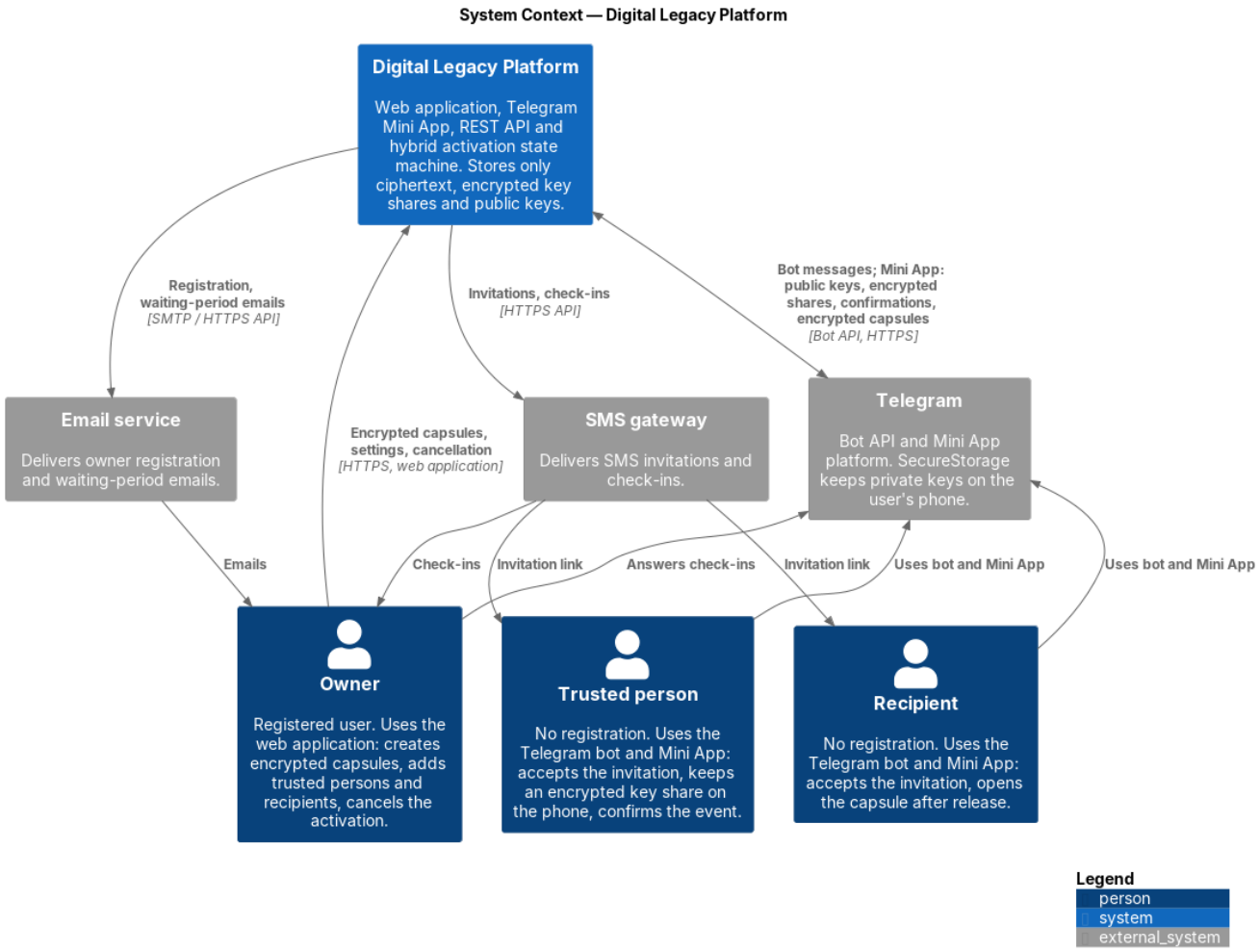


Figure 1. System context diagram

Source: diagrams/src/01-system-context.puml (C4 model, level 1)

The diagram shows the Digital Legacy Platform as one system, the people who use it and the external services it depends on.

People

Actor	Interface	Interaction with the system	Related requirements
Owner	Web application (registered account)	Creates encrypted capsules, configures trusted persons, recipients, check-in interval and waiting period, answers check-ins, cancels the activation	FR-CRY-01…03, FR-ACT-01…05, FR-ACT-10

Actor	Interface	Interaction with the system	Related requirements
Trusted person	Telegram bot and Mini App (no registration)	Accepts the invitation, generates a key pair on the phone, keeps an encrypted key share, confirms the event	FR-CRY-03a, FR-CRY-05, FR-CRY-06, FR-INV-01…05
Recipient	Telegram bot and Mini App (no registration)	Accepts the invitation, generates a key pair on the phone, receives and decrypts the capsule after release	FR-CRY-03a, FR-CRY-07, FR-ACT-11, FR-INV-01…05

External systems

System	Purpose	Data exchanged	Related requirements
Telegram (Bot API, Mini App platform)	Invitations, check-ins, confirmation requests and notifications; runs the Mini App; SecureStorage keeps private keys on the user's phone	Bot messages; from the Mini App: public keys, encrypted shares, confirmations; to the Mini App: encrypted capsules and shares	FR-ACT-02, FR-INV-04, FR-CRY-03a, CON-01…04
SMS gateway	SMS invitations with a link to the bot, check-ins	Invitation links, check-in messages	FR-INV-02, FR-ACT-02
Email service	Owner registration and waiting-period notifications	Email messages	FR-ACT-09

Key properties shown by the diagram

- The platform receives and stores only ciphertext, encrypted key shares and public keys (NFR-SEC-01). Private keys stay in the owner's browser (encrypted) or in Telegram SecureStorage on the phones of trusted persons and recipients.
- Trusted persons and recipients interact only through Telegram; a Telegram bot cannot write first, so the first contact is an SMS invitation (CON-01).
- Telegram, SMS and email carry only messages and links; they never receive keys or plaintext capsule content.

7.2 Use cases

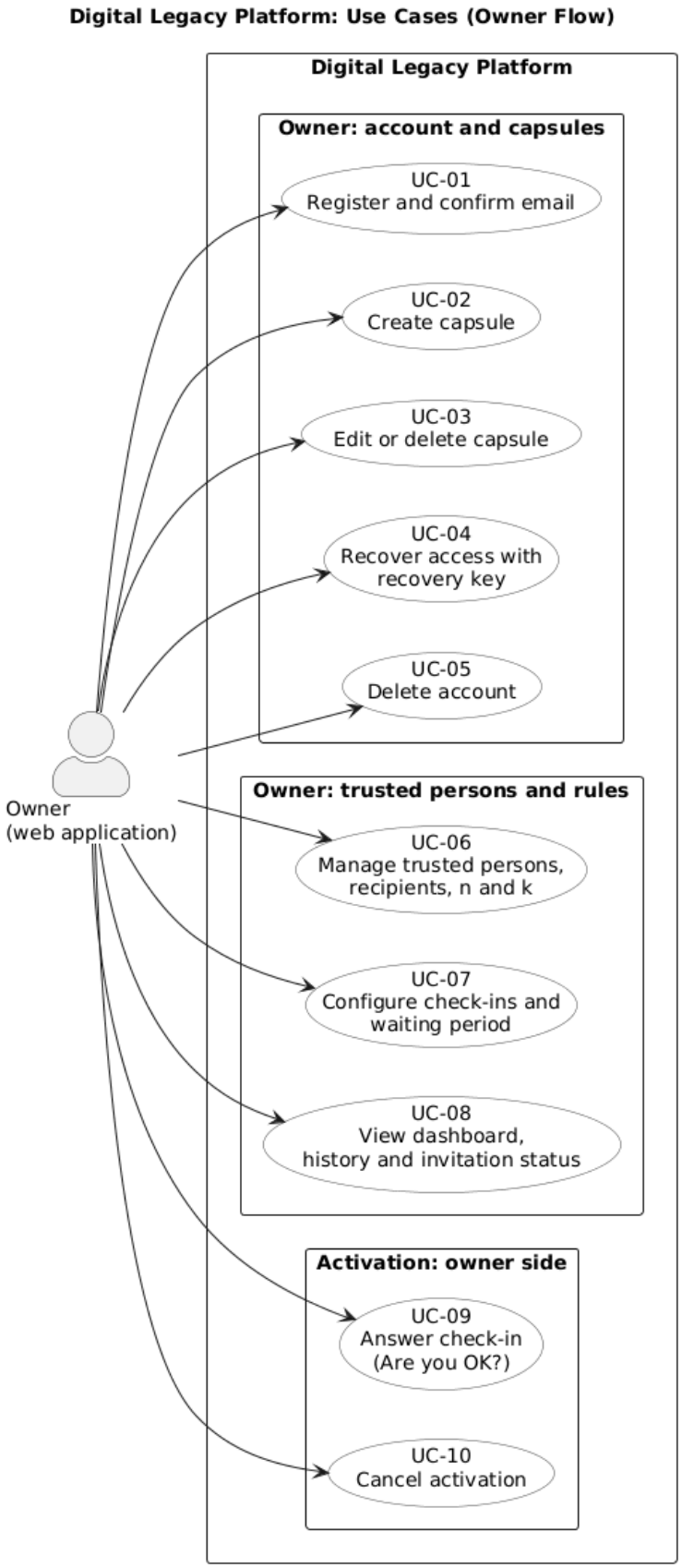


Figure 2. Use Case diagram (Owner Flow)

Source: diagrams/src/02-use-cases-owner.puml (UML use case diagram)

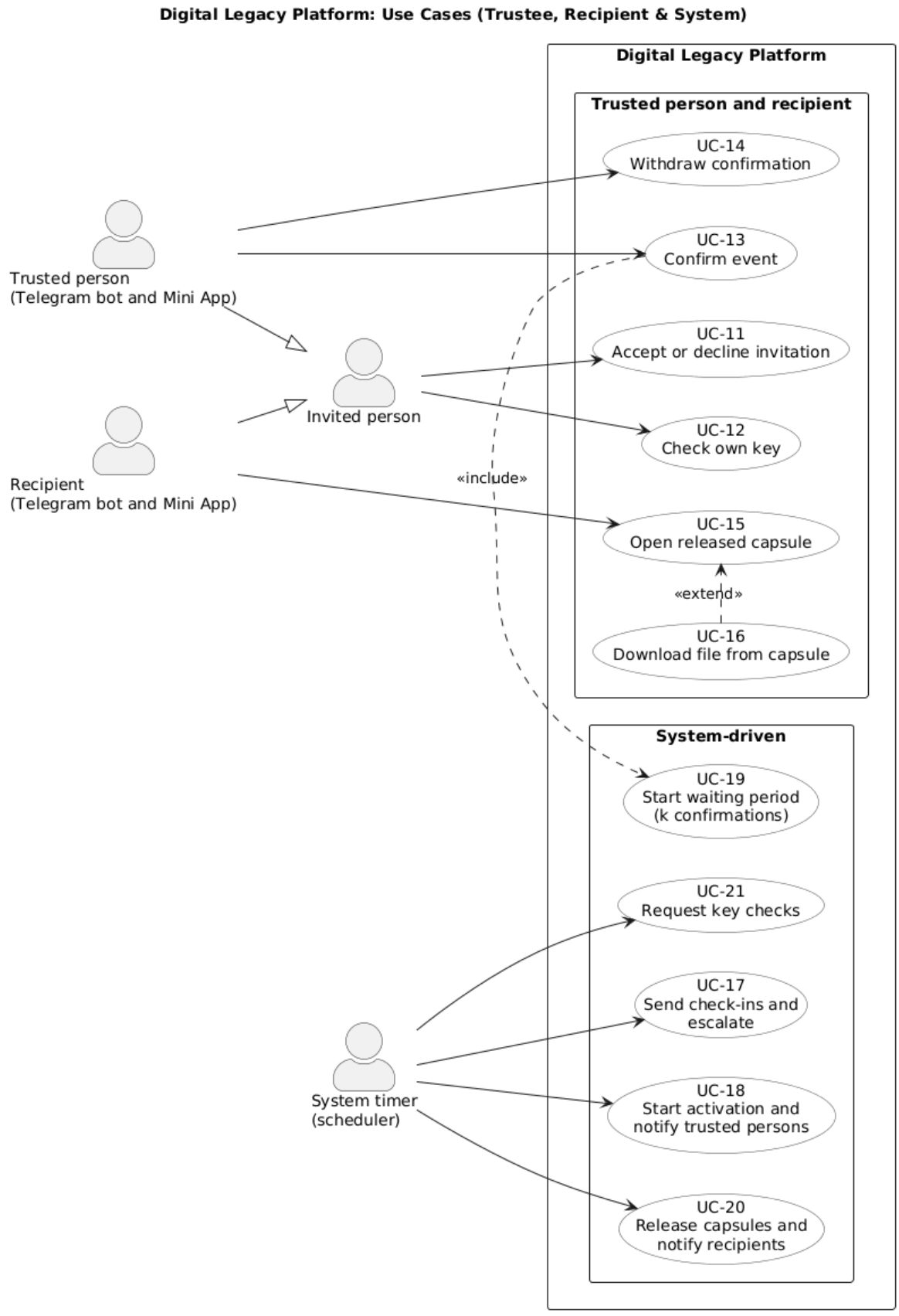


Figure 3. Use Case diagram (System & Trusted Persons)

Source: diagrams/src/02-use-cases-system.puml (UML use case diagram)

The diagrams show what each actor can do in the platform. The actors are the same as in the system context diagram (section 7.1); the system timer is added as the actor that drives the activation process.

Actors

Actor	Interface	Role in the diagram
Owner	Web application (registered account)	Prepares capsules and rules, answers check-ins, cancels activation
Trusted person	Telegram bot and Mini App	Confirms the event, keeps and checks a key share
Recipient	Telegram bot and Mini App	Receives and opens capsules after release
Invited person	Telegram bot and Mini App	Generalization of the trusted person and the recipient: both accept or decline an invitation in the same way
System timer	Scheduler (Quartz)	Starts check-ins, escalation and release by time; the waiting period starts on the k-th distinct confirmation

Use cases and requirements

Use case	Actor	Main requirements
UC-01 Register and confirm email	Owner	FR-OWN-01, FR-CRY-02, FR-CRY-03, FR-CRY-09
UC-02 Create capsule	Owner	FR-OWN-02, FR-OWN-03, FR-OWN-04, FR-ACT-15, FR-OWN-12, FR-CRY-01, FR-CRY-04, FR-CRY-05
UC-03 Edit or delete capsule	Owner	FR-OWN-05, FR-CRY-01
UC-04 Recover access with recovery key	Owner	FR-CRY-09
UC-05 Delete account	Owner	FR-OWN-11
UC-06 Manage trusted persons, recipients, *n* and *k*	Owner	FR-OWN-06, FR-ACT-04, FR-CRY-04, FR-CRY-05, FR-CRY-08, FR-INV-02, FR-INV-03, FR-INV-07, FR-OWN-13
UC-07 Configure check-ins and waiting period	Owner	FR-OWN-07, FR-ACT-01, FR-ACT-02, FR-ACT-05, FR-NOT-09, FR-NOT-10
UC-08 View dashboard, history and invitation status	Owner	FR-OWN-08, FR-OWN-10, FR-ACT-13, FR-INV-07
UC-09 Answer check-in ("Are you OK?")	Owner	FR-NOT-02, FR-NOT-03, FR-ACT-03, FR-ACT-16
UC-10 Cancel activation	Owner	FR-OWN-09, FR-ACT-10
UC-11 Accept or decline invitation	Invited person	FR-INV-04, FR-INV-05, FR-INV-06, FR-TRU-01, FR-TRU-06, FR-CRY-03a, FR-CRY-11
UC-12 Check own key	Invited person (trusted person or recipient)	FR-TRU-07, FR-CRY-10
UC-13 Confirm event	Trusted person	FR-TRU-03, FR-TRU-04, FR-ACT-08, FR-CRY-06
UC-14 Withdraw confirmation	Trusted person	FR-TRU-05, FR-ACT-12
UC-15 Open released capsule	Recipient	FR-TRU-08, FR-CRY-07, FR-ACT-11
UC-16 Download file from capsule (extends UC-15)	Recipient	FR-TRU-09
UC-17 Send check-ins and escalate	System timer	FR-ACT-02, FR-ACT-03, FR-ACT-07, FR-ACT-16, FR-NOT-02, FR-NOT-03, FR-NOT-09
UC-18 Start activation and notify trusted persons	System timer	FR-ACT-03, FR-ACT-06, FR-NOT-04
UC-19 Start waiting period (k confirmations)	Trusted person (via UC-13, on the k-th distinct confirmation)	FR-ACT-06, FR-ACT-08, FR-ACT-09

Use case	Actor	Main requirements
UC-20 Release capsules and notify recipients	System timer	FR-ACT-06, FR-ACT-11, FR-ACT-15, FR-NOT-06
UC-21 Request key checks	System timer	FR-CRY-10, FR-TRU-07, FR-NOT-05

Notes

- The system timer triggers use cases that need no human action. A missed check-in only starts the process (UC-18); the data is never released without *k* confirmations (UC-13, UC-19) and the end of the waiting period (UC-20), see FR-ACT-07.
- Requirements that apply to many use cases are not repeated in the table: FR-TRU-02 and FR-TRU-10 (what a trusted person sees, help screens), FR-NOT-01, FR-NOT-07, FR-NOT-08 (notification catalogue, no sensitive data in messages, language), NFR-SEC, NFR-USE and NFR-L10N. FR-NOT-11 (WhatsApp) is not planned for this version.
- The owner can cancel (UC-10) in every state before RELEASED.

7.3 Components (draft)

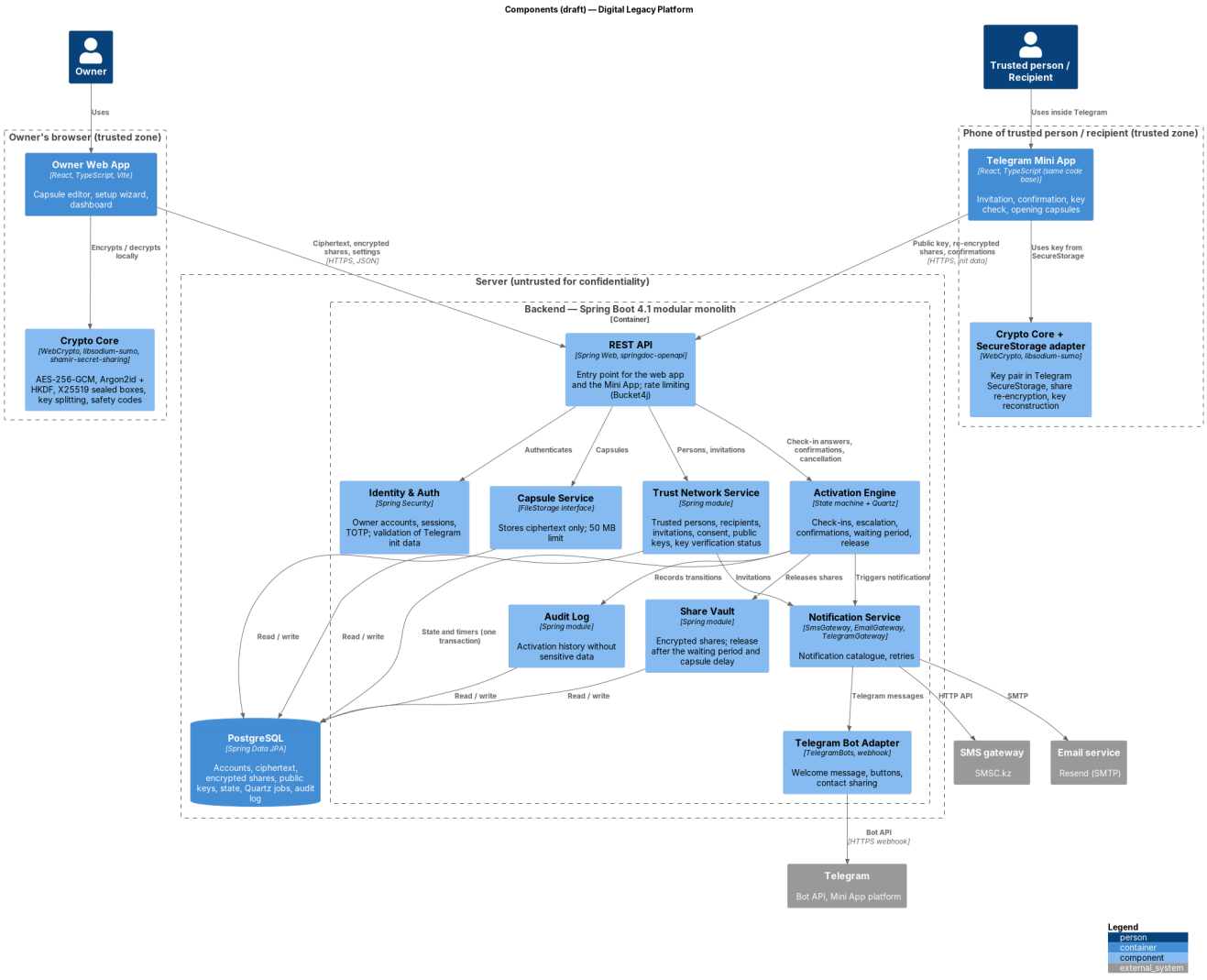


Figure 4. Component diagram

Source: diagrams/src/03-components.puml (C4 model, levels 2–3)

The backend is a **modular monolith** on Spring Boot 4.1 (section 5.1): one deployable application with modules separated by interfaces. For a team of two this keeps one deployment, one database transaction for a state change and its timer (section 5.4b), and still allows a module to be extracted later. The frontend is one React code base with two entry points: the owner web application and the Telegram Mini App (section 5.6).

Zone	Component	Responsibility	Main requirements
Owner's browser	Owner Web App	Capsule editor, setup wizard, dashboard, settings	FR-OWN-01…13, NFR-USE-04
Owner's browser	Crypto Core	AES-256-GCM, Argon2id + HKDF (encryption and authentication keys), X25519 sealed boxes, key splitting, safety codes	FR-CRY-01…05, FR-CRY-11, FR-CRY-12
Phone of trusted person / recipient	Telegram Mini App	Invitation and consent, key check, confirmation, opening capsules	FR-INV-04…08, FR-TRU-01…10
Phone of trusted person / recipient	Crypto Core + SecureStorage adapter	Key pair in SecureStorage, share re-encryption, key reconstruction	FR-CRY-03a, FR-CRY-06, FR-CRY-07, FR-CRY-10
Server	REST API	Single entry point for both clients; per-endpoint rate limiting	NFR-SEC-04, NFR-SEC-05
Server	Identity & Auth	Owner accounts and sessions, TOTP, validation of Telegram init data	FR-OWN-01, FR-CRY-12, NFR-SEC-06
Server	Capsule Service	Stores and returns ciphertext through the `FileStorage` interface; 50 MB limit	FR-OWN-02…05, NFR-CAP-01
Server	Trust Network Service	Trusted persons, recipients, invitations, consent, public keys, key verification status	FR-INV-01…08, FR-CRY-11, FR-OWN-06
Server	Share Vault	Encrypted shares; release after the waiting period and the capsule delay	FR-CRY-05, FR-CRY-06, FR-ACT-11, FR-ACT-15
Server	Activation Engine	State machine (section 7.5) and Quartz timers for check-ins, escalation, waiting period and release	FR-ACT-01…16, NFR-REL-01
Server	Notification Service	Notification catalogue; `SmsGateway`, `EmailGateway`, `TelegramGateway`; retries	FR-NOT-01…10, NFR-REL-02
Server	Telegram Bot Adapter	Webhook, welcome message, buttons, contact sharing	FR-INV-04, FR-INV-05, CON-01
Server	Audit Log	History of transitions and notifications without sensitive data	FR-ACT-13, NFR-SEC-07
Storage	PostgreSQL	All persistent data, including Quartz job tables	section 5.2

The draft will be refined when the implementation starts; module boundaries and names may change.

7.4 Trust boundaries and data protection

There are two trusted zones: the owner's browser and the phone of each trusted person or recipient. Everything else — the server, the database, Telegram, the SMS gateway and the email service — is **untrusted for confidentiality**: it may see metadata, but never plaintext or keys.

Data	Where it is stored	Form	Requirements
Capsule content and files	PostgreSQL	Ciphertext only (AES-256-GCM)	FR-CRY-01, NFR-SEC-01
Capsule key	Nowhere as a whole	$k \geq 2$: Shamir shares, each sealed for one trusted person; $k = 1$: a sealed copy per trusted person	FR-CRY-04, FR-CRY-05

Data	Where it is stored	Form	Requirements
Master password	Nowhere	Known only to the owner	FR-CRY-02
Owner's authentication key	PostgreSQL	Slow hash only	FR-CRY-12
Owner's private key	PostgreSQL	Encrypted with the key derived from the master password	FR-CRY-03
Private key of a trusted person or recipient	Telegram SecureStorage on their phone	Never leaves the device	FR-CRY-03a
Public keys	PostgreSQL	Plain; authenticity checked with safety codes	FR-CRY-11
Shares submitted on confirmation	PostgreSQL	Sealed for the recipient	FR-CRY-06
Name and phone number of invited persons	PostgreSQL	Plain (needed for SMS); deleted after a decline or expiry	FR-INV-08, NFR-LAW-01
Messages via Telegram, SMS, email	External providers	Owner's name and links only	FR-NOT-07

What the server is trusted for. The server cannot read capsules, but it is trusted for **availability and timing**: it runs the timers and decides when shares are released (waiting period, capsule delay). A compromised server alone still cannot decrypt anything; a compromised server colluding with a recipient could release shares to that recipient early. This, the substitution of public keys (mitigated by FR-CRY-11) and the suppression of activation by a person holding the owner's phone are recorded for the threat model (NFR-SEC-03).

7.5 Activation state machine

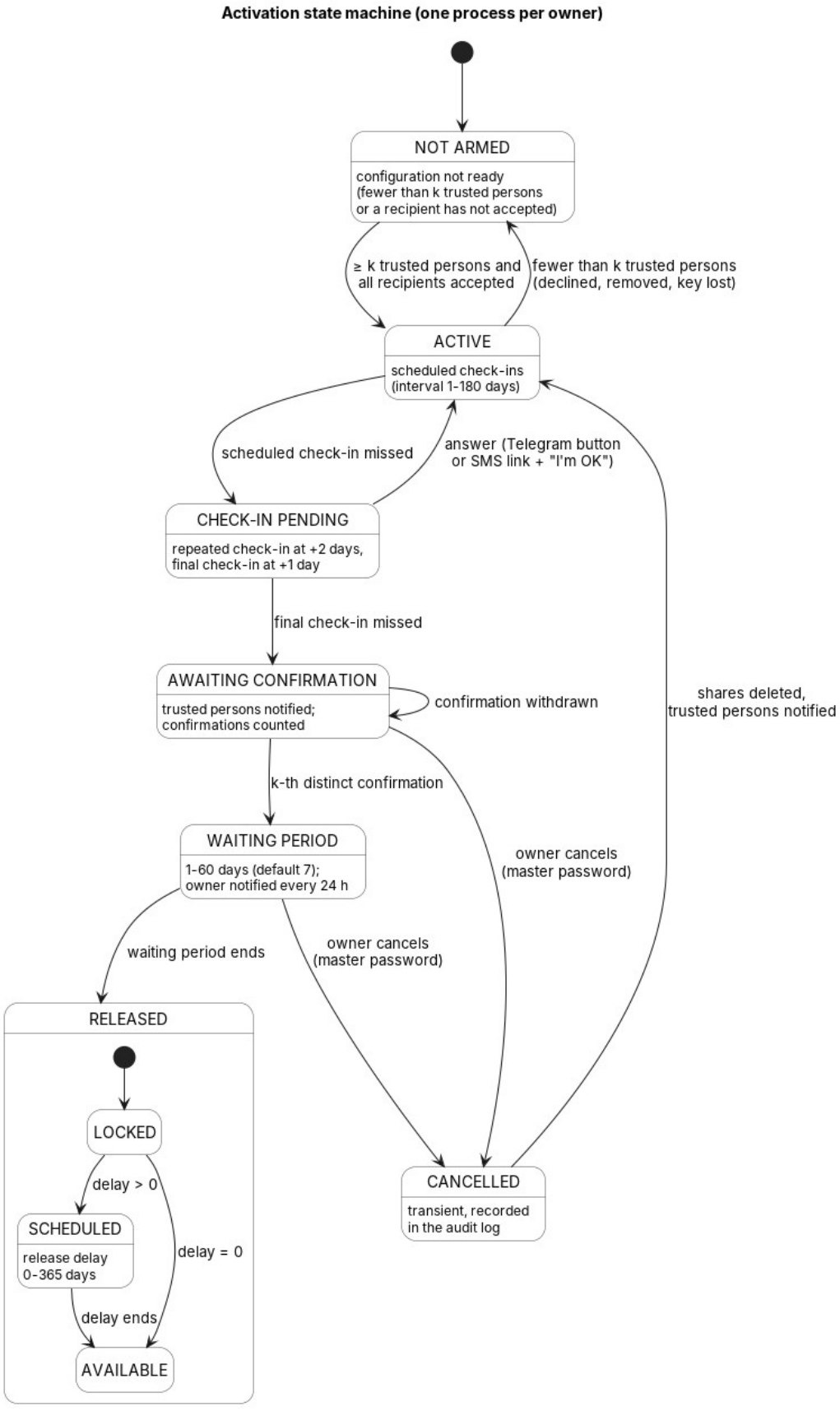


Figure 5. Activation state machine

Source: diagrams/src/04-activation-state-machine.puml (UML state machine)

There is one process per owner (FR-ACT-14). Every transition and the timer that belongs to it are changed in one database transaction (section 5.4b) and recorded in the audit log (FR-ACT-06, FR-ACT-13).

From	Event	To	Effect	Requirements
NOT ARMED	At least *k* trusted persons and every recipient have accepted	ACTIVE	First check-in is scheduled	FR-INV-07
ACTIVE	Fewer than *k* trusted persons remain (declined, removed, key lost)	NOT ARMED	Owner notified	FR-TRU-06, FR-CRY-10
ACTIVE	Scheduled check-in missed	CHECK-IN PENDING	Repeated check-in at +2 days	FR-ACT-03
CHECK-IN PENDING	Answer (Telegram button, or SMS link and "I'm OK")	ACTIVE	Next check-in scheduled	FR-ACT-03, FR-ACT-16
CHECK-IN PENDING	Final check-in (day +3) missed	AWAITING CONFIRMATION	Trusted persons notified	FR-ACT-07, FR-NOT-04
AWAITING CONFIRMATION	Confirmation or withdrawal by a trusted person	AWAITING CONFIRMATION	Count of distinct confirmations updated	FR-ACT-08, FR-ACT-12
AWAITING CONFIRMATION	*k*-th distinct confirmation	WAITING PERIOD	Owner notified on all channels, then every 24 h	FR-ACT-08, FR-ACT-09
AWAITING CONFIRMATION, WAITING PERIOD	Owner cancels with the master password	CANCELLED → ACTIVE	Submitted shares deleted, trusted persons notified	FR-ACT-10
WAITING PERIOD	Waiting period ends	RELEASED	Each capsule enters LOCKED	FR-ACT-11

After RELEASED, each capsule follows its own release delay (FR-ACT-15): **LOCKED → AVAILABLE** when the delay is 0, otherwise **LOCKED → SCHEDULED → AVAILABLE**. A recipient is notified when a capsule becomes AVAILABLE (FR-NOT-06) and sees a SCHEDULED capsule only as unavailable until its date (FR-TRU-08).

Notification transition guards: section 13 applies in addition to the table. A check-in cannot be missed without confirmed transport; total check-in-channel failure holds ACTIVE/CHECK-IN PENDING with a persisted delivery-fault flag. WAITING PERIOD pauses when every permitted owner channel fails; recovery delivers a fresh notice and restarts the full waiting period (FR-NOT-13/14). Existing diagram transitions are conditional on those guards; the delivery fault is metadata, not an extra activation state.

Any transition not listed in the table is rejected. In particular, an SMS check-in link cannot leave WAITING PERIOD (FR-ACT-16), and missed check-ins can never lead to RELEASED without *k* confirmations (FR-ACT-07).

8. UX Prototype and API Examples

Section	Responsible
8.1 Mockup scenarios (DIP-19)	Aibyn Samat
8.2 API examples (DIP-20)	Alisher Medebaev

8.1 Mockup scenarios

Additional interactive prototype: Capsule — Figma Make, supplied by Aibyn on 24.10.2026. It was created with AI assistance and complements the design frames/PNG exports below. It demonstrates interface intent; it is not evidence of implemented cryptography, real Telegram/SMS delivery or measured security/performance. The public-view access and exact scenario coverage must be checked before the committee demonstration.

Figma prototype: *https://www.figma.com/design/TUcjm1m3MKVUpHNSPEMRR0/Mura?node-id=6-2&t=i2iZQjowyfeHM3Ev-1*

PNG exports: `prototype/mockups/` (file names in the table below).

The prototype covers eight scenarios, two more than the six required by DIP-19. Each scenario follows one actor from start to finish, and each frame names the requirement it shows. The same scenarios become the tasks of the usability test (DIP-22).

Frame sizes: the owner cabinet is drawn at 360 px wide (NFR-USE-07) and the Mini App at 390 × 844 px. The interface language is Russian in the first version of the frames. The Kazakh texts are added after the Russian ones are approved and checked by a native speaker (NFR-L10N-01, NFR-L10N-05).

S1. Owner registration

Actor: owner, web application. Requirements: FR-OWN-01, FR-CRY-02, FR-CRY-09, NFR-L10N-02.

Frame	Screen	What it shows
S1-1	Language and sign up	Language switch (RU/KZ); fields for email and master password; a one-sentence note that the master password never leaves the device
S1-2	Master password strength	Strength indicator; a plain sentence that the service cannot reset this password
S1-3	Confirm email	"We sent a link" screen; the account stays locked until the link is opened (FR-OWN-01)
S1-4	Recovery key	Key shown once with Print and Copy buttons; the owner must enter two words from it to continue (design choice supporting NFR-USE-03; it checks that the key was saved)
S1-5	Welcome	Start of the wizard (S2)

S2. Create the first capsule (wizard, steps 1 of 4)

Actor: owner. Requirements: FR-OWN-02, FR-OWN-03, FR-OWN-04, FR-OWN-12, NFR-USE-04, NFR-USE-03.

Frame	Screen	What it shows
S2-1	Wizard progress	Four steps with progress: capsule, trusted persons and *k*, check-in and waiting period, review; a Back button on every step
S2-2	Capsule type	Five content types: credentials, instructions, files and photos, personal messages, business access

Frame	Screen	What it shows
S2-3	Capsule editor	Title, text field, optional checklist of instructions (FR-OWN-12), file upload with the 50 MB limit shown (NFR-CAP-01)
S2-4	Recipient and release delay	Recipient picker; field "release delay after the waiting period, 0 to 365 days" with an example (FR-ACT-15)
S2-5	Encryption explained	A short panel at the save button: "The capsule is locked on your device. Only the people you choose can open it."

S3. Add trusted persons and set k of n

Actor: owner. Requirements: FR-OWN-06, FR-ACT-04, FR-INV-02, FR-INV-07, FR-OWN-13, NFR-USE-03.

Frame	Screen	What it shows
S3-1	Trusted persons list	Empty list, button to add; counter "from 1 to 5 people"
S3-2	Add a person	Name and phone number; warning that the person needs Telegram and a recommendation to choose more people than *k* (FR-OWN-13)
S3-3	Choose *k*	Slider or stepper for *k*; default 2; sentence that updates with the choice, for example "Any 2 of your 3 people must confirm"
S3-4	Error state	*k* larger than *n* or *n* above 5 rejected with a message
S3-5	Invitation status	Per person: sent, accepted, declined, expired; resend button; banner "Not ready" while fewer than *k* have accepted (FR-INV-07)
S3-6	Optional Telegram invite	Prepared message the owner sends from their own Telegram (FR-INV-03)

S4. Check-in and waiting period settings, then review (wizard, steps 3 and 4)

Actor: owner. Requirements: FR-OWN-07, FR-ACT-01, FR-ACT-02, FR-ACT-03, FR-ACT-05, FR-NOT-09, NFR-USE-06.

Frame	Screen	What it shows
S4-1	Check-in settings	Interval (1 to 180 days), time of day, channels (SMS, Telegram), at least one required
S4-2	Total silence	Live line under the interval: "The process starts after about 10 days without an answer" for 7 days; the page shows about 4, 10 and 33 days for 1, 7 and 30 (FR-OWN-07)
S4-3	Waiting period	Field from 1 to 60 days, default 7, with a one-line explanation of what happens in it
S4-4	Review	Summary of capsule, people, *k*, interval and waiting period; the button "Arm" is active only when the configuration is "ready"
S4-5	Dashboard, state ACTIVE	State, last and next check-in, invitation statuses, ready or not ready, all on one screen (FR-OWN-08)

S5. Answer the "Are you OK?" check-in

Actor: owner, Telegram and SMS. Requirements: FR-NOT-02, FR-NOT-03, FR-ACT-03, FR-ACT-16.

Frame	Screen	What it shows
S5-1	Telegram message	"Are you OK?" with one button; one tap answers
S5-2	SMS text	Two segments at most (NFR-L10N-03) with the link

Frame	Screen	What it shows
S5-3	Link page	Single page with the "I'm OK" button; opening the link alone does nothing (FR-ACT-16)
S5-4	Done	"Thank you, the next check-in is on DD.MM.YYYY"
S5-5	Used or expired link	Clear message in the user's language (FR-NOT-03)
S5-6	Waiting period link	The link shows that it cannot stop a running waiting period and points to the web application (FR-ACT-16)

S6. Accept an invitation (trusted person and recipient)

Actor: invited person, Telegram bot and Mini App. Requirements: FR-INV-02, FR-INV-04, FR-INV-05, FR-INV-06, FR-CRY-03a, FR-TRU-01, FR-TRU-06, NFR-USE-05.

Frame	Screen	What it shows
S6-1	SMS	Short explanation, name of the owner, link, mention that Telegram is needed
S6-2	Welcome message	Who added the person, their role, what will be asked, that they cannot see the owner's data, that it is free, buttons Accept, Decline, More (FR-INV-04)
S6-3	Share phone number	Telegram contact sharing button (FR-INV-05)
S6-4	Number mismatch	Rejection when the number differs from the one the owner entered
S6-5	Key created	Mini App makes the key on the phone; one sentence of explanation; no technical terms
S6-6	Accepted	Role, owner name, status "accepted" (FR-TRU-01)
S6-7	Help	At most three short screens: what a key share is, why the server cannot read the data, what happens if the phone is lost (FR-TRU-10)

The path S6-2, S6-3, S6-5, S6-6 should take at most five taps (NFR-USE-05); count them on the prototype and write the number in the frame notes.

S7. Trusted person confirms the event

Actor: trusted person, Mini App. Requirements: FR-NOT-04, FR-TRU-03, FR-TRU-04, FR-TRU-05, FR-ACT-08, FR-CRY-06, NFR-USE-05, NFR-USE-06.

Frame	Screen	What it shows
S7-1	Telegram notification	The owner did not answer check-ins; the message has no capsule data (FR-NOT-07)
S7-2	Confirmation screen	Plain explanation of what is being confirmed and the button "Confirm the event" (FR-TRU-03)
S7-3	Are you sure	Second step that states the consequence: the data will be handed over after the waiting period unless the owner cancels (FR-TRU-04)
S7-4	Sent	The screen says the confirmation was sent and shows no count of other confirmations (design choice to avoid pressure on the other trusted persons)
S7-5	Withdraw	"Withdraw" button available until the waiting period starts (FR-TRU-05)
S7-6	Key check	One-tap key check every 180 days: message with Open, Mini App checks and closes, short confirmation (FR-TRU-07)

Confirmation takes three steps at most: open, confirm, "Are you sure" (NFR-USE-05).

S8. Owner cancels during the waiting period, recipient opens the capsule

Two short flows that end the story.

Owner, web application. Requirements: FR-ACT-09, FR-ACT-10, FR-OWN-09, NFR-USE-06.

Frame	Screen	What it shows
S8-1	Email and Telegram alert	The waiting period started, days left, link to the cabinet
S8-2	Dashboard, WAITING PERIOD	State with a countdown; the Cancel button is visible (not visible in RELEASED)
S8-3	Cancel dialog	States the consequence (shares deleted, trusted persons notified) and asks for the master password
S8-4	Back to ACTIVE	Confirmation and the history entry (FR-ACT-13)

Recipient, Mini App. Requirements: FR-NOT-06, FR-TRU-08, FR-TRU-09, FR-CRY-07, FR-ACT-15.

Frame	Screen	What it shows
S8-5	Notification	Owner name and a link to the bot, no title or content
S8-6	Capsule list	Only the recipient's capsules; a capsule under release delay appears without a title and with its date
S8-7	Open capsule	Decrypted content on the screen
S8-8	Download file	File download after local decryption

Checklist before submission

- At least six scenarios have clickable frames; S1 to S8 give eight.
- Every frame has the requirement IDs in its notes.
- The Figma link opens in a private window without an access request.
- PNG exports are in `prototype/mockups/`, named `S1-1.png`, `S2-3.png` and so on.
- The link is added at the top of section 8.1.
- Text contrast is checked (NFR-USE-08) and the owner frames are checked at 360 px (NFR-USE-07).

8.2 API examples

For external systems and for the Mini App the interaction is described by a draft REST API:

- Specification: prototype/api/openapi.yaml — OpenAPI 3.0.3, 22 paths with request and response examples (validated with `openapi-spec-validator`; can be opened in Swagger Editor).
- Explanation and example flow: prototype/api/README.md.

Client	Authentication	Main endpoints	Requirements
Owner web application	Session after login with the authentication key derived from the master password	`/auth/*`, `/capsules`, `/capsules/{id}/content`, `/capsules/{id}/shares`, `/persons`, `/activation/*`	FR-CRY-12, FR-OWN-01…13, FR-ACT-01…16
Telegram Mini App	Telegram init data, no account	`/mini/invitations/{token}/accept`, `/mini/key-check`, `/mini/confirmations/{ownerId}`,	FR-INV-01…08, FR-CRY-03a, FR-CRY-06, FR-CRY-07, FR-TRU-01…10

Client	Authentication	Main endpoints	Requirements
		`/mini/capsules`	
SMS check-in page	Single-use token in the link	`/checkins/{token}/answer`	FR-ACT-16, FR-NOT-02, FR-NOT-03
Telegram bot	Webhook secret	`/telegram/webhook`	FR-INV-04, FR-INV-05

The examples follow the scenarios above: registration (S1) sends only the authentication key and the encrypted private key; capsule creation (S2, S3) uploads ciphertext and shares sealed for each trusted person; confirmation (S7) sends shares re-encrypted on the phone for the recipients; opening a capsule (S8) returns ciphertext and sealed shares that are decrypted in the Mini App. At no step does the server receive plaintext, the master password or a private key (NFR-SEC-01).

9. Verification and Evaluation Plan

Section	Responsible
9.1 Test levels and tools, 9.2 Outcome metrics, 9.3 Baseline solution, 9.4 Evaluation scenarios and measurement conditions	Alisher Medebaev (DIP-21)
9.5 Usability evaluation	Aibyn Samat (DIP-22)

The plan shows how the aim of the project (`docs/01-proposal.md`, section 1.5) will be demonstrated: data is released only after a confirmed event, nobody but the recipients can read it, and false activations are rarer than in a simple dead man's switch. Every metric is linked to requirement IDs from `docs/06-requirements.md`.

9.1 Test levels and tools

Level	What is tested	Tools	Requirements
Unit	Crypto Core (encryption, key derivation, splitting, sealed boxes, safety codes); rules of the state machine	Vitest (TypeScript), JUnit 5 (Java)	FR-CRY-01…12, FR-ACT-06
Integration	REST API, PostgreSQL, Quartz timers, notification gateways replaced by test doubles	Spring Boot Test, Testcontainers (PostgreSQL)	FR-ACT-01…16, FR-INV-01…08, NFR-REL-01, NFR-REL-02
Protocol simulation	Life scenarios of an owner with a controllable clock: months of check-ins, escalation, confirmations, waiting period and release in seconds	JUnit 5 with an injected `Clock` and the Quartz test scheduler	FR-ACT-03…15
Security	Zero-knowledge property, key substitution, check-in tokens, rate limiting, access control of the Mini App endpoints	Own test suite, OWASP ZAP baseline scan	NFR-SEC-01…07, FR-CRY-11, FR-ACT-16
Performance	Encryption, splitting and key derivation in real browsers and phones	Browser benchmark page, Playwright	NFR-PERF-01, NFR-PERF-02
End-to-end	Scenarios S1–S8 of the prototype (section 8.1) on the running system	Playwright; Telegram test environment for the bot and Mini App	FR-OWN, FR-TRU, FR-NOT
Usability	See section 9.5	—	NFR-USE-01…08

Cryptographic code uses only established libraries (NFR-SEC-02). Its tests therefore check **correct use** of the libraries — parameters, key separation, formats, error handling — not the primitives themselves. Known test vectors from RFC 9106 (Argon2id) and NIST SP 800-38D (AES-GCM) are used where they exist.

9.2 Outcome metrics

ID	Metric	Target	How it is measured	Requirements
M1	False activation rate: data released while the owner is alive and the trusted persons are honest	0 in all scenarios of section 9.4	Protocol simulation; count of scenarios that reach RELEASED although the owner is alive	FR-ACT-07, FR-ACT-08, FR-ACT-10
M1b	Share of false activations compared with the baseline in a randomized simulation	Proposed system not higher than the baseline in every cell of the table below; 0 with $p = 0$	Simulation of 1,000 living owners per cell (fixed random seed): absence of 7, 14, 30 or 60 days; each of $n = 3$ trusted persons confirms by mistake with probability $p = 0$, 0.05 or 0.2; $k = 2$; check-in interval 7 days; waiting period 7 days; the owner returns after the absence and cancels if the waiting period is still running. Results are compared with the formula in the note after the table.	FR-ACT-03, 04, 07, 10

ID	Metric	Target	How it is measured	Requirements
M2	Access to content with fewer than *k* shares or with a full copy of the server database	0 successful attempts	Attempts to reconstruct the key from every combination of $k-1$ shares; decryption attempts with the database dump and server logs only	FR-CRY-04, NFR-SEC-01
M3	Detection of a substituted public key	100% of substitutions detected when safety codes are compared	Security test: the server returns an attacker's key; the code shown to the owner differs from the code in the Mini App	FR-CRY-11
M4	Key reconstruction from *k* shares	100% success in 1,000 random runs for every pair (k, n) with $2 \le k \le n \le 5$	Unit test with random keys	FR-CRY-04, FR-CRY-07
M5	Plaintext leakage	0 occurrences	A unique "canary" string is stored in a capsule title and content, a test master password and a recovery key; the database dump, server logs and HTTP traffic are searched for them	NFR-SEC-01, NFR-SEC-07, FR-CRY-12
M6	Lost or duplicated timers after a server restart	0	Integration test: restart during CHECK-IN PENDING and WAITING PERIOD; timers fire once and no later than 1 hour after the due time	NFR-REL-01
M7	Time from the owner's death to release with default settings	Reported, not a target: 30 + 3 days + time to *k* confirmations + 7 days	Protocol simulation with confirmations after 1, 3 and 7 days	FR-ACT-01…05
M8	Notification delivery when one channel fails	100% delivered through the remaining channels; at least 3 retries logged	Integration test with the SMS gateway double returning errors	NFR-REL-02
M9	Check-in token misuse	0 accepted answers from a link preview, a used token or an expired token	Security test: GET without the button press, repeated POST, POST after expiry	FR-ACT-16
M10	Encryption and splitting of a 10 MB capsule	≤ 3 s (median of 10 runs)	Benchmark page in Chrome on a mid-range laptop	NFR-PERF-01
M11	Argon2id key derivation	≤ 2 s (median of 10 runs)	Benchmark page in the mobile browser and in the Mini App on a mid-range Android phone and an iPhone	NFR-PERF-02
M12	Unsafe progress caused by notification transport failure	0 outage-caused escalations or releases	E10/E11 and NR-02/03/04/06/07 with controllable clock, transient/permanent provider doubles and restart	FR-NOT-12, FR-NOT-13, FR-NOT-14, NFR-REL-01, NFR-REL-02

M1 counts false releases only in the stated living-owner scenarios with honest trustees. E3 has a deceased owner; E5 is an adversarial collusion case whose cancellation outcome assumes reachable owner channels and an owner who actually cancels. No zero-false-release guarantee is made for an unreachable owner and k colluding trustees. The one-hour final reply window is rounded away in day-granularity M1b; exact timer tests must include it.

M1–M3 and M5 carry the main claim of the project; the others check that the mechanism works reliably and fast enough.

Expected results of M1b. With a check-in interval of 7 days the process starts after 10 days of silence (FR-ACT-03). The baseline releases the data on day 10, so it falsely releases in every run with an absence of 14, 30 or 60 days and does not release after 7 days. In the proposed system the earliest release is on day 17 (10 days plus the waiting period), so only absences of 30 and 60 days can end in a false release, and only when at least *k* of the trusted persons confirm by mistake. If mistakes are independent, this probability is $3p^2(1-p) + p^3$: 0 for $p = 0$, 0.725% for $p = 0.05$ and 10.4% for $p = 0.2$. Report the simulated proportions with 95% Wilson intervals; finite-sample deviation is expected and is not by itself proof of an implementation defect. Investigate discrepancies beyond the specified sampling uncertainty. The values of p and the absence lengths are the project's own assumptions (ASM): they are used to

compare the two designs, not to predict real behavior, and the results are reported as a sensitivity analysis.

M2 (unauthorized access) is measured by two tests: (1) for every combination of $k - 1$ shares with $2 \le k \le n \le 5$, the key is not reconstructed and the capsule is not decrypted; (2) a full copy of the server database and logs does not allow decryption of any capsule (scenario E6). **M10 and M11** measure the time targets of NFR-PERF-01 and NFR-PERF-02.

9.3 Baseline solution

The baseline is a **simple dead man's switch**: data is released to the recipients after a fixed time of silence, with no trusted persons and no waiting period. This is how the timer-only services in section 4 (Cipherwill, Just In Case) and the formal dead man's switch in the literature (section 3.2.5) decide that the event happened.

For a fair comparison the baseline is obtained **from the same Activation Engine** with a different configuration: no confirmation step ($k = 0$) and a waiting period of 0 days. Both variants then share the same code for check-ins, escalation, timers and notifications, so the difference in results comes only from the rules of the hybrid activation and not from different implementations. The baseline configuration exists only in the test environment. The cryptographic threshold is never zero: for baseline delivery only, the owner wraps a capsule key directly for each recipient and the server holds that encrypted envelope until the timer gate. E3 must assert that the recipient can decrypt, not merely that a state says RELEASED. These baseline envelopes never enter the proposed trustee protocol. Both variants share the same delivery-fault guard; an extra unsafe timer-only variant may be reported separately, but cannot be presented as an isolated comparison of k-of-n activation.

Parameter	Baseline	Proposed system
Check-ins and escalation	Same (interval, +2, +1)	Same
Confirmation by trusted persons	None	k of n, default 2
Waiting period with cancellation	None	1–60 days, default 7
Who can read the data	Recipients only (same encryption)	Recipients only

9.4 Evaluation scenarios and measurement conditions

M1b is a sensitivity experiment separate from deterministic E1-E11: use a published fixed seed, 1,000 paired synthetic living-owner runs per absence/probability cell, record the absence distribution and trustee-independence assumption as ASM, and report false-release counts/percentages for each variant with uncertainty. The durations 7/14/30/60 days are conditional cells, not a measured population distribution. Initial transport is successful in those cells; outages are isolated in E10/E11.

Each scenario is run in the protocol simulation for both configurations with a check-in interval of 7 days, $k = 2$ of $n = 3$ and a waiting period of 7 days.

ID	Scenario	Expected result: baseline	Expected result: proposed system	Metric
E1	Owner travels without connection for 14 days	Data released on day 10 (false activation)	No release: trusted persons know the owner is alive and do not confirm	M1
E2	Owner is in hospital for 30 days, trusted persons are unsure and one confirms	Data released on day 10	No release with one confirmation; if k confirm, the owner can still cancel during the waiting period	M1

ID	Scenario	Expected result: baseline	Expected result: proposed system	Metric
E3	Owner dies	Data released on day 10	Data released after *k* confirmations and the waiting period (later than the baseline)	M7
E4	One trusted person falsely claims the death, the owner is alive and answers check-ins	Not applicable (no confirmation step)	No release: the process does not start and one confirmation is not enough	M1
E5	Two trusted persons collude while the owner is alive	Not applicable	Owner is notified every 24 hours during the waiting period and cancels	M1
E6	Server database and logs are stolen	No content readable (same encryption)	No content readable	M2, M5
E7	Malicious server substitutes a trusted person's public key	Not applicable	Detected by the safety code comparison	M3
E8	Server restarts during the escalation and the waiting period	Timers fire once	Timers fire once	M6
E9	Someone holding the owner's phone keeps answering "I'm OK" after the owner's death	Release delayed indefinitely	Release delayed as well, but the person cannot read the data	Limitation, recorded in the threat model (NFR-SEC-03)
E10	Living owner; SMS and Telegram fail for 60 days	Shared delivery guard pauses escalation; no outage-caused release	Same guard; persist delivery fault, email warning only if available	M12, M1
E11	All owner channels fail during WAITING PERIOD, including across a restart; then recover	No waiting period; not applicable	Pause release, reject old deadline, deliver fresh notice and restart full waiting period; cancellation still succeeds	M12, M6, FR-NOT-14

E9 is a limitation shared by both designs. It is reported openly: the proposed system protects the confidentiality of the data, but anybody who controls the owner's check-in channels can delay the release.

Measurement conditions

Item	Condition
Test environment	Backend and PostgreSQL in Docker on one machine; notification gateways replaced by test doubles except in the end-to-end tests
Clock	Injected clock in the protocol simulation; real time in the end-to-end tests
Browsers	Latest stable Chrome and Safari at the time of the measurement; versions are recorded with the results
Devices	One mid-range Android phone and one iPhone for NFR-PERF-02 and the Mini App; models are recorded with the results
Repetitions	Performance: 10 runs, median reported; M4: 1,000 random runs per (*k*, *n*); scenarios E1–E11: each run once per configuration (the simulation is deterministic); M1b: 1,000 runs per cell with a fixed random seed
Data	Synthetic capsules and test accounts only; no real personal data

Standalone design-model results are in verification/pre-defense-model-results.md, generated by `node tests/simulation/pre-defense-model.cjs`. They validate the specified assumptions and guards only; they are not execution of a Spring Boot/Quartz/gateway implementation and do not satisfy M2/M5/M6/M8/M10/M11 by themselves.

Results are reported per metric as target, result and verdict (met, not met, not measurable), in the same format as the usability report (section 9.5). The comparison with the baseline (E1–E11 and M1b) is the main evidence for the aim of the project.

9.5 Usability evaluation

9.5.1 Goal and what is measured

The test checks whether ordinary people can set up the platform and act in it without help. It uses the Figma prototype (section 8.1) and measures the usability requirements NFR-USE-01, 02, 03, 05 and 06. The tasks are the eight prototype scenarios, so every task maps to frames that already exist.

Metric	Target	Source requirement	How it is measured
SUS score	At least 70	NFR-USE-01	System Usability Scale [16 in section 3], filled in after all tasks
Task success rate	At least 80% of participant-task attempts completed without help	PRP (project evaluation target)	Observer marks each attempt: success, success with a hint, failure
First capsule with two trusted persons (T2)	At least 80% of participants finish in at most 15 minutes	NFR-USE-02	Stopwatch from the first tap of S2 to the dashboard in S4-5
Time on task	Targets in the task table	PRP	Stopwatch per task
Taps to accept an invitation	At most 5	NFR-USE-05	Observer counts taps on S6-2, S6-3, S6-5, S6-6
Steps to confirm an event	At most 3, and no confirmation after a single tap	NFR-USE-05, FR-TRU-04	Observer counts steps and notes any accidental confirmation
Understanding of k of n	At least 4 of 5 participants explain it correctly in their own words	NFR-USE-03	Comprehension question after the setup (see below)
Irreversible actions understood	Every participant who reaches a confirmation dialog can say what will happen	NFR-USE-06	Question after T7 and T8
Ease per task	Mean of at least 5 on a 7-point scale	PRP	Single Ease Question after each task

The targets are the project's own and come from the requirements. With five participants the numbers are indicative, and the report will give means and ranges and will not claim statistical significance.

9.5.2 Participants

Five owners and three helpers, eight people in total. Owners do T1 to T5 and T8 (owner part). Helpers do T6, T7 and T8 (recipient part). If a participant can play both roles, they do the tasks of both groups and fill in one SUS.

Group	Number	Profile
Owners	5	Adults who use several online accounts; at least one over 45 and at least one small business owner
Helpers (trusted person, recipient)	3	Adults who use Telegram daily and have no technical background

At least three participants should not have taken part in the earlier interviews (DIP-5), so they see the prototype for the first time. Participants speak Russian, and the test runs in Russian because the first version of the prototype is in Russian. One pilot session with a person outside the group checks the script and the timing; its results are not counted.

Participants are recorded as U-01 to U-08. No names, phone numbers or photos are stored in the repository.

9.5.3 Tasks

Each task is given as a short situation without naming the buttons. The observer does not explain the interface and gives a hint only after 90 seconds without progress; a hint is recorded and the attempt counts as "success with a hint".

Task	Situation given to the participant	Prototype scenario	Success criterion	Target time
T1 Register	"You decided to try the service. Create an account."	S1	Account created and recovery key confirmed	5 min
T2 First capsule and trusted persons	"Leave your family documents and instructions for your daughter, and choose two people who will confirm if something happens."	S2, S3, S4	Capsule saved, two people added, *k* chosen, settings reviewed, "Arm" pressed	15 min
T3 Check-in settings	"Make the service ask you every two weeks at 18:00."	S4	Interval 14 days and time 18:00 saved	2 min
T4 Check-in answer	"A message arrives asking if you are OK. Answer it." (Telegram, then SMS link)	S5	Answer sent with one tap in Telegram, and by link plus one button in SMS	1 min each
T5 Check the status	"Find out whether everyone you invited has accepted."	S3-5, S4-5	Correct statuses read aloud	1 min
T6 Accept an invitation	"Your friend asked you to be a trusted person. Accept."	S6	Invitation accepted in at most 5 taps	2 min
T7 Confirm an event	"You learn that your friend cannot answer. Confirm the event."	S7	Confirmed in at most 3 steps, no accidental confirmation	2 min
T8 Cancel and open	Owner: "You are back and the process has started. Stop it." Recipient: "You received access. Open the letter."	S8	Cancellation done with the master password; capsule opened	3 min each

Task order for owners is fixed (T1 to T5, T8) because later tasks depend on earlier ones. For helpers, T6 and T7 are swapped for half of the participants to see whether order changes the result of the confirmation task.

9.5.4 Comprehension questions

Asked after the tasks, before the SUS. The observer notes the answer word for word and marks it correct, partly correct or wrong against the reference answer.

Question	Reference answer	Requirement
"In your own words, what does '2 of 3' mean here?"	Two of the three chosen people must confirm before anything is passed on; one person cannot do it alone	NFR-USE-03
"Can the service read what you stored?"	No, it is locked on the owner's device	NFR-SEC-01
"What happens when you press 'Confirm the event'?"	Nothing is handed over at once; a waiting period starts after enough confirmations and the owner can stop it	FR-TRU-04
"What happens if you lose your phone?"	The key on it is lost; the owner must be told and the shares are recreated	FR-TRU-10
"What do you do if you forget the master password?"	Use the recovery key	FR-CRY-09

9.5.5 Procedure

1. Welcome and consent (3 min). The consent text states that the prototype is tested and not the participant, that the session is recorded on screen only if the participant agrees, and that data is anonymized.
2. Short background questions: age group, how often they use Telegram, whether they have stored passwords for relatives (3 min).

3. Tasks with thinking aloud (about 25 min for owners, 12 min for helpers). The observer records time, taps or steps, success, hints, errors and quotes on the note sheet.
4. Single Ease Question after each task.
5. Comprehension questions (5 min).
6. SUS questionnaire (3 min).
7. Closing question: "What would worry you before trusting the service with real data?" (3 min).

The session takes about 45 minutes for owners and about 25 minutes for helpers. Owner tasks are run on a laptop at desktop width and on a phone at 360 px if time allows; Telegram and Mini App tasks run on the participant's own phone through the prototype link, so the phone frame is not needed.

9.5.6 Scoring and analysis

SUS is scored in the usual way: for odd items subtract 1 from the answer, for even items subtract the answer from 5, add all ten values and multiply by 2.5. The result is between 0 and 100. SUS is reported for owners, helpers and all participants.

Problems found are listed with a severity: critical (the participant cannot finish), major (finishes with a hint or after a long detour), minor (hesitates or complains). Every critical and major problem goes into the backlog with a link to the frame where it appeared. The report states, for each metric, the target, the result and a verdict (met, not met, not testable with this prototype).

9.5.7 Materials and data handling

Material	**Location**
Consent text, task cards, note sheet, SUS form in Russian	`docs/usability/`
Anonymized notes and SUS answers (U-01 to U-08)	`docs/usability/results/`
Screen recordings	Not stored in the repository

No names, phone numbers or other personal data are committed.

9.5.8 Limits of the test

The prototype has no real encryption, no real Telegram and no real SMS, so it measures understanding and flow and cannot measure the delay of key derivation or the behavior of Telegram SecureStorage on different phones (CON-03). Eight participants cannot confirm the SUS target statistically. The Kazakh interface is not covered in this round; it is tested after the Kazakh texts are reviewed by a native speaker (NFR-L10N-05). A moderated session gives the observer's hints some influence on the time results, which is why hints are recorded and reported separately.

10. Project Management

Task: DIP-23. Responsible: Aibyn Samat. Status: done for pre-defense 1; updated on 24.10.2026 after the supervisor feedback (task register in section 10.1.1, tasks DIP-26 and DIP-27).

Dates marked `[TBD]` depend on the schedule of the department and the supervisor and are to be filled in as soon as they are confirmed.

10.1 Team and responsibilities

Area	Alisher Medebaev	Aibyn Samat
Repository, YouTrack, tagging, submission	DIP-1, DIP-2, DIP-25	Review of pull requests
Proposal and scope	DIP-3 (`01-proposal.md`)	Review
Evidence of relevance	Review	DIP-4, DIP-5, DIP-6 (`02-relevance-evidence/`)
Literature review	Review	DIP-7, DIP-8, DIP-9 (`03-literature-review.md`)
Existing systems	DIP-11: verification of cryptographic criteria	DIP-10 (`04-existing-systems.md`)
Technology comparison	DIP-12: backend, database, crypto libraries, interaction	DIP-13: frontend, notification services
Requirements	DIP-14: sections 6.1–6.4, 6.9 (encryption, key shares, activation, security)	DIP-15: sections 6.5–6.8 (cabinets, capsules, check-ins, notifications, usability, localization)
Diagrams	DIP-16 system context, DIP-18 component	DIP-17 use case
Architecture	DIP-18 (`07-architecture.md`)	Review
Prototype	DIP-20: API examples (section 8.2)	DIP-19: Figma mockups (section 8.1)
Verification	DIP-21: protocol, security, metrics, baseline	DIP-22: usability evaluation (section 9.5)
Project management	Review	DIP-23 (`10-project-management.md`)
Supervisor communication	DIP-24 (`11-supervisor-feedback.md`)	Takes part in meetings
Legal analysis (Kazakhstan)	Review	DIP-26 (`12-legal-analysis.md`, prepared 24.10.2026)
Notification reliability	Review; tests M6, M8, M12 (DIP-21)	DIP-27 (`13-notification-reliability.md` and section 6.7.1)

Working rules:

- Every document change goes through a pull request. `main` requires one approval from the partner.
- Each task has one assignee in YouTrack; the other member is the reviewer.
- Tasks that depend on the partner's work (section 10.4) are discussed in the team chat before the due date, not on the due date.
- No secrets, interview recordings or personal data are committed.

10.1.1 Task register

Every task has one responsible member and one reviewer, the other member (working rules above). The milestone is taken from section 10.2; "PR" lists the pull requests that delivered the task.

Task	Title	Responsible	Reviewer	Milestone	Status	PR
DIP-1	Repository structure, README, PR template	Alisher	Aibyn	M1	Done	#1, #23
DIP-2	YouTrack project, milestones and backlog	Alisher	Aibyn	M1	Done	in YouTrack
DIP-3	Project proposal and scope	Alisher	Aibyn	before M3 (22.10)	Done	#2
DIP-4	Interview guide and consent template	Aibyn	Alisher	M2	Done	#6
DIP-5	User interviews	Aibyn	Alisher	M2	Done	#7
DIP-6	Findings summary: verified findings and assumptions	Aibyn	Alisher	M2	Done	#8
DIP-7	Literature review: sources, part A	Aibyn	Alisher	M2	Done	#14
DIP-8	Literature review: sources, part B	Aibyn	Alisher	M2	Done	#14
DIP-9	Critical literature review	Aibyn	Alisher	M4	Done	#14
DIP-10	Existing systems comparison	Aibyn	Alisher	M2	Done	#13
DIP-11	Verification of cryptographic criteria of existing systems	Alisher	Aibyn	M2	Done	#19, #25
DIP-12	Technology comparison: backend, storage, crypto libraries	Alisher	Aibyn	M3	Done	#4
DIP-13	Technology comparison: frontend, notification services	Aibyn	Alisher	M3	Done	#12
DIP-14	Requirements: sections 6.1–6.4, 6.9	Alisher	Aibyn	M3	Done	#3, #11, #18, #25
DIP-15	Requirements: sections 6.5–6.8	Aibyn	Alisher	M3	Done	#9
DIP-16	System context diagram	Alisher	Aibyn	M3	Done	#5
DIP-17	Use case diagram	Aibyn	Alisher	M3	Done	#10
DIP-18	Component diagram and architecture	Alisher	Aibyn	M4	Done	#20
DIP-19	UX prototype: Figma mockups	Aibyn	Alisher	M4	Done	#15
DIP-20	API examples (OpenAPI draft)	Alisher	Aibyn	M4	Done	#21, #24
DIP-21	Verification and evaluation plan	Alisher	Aibyn	M4	Done	#22
DIP-22	Usability evaluation plan	Aibyn	Alisher	M4	Done	#16
DIP-23	Project management and risks	Aibyn	Alisher	M4	Done	#17, #26
DIP-24	Supervisor feedback and decisions	Alisher	Aibyn	M4, M6	Done for round 1 (24.10.2026)	this change
DIP-25	Tag `pre-defense-1` and submission summary	Alisher	Aibyn	M5	Done: tag on the merge of #27, summary in `docs/submissions/pre-defense-1.md`	#27
DIP-26	Legal analysis: Kazakhstan personal data law and inheritance law	Aibyn	Alisher	M5, 24.10.2026 18:00 UTC+5	Document prepared; review and deployment gates open	this follow-up to #27
DIP-27	Notification reliability: specification and tests	Aibyn	Alisher	M5, 24.10.2026 18:00 UTC+5	Specification and model prepared; integration/live tests pending	this follow-up to #27

Balance: Alisher is responsible for 12 tasks (repository, proposal, cryptography, architecture, API, verification, feedback) and Aibyn for 15 (research, requirements 6.5–6.8, use cases, prototype, usability, project management, legal analysis, notification reliability). Reviews are done by both members for all pull requests.

10.2 Milestones

The first block is fixed by the task plan. The second block lists the later milestones with the deliverables they must produce; dates are filled in after they are agreed with the supervisor.

ID	Milestone	Date	Deliverables	Tasks
M1	Repository and tracker ready	20.10.2026 – 21.10.2026	Repository with structure, README, protected `main`; YouTrack project with backlog	DIP-1, DIP-2
M2	Evidence and sources collected	22.10.2026	Interview guide, interview notes, findings table; literature sources; existing systems comparison	DIP-4 – DIP-8, DIP-10, DIP-11
M3	Requirements and technology choices	22.10.2026	Requirements 6.1–6.8; technology comparison; system context and use case diagrams	DIP-12 – DIP-17
M4	Architecture, prototype and plans	23.10.2026	Literature review; component diagram and architecture; Figma mockups; API examples; verification and usability plans; this document; drafts sent to supervisor	DIP-9, DIP-18 – DIP-24
M5	Pre-defense 1	24.10.2026	Tag `pre-defense-1` on reviewed `main`; submission summary with known limitations and outstanding tasks	DIP-25
M6	Supervisor feedback processed	Round 1: 24.10.2026; later rounds: November 2026	Every comment in `11-supervisor-feedback.md` has a decision and a link to the change; requirements updated	DIP-24 follow-up
M7	Open questions closed	November 2026 (expert review and implementation follow-ups; DIP-26/27 documents delivered for 24.10)	Expert interview (notary or IT security) done; legal analysis written and the personal data location decided (`12-legal-analysis.md`); notification reliability specified and its tests described; threat model written (NFR-SEC-03)	DIP-26, DIP-27; follow-up of DIP-5, DIP-6, DIP-14
M8	Working core	December 2026	Client-side encryption, key splitting and the activation state machine running in `src/` with tests in `tests/`	Implementation
M9	Working system and test results	January 2027	End-to-end flow with Telegram Mini App and notifications; results of the protocol and security tests; baseline comparison against a simple dead man's switch	Implementation, DIP-21
M10	Usability test	February 2027	Eight participants, SUS and task results, list of problems with severity	DIP-22
M11	Pre-defense 2	March 2027	Updated report, demonstration of the working system	All
M12	Final defense	May 2027	Final report, repository tag, presentation	All

10.3 Risk register

Scales. Probability: Low (unlikely during the project), Medium (could happen), High (expected or already visible). Impact: Low (a small delay or rework), Medium (a requirement or a deliverable has to change), High (the aim or a main objective is threatened).

ID	Risk	Probability	Impact	Mitigation	Owner
R-01	The interview sample is small and not representative: three respondents aged 40+, no domain expert, short messenger answers	High	Medium	Mark findings as assumptions when only one interview supports them; add an expert interview and 1–2 younger respondents (M7); report limitations in `02-relevance-evidence/README.md`	Aibyn
R-02	Trusted persons depend on Telegram: a person without Telegram cannot take part, and SecureStorage support outside iOS and Android clients is unverified (CON-01 to CON-04)	Medium	High	Recommend *n* greater than *k*; keep SMS for invitations and notifications; verify Mini App and SecureStorage behavior on the prototype early; run a TelegramBots / Spring Boot 4.1 compatibility spike before implementing the adapter (review of PR #12)	Alisher
R-03	A malicious server could substitute a trusted person's public key, if safety	Medium	High	Define key authentication (via security code verification, FR-CRY-11) in the threat model	Alisher

ID	Risk	Probability	Impact	Mitigation	Owner
	codes are not compared or a previously verified key is replaced (literature review, section 3.2.3)			(NFR-SEC-03); add a test case to the verification plan	
R-04	A lost or replaced phone destroys a trusted person's key, and fewer than *k* shares remain after the owner is gone (CON-02, FR-CRY-10)	Medium	High	Periodic key checks every 180 days; re-split by the owner (FR-CRY-08); *n* greater than *k*; explain the consequence in the interface	Alisher
R-05	False activation: the owner is alive but silent (travel, hospital) and data is released	Medium	High	Three check-ins, *k* confirmations, a waiting period with daily notifications and cancellation with the master password; measure the false activation rate against the baseline (M1, M1b and scenarios E1–E11 in the verification plan, DIP-21)	Alisher
R-06	Legal uncertainty in Kazakhstan: Article 12 requires Kazakhstan personal-data storage; actual hosting and transfer compliance are not yet evidenced; consent of a trusted person whose phone number is entered by the owner (FR-INV-08); transfer of numbers to an SMS provider	Medium	High	Open, partially mitigated 24.10.2026: section 12 maps official articles; LD-01 selects Kazakhstan storage and NFR-LAW-01 is Must; initial invitation/transfer gates are NFR-LAW-02/04. Expert interview, provider assessment and implementation tests remain open; no claim of operational compliance	Aibyn
R-07	A custom or unaudited cryptographic implementation introduces a vulnerability	Low	High	Use only WebCrypto, libsodium and an audited Shamir library (NFR-SEC-02); test with known vectors; second reviewer for every cryptographic change	Alisher
R-08	Argon2id or encryption is too slow on mid-range phones (NFR-PERF-01, NFR-PERF-02)	Medium	Medium	Measure early on real devices; choose parameters by measurement and document them; lower the memory setting if the 2 s target fails	Alisher
R-09	SMS or Telegram delivery in Kazakhstan is unreliable or too expensive, so check-ins or confirmations do not arrive	Medium	High	Retry at least three times and keep channels independent (NFR-REL-02); compare providers by delivery and cost (DIP-13); fall back to the other channel; an undelivered check-in is never counted as missed (FR-NOT-13); specification and model checks in section 13 (DIP-27); FR-NOT-14 pauses waiting-period release during total outage; integration/live tests remain open	Aibyn
R-10	Usability results are only indicative: the prototype has no real encryption or Telegram, and eight participants cannot confirm the SUS target statistically	High	Medium	Report means and ranges without claiming significance; record hints separately; measure key derivation time and SecureStorage behavior in the technical tests, not in the usability test	Aibyn
R-11	The team has two members and several tasks fall due on the same days; illness or overload of one member delays the other's review	Medium	High	Keep the task table in section 10.4 up to date; start reviews as soon as a draft exists; agree in advance which tasks can move without breaking dependencies	Aibyn
R-12	The literature review contains unverified details: some sources were read only in part, preprints are not peer reviewed, article numbers of laws and some bibliographic data were not rechecked	Medium	Medium	Recheck against publisher pages and adilet.zan.kz before each defense; keep the list of unchecked sources in section 3.7 current	Aibyn
R-13	Scope grows (for example additional release rules beyond FR-ACT-15, or other channels such as WhatsApp) and the core is not finished	Medium	Medium	Decide each request against the in-scope list in the proposal; record rejected ideas with a reason; build the core (M8) before extensions	Alisher
R-14	Supervisor feedback arrives late and forces changes to requirements or architecture	Medium	Medium	Send proposal and requirements by 22.10 (DIP-24); keep the feedback log with a decision for every comment; keep changes small and traced to requirement IDs	Alisher
R-15	Personal data or secrets are committed by mistake (interview details, keys, tokens)	Low	High	`.gitignore` and a check before every commit; anonymized notes only; review of every pull request for personal data; remove and rotate anything exposed	Alisher

10.4 Task dependencies

An arrow in the diagram means "the second task needs the result of the first".

The dependency graph is shown in Figure 6 on the next page.

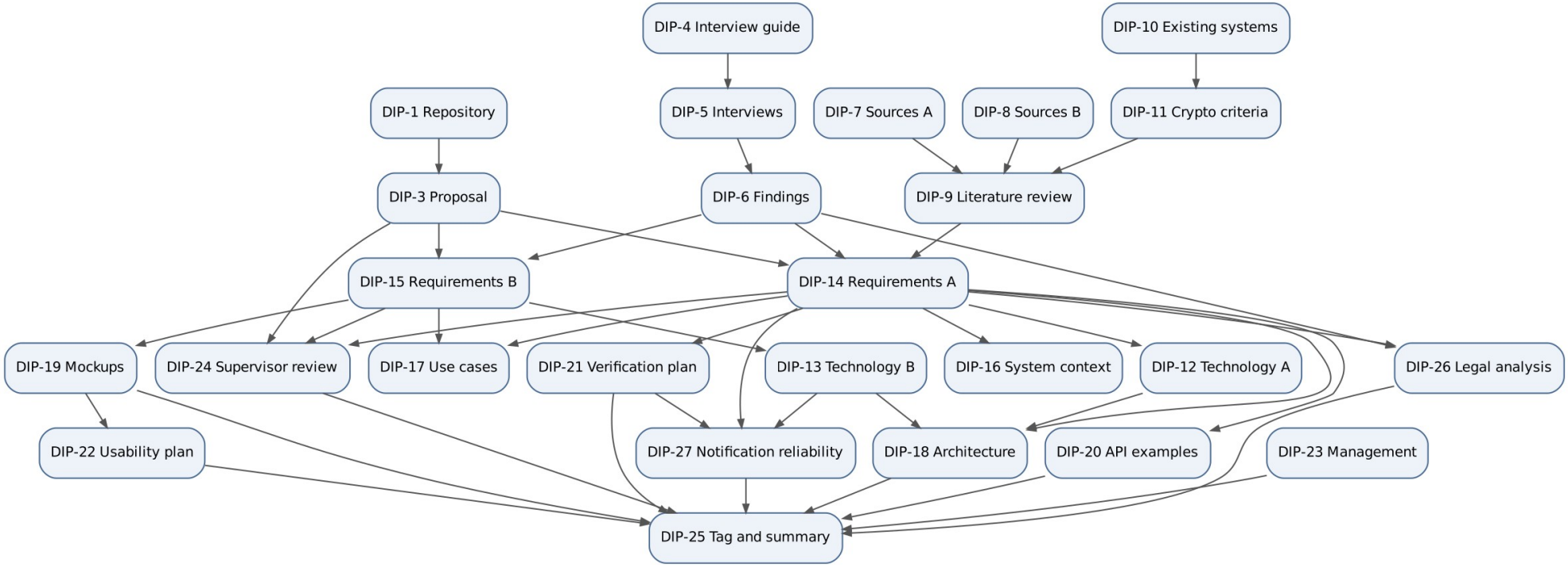


Figure 6. Task dependencies (an arrow means "the second task needs the result of the first")

Task	Depends on	Why
DIP-3 Proposal	DIP-1	Written and reviewed as a pull request in the repository
DIP-5 Interviews	DIP-4	The guide gives questions, consent text and the note template
DIP-6 Findings	DIP-5	Every finding refers to interview IDs
DIP-9 Literature review	DIP-7, DIP-8, DIP-11	Needs all sources and the comparison of systems it refers to
DIP-10 Existing systems	DIP-7, DIP-8	Analyzes existing systems
DIP-11 Crypto criteria	DIP-10	Cryptographic criteria verify existing systems
DIP-14 Requirements A	DIP-3, DIP-6, DIP-9	Requirements cite the proposal, findings and literature as sources
DIP-15 Requirements B	DIP-3, DIP-6	Same as above
DIP-12 Technology A	DIP-14	Criteria are linked to requirements
DIP-13 Technology B	DIP-15	Same as above
DIP-16 System context	DIP-14	Actors and external systems come from requirements; actors must match DIP-17
DIP-17 Use cases	DIP-14, DIP-15	Each use case maps to a requirement
DIP-18 Architecture	DIP-12, DIP-13, DIP-14	Must be consistent with technology choices and requirements
DIP-19 Mockups	DIP-15	Each frame names the requirement it shows
DIP-20 API examples	DIP-14	Shows that only encrypted data reaches the server
DIP-21 Verification plan	DIP-14	Every metric traces to a requirement
DIP-22 Usability plan	DIP-19	Tasks must match the mockup scenarios
DIP-24 Supervisor review	DIP-3, DIP-14, DIP-15	Proposal and requirements go to the supervisor by 22.10
DIP-26 Legal analysis	DIP-6, DIP-14	Findings and the notary interview give the questions; requirements NFR-LAW-01 and FR-INV-08 are checked against the law
DIP-27 Notification reliability	DIP-13, DIP-14, DIP-21	Uses the chosen channels and providers, the requirements NFR-REL-01/02 and the metrics M6, M8, M12
DIP-25 Tag and summary	All document tasks including DIP-26 and DIP-27; list unexecuted implementation/expert checks explicitly	Tag is placed on reviewed `main`; unfinished tasks are listed as outstanding

Critical path to pre-defense-1: DIP-4 → DIP-5 → DIP-6 → DIP-14 and DIP-15 → DIP-17, DIP-18, DIP-19 → DIP-25. A delay in the interviews moves the source column of the requirements and everything after it. If the interviews slip, the requirements are submitted with the source ASM and the findings table is completed in the next iteration; this is recorded as an outstanding task in DIP-25.

Cross-member handoffs (the places where one member waits for the other):

From	To	What	Needed by
Aibyn	Alisher	Findings table (DIP-6) for the sources of requirements	22.10
Aibyn	Alisher	Existing systems table (DIP-10) for verification of cryptographic criteria (DIP-11)	22.10
Alisher	Aibyn	Requirements 6.1–6.4 for the use cases and mockups	22.10
Alisher	Aibyn	Technology choices for the notification services that affect NFRs	22.10
Aibyn	Alisher	Mockups (DIP-19) and usability tasks for the shared prototype document	23.10
Both	Both	Pull request reviews of the documents marked "Reviewed by partner"	Before 24.10

10.5 Maintenance of this document

The risk register is reviewed at every milestone. A risk is closed only when its mitigation is done and checked; the closing date and the evidence are added to the row. New risks found in reviews, interviews or tests get the next free ID. The dates marked `[TBD]` are replaced as soon as the supervisor confirms them.

11. Supervisor Feedback

Task: DIP-24. Responsible: Alisher Medebaev. Reviewer: Aibyn Samat. Supervisor: Tutkyshbayeva Sh.S.

11.1 How feedback is recorded

Every comment gets an ID (SF-nn), a decision (accepted, accepted in part, rejected with a reason), the change that follows from it (file and section) and a status. Comments are recorded in writing, in the original wording (section 11.4). Dates of sent materials and of meetings are added to section 11.3 as they happen; nothing is entered here that did not take place.

11.2 Feedback log

Round 1: written comments received on 24.10.2026

ID	Comment (summary)	Decision	Change	Where	Status
SF-01	The aim is overloaded: it contains the whole mechanism. The aim should say what is done and why; the mechanism belongs to the tasks.	Accepted. The aim is rewritten in the proposed form. The mechanism stays in objectives 3–5, the evaluation in objective 7.	New aim in section 1.5; reference to the objectives added	`01-proposal.md` 1.5, 1.6; README opening; Word synchronization assigned to Alisher	Markdown updated; Word pending
SF-02	There is no task for the legal analysis, although the scope includes Kazakhstan legislation and risk R-06 is rated High. Needed: a task "Analyse the requirements of the Law of Kazakhstan on personal data and of inheritance law for the platform".	Accepted. DIP-26 is assigned to Aibyn, reviewer Alisher, for the document deadline 24.10.2026 18:00 UTC+5. Section 12 now contains the official-article mapping, Kazakhstan hosting decision and consent/transfer gates. The expert interview is absent and recorded as a limitation, not fabricated.	Objective 8 added; DIP-26 in the task register, milestone M7, dependency table and graph; R-06 mitigation refers to DIP-26	`01-proposal.md` 1.6; `10-project-management.md` 10.1–10.4; `12-legal-analysis.md`	Analysis document prepared 24.10; reviewer/expert and deployment checks open
SF-03	The criteria of the verification task are not measurable: "false activation" and "resistance to unauthorized access" are not measured. Needed: simulation scenarios, share of false activations compared with the baseline, tests that $k-1$ shares do not restore the key, time by NFR-PERF.	Accepted. Metrics M1–M11 existed in the plan but were not visible in the task. They are now stated per metric with a threshold and a method; a randomized comparison with the baseline (M1b) is added.	M1b added with expected values; M2 described as two tests (every combination of $k-1$ shares; stolen database); M10 and M11 tied to NFR-PERF-01/02; scenario E10 added	`09-verification-plan.md` 9.2, 9.4	Done
SF-04	Reliability of notifications (NFR-REL-01/02) is mentioned in one phrase, although a missed notification leads to false activation. Make it a separate task or a sub-item.	Accepted both ways: a sub-item in the requirements and a separate task DIP-27 (Aibyn, reviewer Alisher) with a full specification prepared for 24.10.2026 18:00 UTC+5.	FR-NOT-12 (delivery log, definition of "delivered") and FR-NOT-13 (an undelivered check-in is not counted as missed); section 6.7.1; metric M12 and scenario E10; R-09 mitigation	`06-requirements.md` 6.7/6.7.1; `09-verification-plan.md` 9.2/9.4; `13-notification-reliability.md`; `10-project-management.md` 10.3	Section 13 matrix, retries, all-channel failure guards and standalone model prepared; integration/live tests not run
SF-05	The work must be distributed between the members and every task must have a responsible person, as already done in section 10.1, because the commission will assess each member's contribution.	Accepted. Section 10.1.1 lists every task (DIP-1 to DIP-27) with the responsible member, the reviewer, the milestone, the status and the pull requests.	Task register added	`10-project-management.md` 10.1.1	Done

Changes found while processing the feedback

Finding	Change
A stray row of the notification catalogue broke the table of section 6.7 (FR-NOT-05 to FR-NOT-11 were rendered outside the table).	Row removed.
The catalogue said that the trusted persons receive an SMS "if the bot has not been started", FR-NOT-04 says "if Telegram delivery fails (for example, the bot is blocked)".	Catalogue aligned with FR-NOT-04.

Deadline follow-up: 24.10.2026

The initially proposed 07.11.2026 document deadline was superseded by the team deadline of 24.10.2026, 18:00 Asia/Qyzylorda. Legal analysis and reliability documents are prepared for review now. Preparation is not supervisor approval. No Word edits, expert interview, live-delivery result or system benchmark is claimed without evidence. Alisher prepares the formatted Word version from these reviewed sources; the revised aim and objective/responsibility table must be synchronized there.

Additional Figma Make prototype supplied by Aibyn is linked in README and section 8.1, with its AI-assisted demonstration scope stated.

Open after round 1

Item	Owner	Due
Review of section 12 and actual supplier/transfer/consent deployment evidence	Aibyn; reviewer Alisher	Before any real-data pilot; document prepared 24.10.2026
M6/M8/M12 integration/live-provider results against section 13	Alisher; specification Aibyn	Implementation phase; specification/model prepared 24.10.2026
Expert interview (notary or IT security)	Aibyn	November 2026 (M7)

11.3 Communication log

Date	Event	Result
24.10.2026	Written comments of the supervisor received (two messages)	SF-01 to SF-05

11.4 Original comments (Russian)

24.10.2026, message 1. «Цель перегружена: в неё включено всё описание механизма. Цель должна отвечать на вопрос "что и зачем", а механизм лучше перенести в задачи. Вариант: "Разработать платформу передачи цифрового наследия, которая передаёт зашифрованные данные владельца выбранным получателям только после подтверждённого события, без доверия к провайдеру и с защитой от ложной активации"».

24.10.2026, message 2. «Задачи нужно дополнить:

1. Правовой анализ. В scope есть пункт "учёт законодательства РК", но отдельной задачи нет, хотя риск R-06 оценён как High. Нужна задача: "Проанализировать требования Закона РК о персональных данных и наследственного права к платформе".
2. Измеримые критерии в задаче 7. Сейчас "ложная активация" и "устойчивость к несанкционированному доступу" не измеряются. Нужно указать, как именно: сценарии

симуляции, доля ложных активаций по сравнению с baseline, тесты "k−1 долей не восстанавливают ключ", время по NFR-PERF.

3. Надёжность уведомлений (NFR-REL-01/02) упоминается в задаче 5 одной фразой, хотя пропущенное уведомление ведёт к ложной активации. Стоит выделить в отдельную задачу или подпункт.
4. Распределение по участникам. Проект командный, и комиссия будет оценивать вклад каждого. Нужно указать ответственного у каждой задачи, как это уже сделано в разделе 10.1».

12. Kazakhstan Legal Requirements and Design Decisions

Task: DIP-26. Author: Aibyn Samat. Reviewer: Alisher Medebaev. Prepared: 24.10.2026 for pre-defense 1.

12.1 Scope and evidence

This is a requirements analysis of the official texts, not a legal opinion or a certificate of compliance. The platform transfers encrypted information; it does not determine heirs, establish death legally, transfer ownership or replace a notarial will. The legal position of an individual online account also depends on the provider's contract and the nature of the rights involved.

The Personal Data Law [1] was inspected on the official Adilet portal on 24.10.2026, including the displayed amendments and commencement notes. The Civil Code provisions [2] were checked on the official Adilet legacy portal on the same date. Recheck the applicable edition before deployment. No lawyer/notary interview has taken place in the evidence available for this submission: I-01 to I-03 are user interviews, not expert opinions. An expert interview remains an explicit limitation; no I-04 is invented.

12.2 Norm-to-design traceability

The legal rule and the project's implementation decision are separated below. A requirement is a design obligation, not evidence that working software already satisfies it.

Official provision	Requirement of the provision (summary)	Project decision / requirement	Verification evidence needed
Personal Data Law, Article 7(1), (6), (8), (9) [1]	Consent is the general basis, subject to statutory exceptions; processing and disclosure must have specific lawful purposes and use no excessive data.	NFR-LAW-02; FR-INV-08. Collect only necessary contact and role information; do not assume an owner's consent replaces the invited person's consent.	Data inventory, legal basis for each field and operation, consent flow review.
Article 8(1), (4)-(7) [1]	Consent must be confirmable; its content includes operator, purpose-related data, duration, third-party and cross-border information; withdrawal must be handled.	NFR-LAW-02. Versioned notice and explicit unticked consent control; record subject, notice version, scope and timestamp. Provide a withdrawal route.	Consent record and withdrawal tests; complete operator details before a real-data pilot.
Article 12(1)-(2) [1]	Collect necessary/sufficient data and keep personal-data storage in Kazakhstan; retention is linked to the processing purpose.	NFR-LAW-01 raised from Should to Must. Kazakhstan placement for the application database, replicas, backups, contact-bearing logs and recovery copies.	Hosting contract/region, backup location and restore inventory; no real-data launch without this evidence.
Article 7(6), Article 16 [1]	Third-party and cross-border transfers have conditions; cross-border transfer is not automatically permitted merely because a provider offers encryption.	NFR-LAW-04. Inventory SMSC.kz, Telegram and Resend, their subprocessors, destination countries, data and legal basis.	Processor/transfer assessment and notice; a local domain name is not proof of local processing.
Article 18, Article 25(2) [1]	Deletion and protection duties apply in the specified circumstances; an operator must document and demonstrate compliance.	FR-INV-08; NFR-LAW-02. Delete declined/expired invitation contacts within the project's 24-hour target, with documented backup retention and deletion propagation.	Deletion tests across primary storage, logs, queues and backups. The 24-hour value is a stricter project target, not a quotation from the law.
Article 22(1)-(2) [1]	Protect data against unauthorized access throughout its processing lifecycle and account for relevant actions.	NFR-SEC-01, NFR-SEC-04, NFR-SEC-07; NFR-LAW-01. Encryption of capsule content does not remove obligations for readable contact	Access-control tests, minimized audit logs, incident and retention procedures.

Official provision	Requirement of the provision (summary)	Project decision / requirement	Verification evidence needed
		metadata.	
Civil Code, Articles 1038-1040 [2]	Inheritance concerns rights/property that survive death and has statutory or testamentary grounds; some personal rights are excluded.	NFR-LAW-03; proposal 1.8. A selected capsule recipient is not certified as a legal heir by the service.	Scope and interface wording review.
Articles 1046 and 1050 [2]	Testamentary disposition and the required form of a will are governed separately.	NFR-LAW-03. Capsule instructions and trustee confirmations are technical directions, not a substitute for the legally required will or proof of death.	No product claim that capsule creation transfers property or authorizes access to every external account.

12.3 Hosting decision

Decision LD-01: production personal-data storage, including backups and operational copies, must be physically located in Kazakhstan. The preferred deployment is a Kazakhstan-hosted application and PostgreSQL instance with backups in Kazakhstan; the exact supplier is not yet contracted. This makes NFR-LAW-01 a Must now, rather than postponing the decision until procurement. Development and the pre-defense demonstration use synthetic contacts and content only.

Before real personal data is processed, Alisher must record the provider, physical region, backup/replica locations, support access and recovery arrangements. A provider choice without those facts does not pass the deployment gate. This document does not claim that a server has already been rented or configured.

Local primary storage does not by itself settle transfers to Telegram, SMS or email providers. Resend's existing selection is provisional for personal-data traffic: assess it or replace it before a real-data pilot. Send no capsule titles, plaintext, keys or shares in notifications (FR-NOT-07). A phone number, an email address or an identifying message is still personal data even if capsule content is encrypted.

12.4 Consent and the first invitation

FR-INV-08 covers explicit acceptance, refusal/expiry and the deletion target. It does **not** itself establish a legal basis for the earlier step in which an owner enters somebody else's name/number and the server sends an SMS. Later consent must not be treated as retroactively proving that earlier processing was lawful.

Decision LD-02: until a documented lawful basis for that initial processing is reviewed, the server-SMS invitation flow is demonstrated only with synthetic data. For a real-data pilot, prefer an owner-shared, unidentifying invitation link: the invited person sees the operator notice and gives consent before providing their own contact information. Do not silently change FR-INV-02/05 into a different identity protocol: the resulting changes to invitations and phone verification require review together. Any reliance on an exception under Article 9 needs a specific, justified assessment; none is presumed here.

The consent notice must identify the actual operator, fields, purpose, period, third parties, cross-border handling, withdrawal and contact route. The checkbox shown in mockup S6-2 is evidence of interface intent, not a complete legal notice. Tests must reject acceptance without explicit consent and verify deletion after refusal/expiry. These gates are NFR-LAW-02 and NFR-LAW-04.

12.5 Risk and completion status

R-06 remains **open, partially mitigated**: official article mapping, the Kazakhstan hosting decision and requirement priorities are documented on 24.10.2026. Remaining evidence is expert review, actual supplier/transfer assessment, consent text and working deletion/access-control tests. Probability remains Medium and impact High until those checks exist. The document analysis is ready for review now; operational compliance is not marked complete.

References

1. Republic of Kazakhstan, Law No. 94-V of 21 May 2013, On Personal Data and Their Protection, Articles 7, 8, 12, 16, 18, 22 and 25. Official Adilet text, inspected 24.10.2026: https://adilet.zan.kz/rus/docs/Z1300000094
2. Republic of Kazakhstan, Civil Code (Special Part), No. 409 of 1 July 1999, Articles 1038-1040, 1046 and 1050. Official Adilet text, inspected 24.10.2026: https://old.adilet.zan.kz/rus/docs/K990000409_

13. Notification Reliability Specification

Task: DIP-27. Specification owner: Aibyn Samat. Reviewer and integration-test owner (M6/M8/M12): Alisher Medebaev. Version: 24.10.2026, pre-defense 1.

This specification completes the design deliverable now. Live gateway, restart, browser and device tests remain implementation work; no production delivery measurements are claimed.

13.1 Event, channel and fallback matrix

Only channels configured for that recipient and covered by the applicable consent may be used. Email may warn about failure but cannot answer a check-in or replace the Telegram Mini App's cryptographic operations.

Event	Receiver	Primary dispatch	Fallback / parallel channel	All permitted channels unavailable
Invitation	Invited person	SMS in the synthetic-data prototype (FR-INV-02)	Owner shares a prepared Telegram message (FR-INV-03); real-data use is gated by legal analysis 12.4	Invitation stays SENT/failed-delivery; never accepted automatically; owner sees failure.
Scheduled, repeated and final check-in	Owner	Configured SMS and Telegram, independently	Use the remaining configured check-in channel; email is an operational warning only	Freeze this escalation step; do not count it as missed or enter AWAITING CONFIRMATION. Retry next configured daily check-in time.
Event-confirmation request	Each accepted trusted person	Telegram	SMS after explicit Telegram failure or 60 seconds without confirmation	Keep the request pending; no confirmation is invented and k cannot be bypassed.
Confirmation, withdrawal, decline or failed key check	Owner	Configured SMS, Telegram and email independently	Other configured channels	Persist the event and show it at next login; if it is part of an active release process, apply the owner-notification gate below.
Waiting period start and each 24-hour notice	Owner	All configured SMS, Telegram and email independently	The other configured channels	Pause the release countdown; do not enter RELEASED on an unnotified waiting-period deadline.
Cancellation	Trusted persons	Telegram	SMS if Telegram fails and contact use is permitted	Cancellation takes effect immediately; queue the notice. Notification failure never undoes an owner's veto.
Capsule becomes AVAILABLE	Assigned recipients	Telegram	SMS if permitted and Telegram fails	Queue the notice, show status on next Mini App visit; do not revoke access already correctly released.
Periodic key check	Trusted persons and recipients	Telegram	SMS reminder/link if Telegram fails and consent permits	Record key status as unknown, notify owner when reachable; never count silence as a confirmation.

For confirmation requests, send the initial Telegram attempt at t=0, start SMS fallback by t=60 seconds if needed, and aim to receive a positive transport confirmation within 5 minutes under the assumptions of FR-NOT-04. A provider outage is reported as a failed target, not hidden as successful delivery.

13.2 What confirmation means

Channel	Positive transport confirmation	Not sufficient	Limitation
SMS	Authenticated delivery report/status lookup with a final delivered status and matching provider message ID	HTTP success for enqueueing, a timeout or pending status	A delivery report is not proof that the owner read or understood the SMS.

Channel	Positive transport confirmation	Not sufficient	Limitation
Telegram	Successful Bot API response with a matching chat/message ID	A request merely sent, invalid chat, blocked bot or timeout	Telegram API acceptance confirms dispatch to a chat, not reading on the device.
Email	SMTP/provider accepted-for-delivery response and message ID	Connection attempt, rejection, known bounce	Acceptance is not inbox placement or reading; a later failure invalidates the current notification evidence.

The internal field is `transportConfirmed`, not `humanRead`. The OR of current permitted channel confirmations is used for the notification guard. A reply is a separate authenticated event; link previews never count (FR-ACT-16). Unknown/pending status never counts as success. These are explicit design assumptions (ASM); transport acknowledgements cannot guarantee human awareness or exclude every false release.

Record `eventId`, process/step version, pseudonymous recipient ID, channel, attempt number, due/actual times, provider message ID, status and sanitized failure category. Keep full phone numbers, tokens, credentials and capsule data out of logs. Callbacks are authenticated and matched to the current event/version; duplicates and stale callbacks are idempotent and cannot advance the state twice.

13.3 Retries and recovery

Initial attempt at t=0; at least three retries at +1, +5 and +15 minutes after the initial attempt for transient failures (4 total attempts). Values are project defaults (ASM), not provider guarantees. Honor Retry-After without a busy loop; log deferred attempts. Permanent errors such as invalid address or blocked bot trigger immediate fallback and are not retried unchanged; the three-retry test uses a transient-failure double.

Channels have separate jobs, deadlines and circuit breakers. A failed SMS call cannot block Telegram/email. Use provider idempotency where available; otherwise deduplicate logical actions and tolerate duplicate messages after an ambiguous timeout. Exactly-once external SMS delivery is not promised.

Persist notification intents and timers transactionally with the process transition (outbox + Quartz JDBC JobStore). A restart reloads outstanding attempts rather than clearing them or creating another activation. Delayed callbacks must carry the event version. Recovery of timers must meet NFR-REL-01 (within one hour); timely recovery does not override the transport guard.

After a retry batch is exhausted, persist a visible delivery fault. For check-ins reattempt at the next configured daily time, with new expiry tokens; old tokens cannot count. The ordinary escalation schedule is day 0, +2 and +3 only when transport is confirmed on schedule. An outage suspends that schedule: after successful redispatch restart the full response window for the current step, then preserve the +2/+1 spacing. Never release immediately because an outage consumed the original deadlines. The final check-in has a one-hour response window after confirmed dispatch/redispatch (project assumption). Thus the precise ideal escalation deadline is interval + 3 days + 1 hour. Day-granularity M1b rounds away that hour; exact timer tests must not. The cabinet's approximate total silence text remains interval + 3 days and must disclose the final reply window in detailed settings.

13.4 Fail-closed state guards

`notificationFault` is a persisted flag on the existing activation state, not a new state that silently changes the diagram's vocabulary.

1. A check-in step is missed only after a positive transport confirmation for that step and expiry of its response window with no valid answer. Without confirmation, the current state stays ACTIVE or CHECK-IN PENDING; no escalation based solely on failed transport occurs (FR-NOT-13).
2. Reaching k confirmations enters WAITING PERIOD, but the countdown runs only while the required owner start/daily notification is transport-confirmed. Total owner-channel failure pauses it. After channels recover, deliver a fresh owner notice and restart the full configured waiting period. Record the reset; do not reuse an expired deadline (FR-NOT-14).
3. A valid owner cancellation always succeeds before RELEASED, including during an outage; delete submitted shares and invalidate release jobs transactionally.
4. At the final release transaction recheck k, process version, cancellation, waiting-period expiry and the notification guard. A racing stale timer cannot bypass a pause/cancellation.

This chooses confidentiality and protection from false activation over availability. A permanent total outage can prevent legitimate release indefinitely. Report this as a limitation, not as reliability success; the cabinet shows a delivery fault and the next recovery action.

13.5 Acceptance and test cases

Case	Setup / action	Expected result	Metric / requirement
NR-01	SMS transient failures, Telegram success	Telegram not delayed; at least 3 SMS retries logged with due times; one logical event	M8, NFR-REL-02
NR-02	Both SMS and Telegram fail for 60 simulated days	No outage-caused escalation to AWAITING CONFIRMATION and no release; log fault, email warning only if email is available	M12, E10, FR-NOT-13
NR-03	All owner channels fail at waiting-period start or daily notice	Countdown pauses, no RELEASED despite a fast-forward beyond original deadline; recovery starts a full new waiting period	M12, E11, FR-NOT-14
NR-04	Restart during retries, check-in escalation or paused waiting period	Persisted jobs recover within one hour, no duplicate transition; pause/confirmation status survives	M6, NFR-REL-01
NR-05	Repeated/out-of-order callback or webhook for an old process	No duplicate confirmation or release; stale event ignored and audited	FR-NOT-12, FR-ACT-06
NR-06	Delivery recovers after original check-in deadline	Current step gets a fresh response window; no immediate escalation; old token cannot answer	FR-NOT-13, FR-ACT-16
NR-07	Owner cancels while a delayed release job is queued	Cancellation wins before release; job rejects stale process version	FR-ACT-10, FR-NOT-14
NR-08	A positive SMTP enqueue is followed by a known bounce	Mark failed, use another permitted owner channel; if none succeeds, apply the waiting-period guard	FR-NOT-12, FR-NOT-14

Specification review and a standalone model can be run for pre-defense 1. Backend integration tests with actual persistence, callbacks and provider contracts are not yet executable; Alisher owns those results in DIP-21. Results must distinguish `model checked`, `integration not run` and `live-provider not run`.

13.6 Operations and alerting

Monitor failed/pending attempts by channel, oldest outbox age, delayed Quartz jobs and paused processes. Alert the operator via a separate operational route after a failed retry batch; expose the same fault at next login. Acknowledging an operational alert does not mark a user message delivered. Store alert/contact metadata in the Kazakhstan deployment and assess third-party transfers under section 12.3. Before a pilot, set thresholds from actual provider behavior and document rate limits; no delivery percentage is claimed from the present mockups.

Appendix A. Interview Guide

Task: DIP-4. Author: Aibyn Samat.

The interviews themselves were conducted in Russian. This guide is written in English like the rest of the repository; the Russian wording that was actually sent to respondents is in Appendix A.

1. Purpose

The interviews check whether the problem is relevant for ordinary people and domain experts, and confirm or reject the assumptions behind the requirements. We want to know how people currently handle access to their digital data if they suddenly cannot use it themselves, what they fear, whom they trust, and what they would accept.

Assumptions to verify (the IDs are used in interview notes and in the findings table, DIP-6):

ID	Assumption	Questions	Related requirements
A-01	People have no working way to pass access to their digital data to close people	1, 2, 3, 4	Project purpose (PRP)
A-02	People do not trust services to store their personal data in readable form	6, 7	FR-CRY-01, NFR-SEC-01
A-03	A person can name 2–5 trusted persons and is ready to ask them	9, 10	FR-ACT-04
A-04	A waiting period (7 days by default) before data release is acceptable	11	FR-ACT-05
A-05	"Are you OK?" check-ins by SMS or Telegram are acceptable in frequency and channel	11	FR-ACT-01, FR-ACT-02
A-06	A false activation and a failed activation are judged differently	12, 13	FR-ACT-07, FR-ACT-10
A-07	Some people are willing to pay for such a service	14	Outside the requirements

2. Format

An interview is a voice or video call of 20–30 minutes. A messenger conversation counts as an interview when three conditions are met: questions are sent one or two at a time, follow-up questions are asked when an answer is short or unclear, and the note states that the format was a messenger conversation. The full list of questions is never sent at once, otherwise it becomes a questionnaire. Experts (notary, lawyer, IT security specialist) are better interviewed by call.

Rules for the interviewer:

- Do not name or evaluate the product before block D. Before that, ask only about past experience and current habits.
- Do not hint at an answer and do not offer options inside a question. If the person is silent, wait, then ask for an example.
- Do not argue or correct. If an answer is unexpected, ask a follow-up question.
- Do not name prices or periods before the respondent names their own.
- Universal follow-ups: "Tell me more", "Can you give an example?", "How did it go last time?", "Why is that?".
- Record quotes verbatim but keep them short. Write your own conclusions separately.

3. Respondent profiles

3–5 interviews are needed, including at least one domain expert if one can be found.

Profile	Who	Why
P1	Adult without technical background, 25–45	Main target audience
P2	Adult 50+	Different digital literacy, more often faces inheritance questions
P3	Technically experienced user (student, developer)	Attitude to encryption and password managers
P4	Notary or lawyer	Legal side: inheritance of digital data in Kazakhstan, personal data
P5	Information security specialist	Threats, key-splitting schemes, trust in client-side encryption

Respondents are identified only by profile code and interview number (I-01…I-05). Names, workplaces and exact age are not recorded.

4. Consent text

Read aloud before a call or sent in the messenger before the conversation. A reply "I agree" is needed (written, or verbal with a note). A signature is not required.

> *Hello! My name is Aibyn. I am a student working on a project: a web service that helps pass access to digital data to close people if a person does not come online for a long time. I want to understand how people solve such problems today and what matters to them. The conversation takes about 20–30 minutes. Participation is voluntary: you can skip any question or stop at any moment without giving a reason. Your name is not used in the project materials; only anonymized answers and conclusions are included. Please do not write names of other people, passwords or account numbers. Do you agree to take part? Please reply "I agree" and I will send the first questions.*

5. Interview script

Introduction (2 minutes)

Thank the respondent, read the consent text, receive the reply, remind that there are no right or wrong answers.

Block A. Current practices

1. Tell me which important digital data you have: accounts, photos, documents, passwords, money in apps.
2. Where do you keep all of this and how do you protect it? What do you do so as not to lose access?
3. Have you or people you know ever needed access to the data or account of another person who could not provide it? Tell me how it went.

Block B. Concerns

1. Have you thought about what will happen to your data if you suddenly cannot use it? If yes, what came to mind?

2. In such a situation, what matters more to you: that the right people can get access, or that no outsider gets it? Why?

Block C. Trust in services

1. Which services for storing passwords, files or notes do you use, and why did you choose them?
2. In your opinion, what happens to your data on the service's side? Who can see it? How do you feel about that?

Idea description (show after block C)

Read or send without adding any evaluation:

> *Imagine a service where a person saves encrypted data or a message in advance for chosen people. The service periodically asks whether everything is fine with the person. If the person does not answer for a long time, their trusted persons must confirm that an event has happened. The key is split between them, so one trusted person is not enough. After the confirmation and a waiting period, the data is opened to the recipient. The service itself cannot read the data.*

Block D. Attitude to the idea and the trustee role

1. What is clear in this description and what is not? What of the things you use today could it be compared to?
2. Whom would you consider as trusted persons? How many such people would you have?
3. If you were asked to be someone's trusted person, what would be acceptable for you to do and what would not?

Block E. Activation and errors

1. How often and through which channel (SMS, Telegram, email, call) would you be ready to receive the question "Are you OK?" How much time without an answer should pass before someone decides that something has happened, and how long should one wait after that until the data is released?
2. Imagine the data was opened to a recipient although you are alive, for example you were in hospital and did not answer. How would you assess this? What would be acceptable in such a situation and what would not?
3. Now the opposite: you cannot answer, and your trusted persons failed to open the data in time. How would you assess this?

Block F. Willingness to pay

1. Do you pay for any services for data storage or security now? If such a service existed, under what conditions would you pay for it, what amount would seem reasonable, and would it seem reasonable at all?

Closing

1. What did I not ask that, in your opinion, should be discussed?

Thank the respondent. Ask whether it is possible to write again if clarifications are needed.

Additional questions for a notary or lawyer (P4)

- L1. What questions about the digital data of a deceased person (accounts, passwords, correspondence, files) do people bring to you?
- L2. How is access of heirs to such data resolved under the legislation of Kazakhstan today?
- L3. What legal questions does it raise when a service stores data intended for third persons after the owner's death?
- L4. How does the personal data law treat the fact that an owner uploads data about other people?
- L5. What risks do you see for trusted persons who confirm an event that has not happened?
- L6. What should be taken into account so that the owner's will has legal significance?

Additional questions for an information security specialist (P5)

- S1. What are the main threats in a system where data is encrypted on the user's side and the key is split between several people?
- S2. How do you assess a k-of-n key-splitting scheme for ordinary users: where does it work well and where does it break?
- S3. What should be considered in check-ins and the waiting period to reduce the risk of false activation and abuse?
- S4. Which security checks would you consider sufficient for such a service?

6. Note template

Copy to `docs/02-relevance-evidence/interviews/I-0X.md`. "Facts" and "Interpretation" are filled in separately. "Facts" contains only what the respondent said. Conclusions, guesses and evaluations of the interviewer go only into "Interpretation".

```
# I-0X

## Metadata
- Date: DD.MM.YYYY
- Format: call / video call / messenger conversation
- Language: Russian / Kazakh
- Duration: __ minutes
- Respondent profile: P_ (no name, workplace or exact age)
- Consent: received verbally / received in writing (date)
- Audio recording: no / yes, deleted on DD.MM.YYYY

## Facts (what the respondent said)

| Question | Short content of the answer | Verbatim quote (1–2 sentences) |
|----------|-----------------------------|--------------------------------|
| 1 | | |
| 2 | | |
| ... | | |

Situations and examples the respondent described:
-

## Interpretation (my conclusions, not the respondent's words)

- What I think this means:
- What was surprising or contradicts expectations:

## Assumptions

| Assumption ID | Supports / contradicts / unclear | Basis (question, quote) |
```

```
|--------------|-----------------------------------|------------------------|
| A-01 | | |

## New requirements or ideas

-

## What remains unclear

-
```

7. Storage and anonymity

- Only anonymized notes are committed to the repository. Screenshots of conversations, audio and contact details of respondents are not added.
- Names, phone numbers, messenger nicknames and organization names are removed from the notes.
- Audio, if any, is deleted after the note is written.
- Before every commit, check that the note contains nothing by which a person can be recognized.
- The findings table (DIP-6) is built only from finished notes; every conclusion refers to an interview ID.

8. Check against DIP-4 acceptance criteria

Criterion	Where it is met
Questions are neutral, not leading	Section 2 (rules), section 5
Covers current practices, fears, trust in services, trustee role, tolerance to false activation, willingness to pay	Blocks A–F
Note template separates facts from interpretation	Section 6
Respondent profiles, 12–15 questions, consent text, note template	Sections 3, 5, 4, 6

Appendix A. Russian wording used in the messenger interviews

Messages were sent one after another; the next message was sent after the reply.

Message 0 (introduction and consent). Здравствуйте, [имя]! Меня зовут Айбын, я студент и делаю проект: сервис, который помогает передать доступ к цифровым данным близким людям на случай, если человек долго не выходит на связь. Хочу понять, как люди сейчас решают такие вопросы.

Это небольшая переписка, примерно на 20-30 минут. Отвечать можно в любое удобное время. Участие добровольное, на любой вопрос можно не отвечать или остановиться в любой момент. В материалах проекта ваше имя не указывается, туда попадут только обезличенные ответы. Пожалуйста, не пишите имена других людей, пароли и номера счетов.

Вы согласны участвовать? Напишите «согласен» или «согласна», и я пришлю первые вопросы.

Message 1.

1. Какие важные цифровые данные есть у вас: аккаунты, фотографии, документы, пароли, деньги в приложениях?

2. Где вы всё это храните и как защищаете? Что делаете, чтобы не потерять доступ?

Message 2.

1. Бывало ли, что вам или кому-то из знакомых нужно было получить доступ к данным или аккаунту другого человека, который сам не мог этого сделать? Расскажите, как это было.
2. Думали ли вы о том, что будет с вашими данными, если вы внезапно не сможете ими пользоваться? Если да, что приходило в голову?

Message 3.

1. Что для вас важнее в такой ситуации: чтобы нужные люди смогли получить доступ или чтобы никто посторонний его не получил? Почему?
2. Какими сервисами для хранения паролей, файлов или заметок вы пользуетесь? Почему выбрали именно их?

Message 4.

1. Что, по-вашему, происходит с вашими данными на стороне такого сервиса? Кто может их увидеть? Как вы к этому относитесь?

Message 5 (idea description and question 8). Теперь коротко об идее, над которой я работаю. Представьте сервис, где человек заранее сохраняет зашифрованное сообщение или данные для выбранных людей. Сервис периодически спрашивает, всё ли у человека в порядке. Если он долго не отвечает, его доверенные лица должны подтвердить, что произошло событие. Ключ разделён между ними так, что одного человека недостаточно. После подтверждения и периода ожидания данные открываются получателю. Сам сервис прочитать данные не может.

1. Что в этом описании вам понятно, а что нет? С чем из того, чем вы пользуетесь сейчас, это можно сравнить?

Message 6.

1. Кого бы вы рассматривали в качестве доверенных лиц? Сколько таких людей у вас нашлось бы?
2. Если бы вас попросили стать доверенным лицом другого человека, что вам было бы приемлемо делать, а что нет?

Message 7.

1. Как часто и по какому каналу (SMS, Telegram, почта, звонок) вы были бы готовы получать вопрос «Вы в порядке?»? Сколько времени без ответа должно пройти, прежде чем кто-то решит, что что-то случилось, и сколько после этого нужно ждать до выдачи данных?

Message 8.

1. Представьте: данные открылись получателю, хотя вы живы. Например, вы были в больнице и не отвечали. Как бы вы это оценили? Что в такой ситуации было бы допустимым, а что нет?
2. Теперь наоборот: вы не можете ответить, а доверенным лицам не удалось открыть данные вовремя. Как бы вы это оценили?

Message 9.

1. Платите ли вы сейчас за какие-то сервисы для хранения данных или безопасности? Если бы такой сервис существовал, при каких условиях вы стали бы за него платить, какая сумма показалась бы разумной и показалась бы ли вообще?
2. Что я не спросил, но, по вашему мнению, стоило бы обсудить?

Message 10 (closing). Большое спасибо за ответы, они очень помогут! Если появятся уточнения, можно будет написать вам ещё раз?

Appendix B. Interview Notes

I-01

Metadata

- Date: 21.10.2026
- Format: messenger conversation
- Language: Russian (quotes are given in the original with an English translation)
- Duration: conversation from 18:57 to 20:26 with breaks; answers are short
- Respondent profile: P1, adult 40+, keeps data on a phone, names no specialized services
- Consent: received in writing in the chat, 21.10.2026
- Audio recording: no

Facts (what the respondent said)

Question	Short content of the answer	Verbatim quote
1	Accounts, documents, money	«Аккаунты, документы, деньги.» (Accounts, documents, money.)
2	Keeps data on the phone, protects it with a password, remembers the password	«Храню в телефоне. Защищаю паролем. Запоминаю пароль.» (I keep it on the phone. I protect it with a password. I memorize the password.)
3	Such cases happened: account data was restored through a third-party application	«Востанавливали данные аккунта через сторонные приложение.» (We restored the account data through a third-party application.)
4	Losing access would be a serious problem	«Очень большая беда будет.» (It would be a very big trouble.)
5	It is more important that the right people get access, because then the data can be restored	«Чтобы нужные люди получили доступ.» (That the right people get access.)
6	Keeps data on the phone with a copy on a computer	«Храню в телефоне с копии в компьютере» (I keep it on the phone with a copy on the computer)
7	Considers the storage not safe: anyone who gets access to the phone can see the data. Has not met other trusted applications	«Других доверенных приложении пока не встричал» (I have not met other trusted applications yet)
8	The description is clear, nothing to compare it with yet	«Пока сравнивать несчем» (There is nothing to compare with so far)
9	Trusted persons: wife and children. A number "4" is written after it (the answer format is "4.", probably four people)	«Доверенные лица - жена и дети.» (Trusted persons are my wife and children.)
10	Everything the trusted person agrees to is acceptable	«Все на что даст согласие доверенное лицо» (Everything the trusted person gives consent to)
11	Channel: SMS. Alarm after 2 days without an answer, then 2 more days before release	«Канал SMS. 2 дня. 2 дня ждать.» (Channel SMS. 2 days. Wait 2 days.)
12	Suggests opening data in stages: only the necessary data in the first 2 days, the rest later	«Первые дня 2 только необходимые данные открыть, а остальные ещё через несколько дней.» (In the first 2 days open only the necessary data, and the rest after a few more days.)
13	No direct answer. Separately suggested a special code for force-majeure situations	«Для форс-мажорных ситуации можно отдельный код какой нибудь выбрать» (For force-majeure situations one can choose some separate code)
14	Does not pay for such services. Would pay if security and anonymity are the main thing. A	«Главное безопасность и анонимность, тогда платил бы.» (The main thing is security and anonymity, then I

Question	Short content of the answer	Verbatim quote
	reasonable amount is 1000 KZT (payment period not stated)	would pay.)
15	Questions 14 and 15 were sent together; there is no separate answer to 15	

Interpretation (interviewer's conclusions, not the respondent's words)

- The respondent is aware of the risk of losing access and describes it as serious, but has no protection in place: phone, password in memory, copy on a computer.
- For him the main thing is that the right people can restore access, rather than that data is hidden from everyone.
- His periods are the shortest of the three interviews (2 + 2 days), noticeably shorter than the 7-day default.
- The idea of staged release of data may become a separate requirement.
- Answers are brief and no follow-up questions were asked, so the reasons behind the answers are not explored.

Assumptions

Assumption ID	Supports / contradicts / unclear	Basis
A-01	Supports	Questions 2, 6: no way to pass access other than memorizing the password
A-02	Partly supports	Question 7: considers storage unsafe, but he speaks about the phone, not about a service
A-03	Supports	Question 9: wife and children
A-04	Contradicts the default value	Question 11: 2 days of waiting, not 7
A-05	Partly supports	Question 11: SMS is acceptable, Telegram is not mentioned
A-06	Unclear	Questions 12, 13: no direct comparison
A-07	Supports	Question 14: ready to pay about 1000 KZT if security and anonymity are ensured

New requirements or ideas

- Staged release of data: the necessary part first, the rest later.
- A separate code for force-majeure situations (meaning not clarified).

What remains unclear

- How many trusted persons exactly (the answer "4." is ambiguous).
- For what period the amount of 1000 KZT was named.
- What he meant by a "separate code for force-majeure situations".
- How he judges a false activation and a failed activation separately.

I-02

Metadata

- Date: 21.10.2026
- Format: messenger conversation
- Language: Russian (quotes are given in the original with an English translation)
- Duration: conversation from 18:19 to 18:32, about 13 minutes
- Respondent profile: P1, adult 40+, low confidence with technology (says so herself)
- Consent: received in writing in the chat, 21.10.2026
- Audio recording: no

Facts (what the respondent said)

Question	Short content of the answer	Verbatim quote
1	Banking apps, email, social networks, family photos, documents, personal chats. Everything is on the phone	«Всё это хранится в телефоне, и многое из этого для меня важно.» (All of this is stored on the phone, and much of it is important to me.)
2	Everything is on the phone; passwords are written in a notebook, she does not remember where. Does not understand technology, avoids changing anything	«Пароли где-то записаны в блокноте, а где именно — уже не вспомню.» (Passwords are written down in a notebook somewhere, and I no longer remember where.)
3	A relative was in hospital, documents were needed from his phone, nobody knew the password, they had to wait until he could tell it	«Пароль никто не знал, пришлось ждать, пока он сам сможет подсказать.» (Nobody knew the password, we had to wait until he could tell it himself.)
4	Had not thought about it, relatives would find it hard to figure out her phone. Wants to write everything down but keeps postponing	«Надо бы как-нибудь всё записать, но постоянно откладываю на потом.» (I should write everything down somehow, but I keep putting it off.)
5	It is more important that close people get access to really needed data, but not to everything	«Личная жизнь всё-таки должна оставаться личной.» (Private life should still stay private.)
6	No specialized services, uses what is already on the phone. Does not understand new apps	«Пользуюсь тем, что уже есть, потому что в новых приложениях не очень разбираюсь.» (I use what already exists because I do not really understand new apps.)
7	Thinks that service staff could theoretically access the data. It worries her a little, but she hopes it is protected	«Думаю, сотрудники сервиса теоретически могут получить доступ к данным.» (I think service employees could theoretically get access to the data.)
8	The purpose is clear. Key splitting and encryption are not quite clear. Compares it to a safe that opens under certain conditions. Would not compare it to banking apps or cloud storage	«Это как сейф, который открывается только при определённых условиях.» (It is like a safe that opens only under certain conditions.)
9	Would choose children or closest relatives, 2–3 people	«Человека два-три.» (Two or three people.)
10	Ready to confirm that something has really happened to the person. Does not want to be responsible for serious decisions or to keep complex passwords	«Не хотела бы отвечать за какие-то серьёзные решения или хранить сложные пароли.» (I would not want to be responsible for serious decisions or to keep complex passwords.)
11	One message per week by SMS or WhatsApp. A week without an answer, then contact the close people. After the confirmation she would wait about a month before release	«Одного сообщения в неделю по SMS или WhatsApp было бы достаточно.» (One message a week by SMS or WhatsApp would be enough.)
12	If data is opened by mistake, it would be unpleasant. A long waiting period and the ability to cancel the release are needed	«Должен быть длительный период ожидания и возможность отменить выдачу.» (There should be a long waiting period and the ability to cancel the release.)
13	If close people cannot get the data in time, that is	«Сервис должен быть надёжным, чтобы в трудный

Question	Short content of the answer	Verbatim quote
	also bad. The service must be reliable	момент не подвести людей.» (The service must be reliable so as not to let people down at a hard moment.)
14	Does not pay for such services, uses free ones. Could pay 500–1000 KZT per month for this one if it were simple and reliable	«Около 500–1000 тенге в месяц, если бы он был простым и надёжным.» (About 500–1000 tenge per month if it were simple and reliable.)
15	A clear instruction is important because not everyone understands technology well	«Важно, чтобы была понятная инструкция.» (It is important to have a clear instruction.)

Interpretation (interviewer's conclusions, not the respondent's words)

- A typical user without technical background: data on the phone, passwords on paper with no known location. She knows the problem from a real case but has not done anything herself.
- For her the main goal of the service is that close people get what is needed. Privacy is a limit: access to "really needed" data, not to everything.
- The concept is understandable overall, while encryption and key splitting cause confusion. Such users need simple explanations.
- The longest pause after confirmation of the three interviews (about a month). She links it directly to protection against mistakes.
- WhatsApp as a notification channel was not mentioned in our requirements.
- She asked for the ability to cancel, which matches the cancellation requirement in the waiting period.

Assumptions

Assumption ID	Supports / contradicts / unclear	Basis
A-01	Supports	Questions 2, 3, 4: real case, passwords in a notebook, keeps postponing the solution
A-02	Partly supports	Question 7: worried that staff could access data, but hopes for protection
A-03	Supports	Question 9: 2–3 close people
A-04	Contradicts the default value	Question 11: a week without an answer and about a month of waiting, longer than 7 days
A-05	Partly supports	Question 11: SMS is acceptable, but she names WhatsApp, not Telegram
A-06	Unclear	Questions 12, 13: both errors are assessed as bad, no comparison
A-07	Supports	Question 14: 500–1000 KZT per month

New requirements or ideas

- Ability to cancel the release (already in the requirements).
- Pass only the needed data, not everything.
- A clear instruction for users without a technical background.
- WhatsApp as a channel (check in DIP-13).

What remains unclear

- What exactly she counts as "needed" data.

- Why she chose a month of waiting rather than a shorter period.
- What prevents her from writing the passwords down for relatives now.

I-03

Metadata

- Date: 21.10.2026 (the exported conversation has no time stamps, to be confirmed)
- Format: messenger conversation
- Language: Russian (quotes are given in the original with an English translation)
- Duration: conversation time not recorded
- Respondent profile: P1/P3, adult 40+, confident user: cloud storage, two-factor authentication, a password manager, the Google "Inactive Account Manager" feature
- Consent: received in writing in the chat
- Audio recording: no

Facts (what the respondent said)

Question	Short content of the answer	Verbatim quote
1	Email, the e-government portal, work files, phone photos, banking apps	«У меня, как и у всех, всё в цифре.» (Like everyone, I have everything in digital form.)
2	Cloud storage with two-factor authentication, backups, a phone number linked to the accounts	«Настроила резервное копирование и привязала номер телефона к аккаунтам.» (I set up backups and linked my phone number to the accounts.)
3	A friend's husband died; access to his email had to be obtained through technical support and documents in order to close his sole proprietorship. After that she set up Google "Inactive Account Manager", wrote the master password on paper, put it in a safe and told her daughter where to look	«Пришлось через техподдержку и документы выбивать доступ к его почте.» (We had to push through access to his email via technical support and documents.)
4	No separate answer; the answer to question 3 already includes what she did about it	
5	The main thing is that outsiders do not get the data; her own people will find everything anyway	«Главное чтобы чужие не утащили, а свои и так всё найдут!» (The main thing is that outsiders do not steal it, and my own people will find everything anyway!)
6	Passwords are in a password manager and in a notebook in a safe. The daughter knows where to look	«Все пароли у меня в надежной программе и в тетрадочке в сейфе.» (All my passwords are in a reliable program and in a notebook in the safe.)
7	Believes everything is reliably encrypted. Feels fine about service-side storage with strong protection and 2FA	«С сильной защитой и 2FA бояться нечего!» (With strong protection and 2FA there is nothing to fear!)
8	The idea is clear. Compares it with Google "Inactive Account Manager": there access is passed automatically, here the key is split between several people	«Только там доступ передается автоматически, а тут ключ разделен между несколькими людьми.» (Only there access is passed automatically, and here the key is split between several people.)
9	Two trusted persons: daughter and sister	«Дочку и родную сестру, итого 2 человека.» (My daughter and my own sister, 2 people in total.)
10	Acceptable: confirm the status and pass the key. Not acceptable: dig through someone's archives or take financial responsibility	«Мне приемлемо просто подтвердить статус и передать ключ.» (For me it is acceptable to simply confirm the status and pass the key.)

Question	Short content of the answer	Verbatim quote
11	A message once a month, better in Telegram or SMS because she may not open email for a week. Alarm after 10 days without an answer. After the confirmation a pause of about 5 more days	«Раз в месяц получать такое сообщение самое то.» (Receiving such a message once a month is just right.)
12	If data is opened while she is alive: unpleasant but not fatal. Acceptable if only the most necessary was viewed, not everything	«Неприятно, конечно, что кто-то раньше времени в мои тайны залез, но не смертельно.» (It is unpleasant, of course, that someone got into my secrets ahead of time, but not fatal.)
13	If close people cannot open the data in time, it is the worst: the whole idea loses its point and relatives are left alone with their problems	«Вот это хуже всего.» (That is the worst.)
14	No direct answer about current payments or an amount. Wants a reliable service with encryption, access through trusted persons after verification, and without "crazy money"	«За это не требуют бешеных денег.» (They do not demand crazy money for it.)
15	Questions 14 and 15 were sent together; the answer is common, see 14	

Interpretation (interviewer's conclusions, not the respondent's words)

- The only respondent who already has a solution (the Google feature, a master password on paper in a safe). The reason is a painful personal experience: she saw the difficulty of getting access to the email of a friend's deceased husband.
- This confirms both that the problem is real and that Google has a working competitor worth including in the system comparison (DIP-10). The difference she herself pointed out: in our service the key is split between several people.
- For her a false activation is acceptable if only the necessary data is opened, and a failed activation is the worst. This is the only direct comparison of the two errors in the three interviews.
- Periods: 10 days before the alarm, about 5 days after the confirmation, a check-in once a month. The spread between respondents is large.
- The answer to question 14 is incomplete, there is no amount. It is not enough to assess willingness to pay.

Assumptions

Assumption ID	Supports / contradicts / unclear	Basis
A-01	Partly supports	Question 3: the problem is real, but she has her own workaround (Google, paper in a safe)
A-02	Partly contradicts	Question 7: trusts encryption and 2FA
A-03	Supports	Question 9: 2 people
A-04	Unclear	Question 11: 10 days before the alarm and about 5 days after the confirmation
A-05	Supports	Question 11: Telegram or SMS, email does not suit
A-06	Supports	Questions 12, 13: a false activation is "not fatal", a failed activation is "the worst"
A-07	Unclear	Question 14: no amount

New requirements or ideas

- Open only the necessary data, not everything.
- The trusted person confirms the status and passes the key, nothing more.
- Consider Google "Inactive Account Manager" as a competitor in the comparison.

What remains unclear

- The exact time of the interview.
- Whether she pays for a password manager or cloud now and how much she would pay for our service.
- What she means by "verification" of trusted persons before the data is released.

Appendix C. Design-Model Results (M1b and notification guards)

Prepared: 24.10.2026. Tasks DIP-21 and DIP-27. Command: `node tests/simulation/pre-defense-model.cjs`.

Evidence level: standalone specification model. No Spring Boot/Quartz, real provider, cryptographic library or device benchmark was executed. A model pass is not a production/security test pass.

C. M1b: paired sensitivity experiment

LCG seed: 20261024; 1,000 paired living-owner runs per cell; n=3, k=2; transport succeeds; independent mistaken trustee confirmations with probability p. Absence lengths are fixed conditional cells, not measured population frequencies. Owner returns/cancels at the end of the absence. Day-level abstraction rounds away the final one-hour reply grace.

Absence (days)	p (ASM)	Baseline false / 1000	Hybrid false / 1000	Baseline %	Hybrid %	Hybrid Wilson 95% interval	Analytical hybrid %
7	0	0	0	0.0	0.0	0.00–0.38%	0.000
7	0.05	0	0	0.0	0.0	0.00–0.38%	0.000
7	0.2	0	0	0.0	0.0	0.00–0.38%	0.000
14	0	1000	0	100.0	0.0	0.00–0.38%	0.000
14	0.05	1000	0	100.0	0.0	0.00–0.38%	0.000
14	0.2	1000	0	100.0	0.0	0.00–0.38%	0.000
30	0	1000	0	100.0	0.0	0.00–0.38%	0.000
30	0.05	1000	7	100.0	0.7	0.34–1.44%	0.725
30	0.2	1000	91	100.0	9.1	7.47–11.04%	10.400
60	0	1000	0	100.0	0.0	0.00–0.38%	0.000
60	0.05	1000	5	100.0	0.5	0.21–1.17%	0.725
60	0.2	1000	112	100.0	11.2	9.39–13.31%	10.400

The paired model never exceeds the baseline and has zero false releases with p=0. A nonzero p can cause false release while the owner is alive; these numbers do not establish a real-world false-activation rate. Finite-sample deviation from the analytical binomial probability is expected, not automatically an implementation defect.

C. Notification guard model checks

- PASS (model): NR-02: 60 days of undelivered check-ins do not escalate
- PASS (model): NR-03: total owner-channel failure blocks old waiting-period deadline
- PASS (model): NR-04: serializing/reloading model preserves fault and deadline
- PASS (model): NR-07: cancellation rejects a stale release job

The reload check serializes a JavaScript object only. It does not test database transactions, Quartz persistence, callback authentication, timing within one hour, rate limits, live deliverability or restart behavior of the backend.

C. Unexecuted implementation evidence

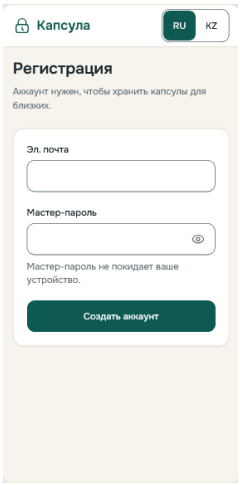
Metric / evidence	Status
M2 / M4: every k-1/k subset and cryptographic reconstruction	Not run; implementation/library harness required

Metric / evidence	Status
M5: canary scan of database, logs and decrypted HTTP payloads	Not run; running application required
M6 / M8 / M12 integration and provider tests	Not run; standalone guard model only
M10 / M11: 10 MB encryption/sharing and Argon2id, median of 10 runs	Not run; real browser/device and recorded versions required
Expert legal interview	Not conducted in the supplied evidence

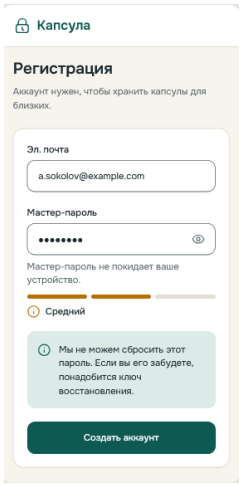
Appendix D. Mockup Screens

Exported frames of the Figma prototype (`prototype/mockups/`). The scenarios S1–S8 and the requirement shown by each frame are listed in section 8.1.

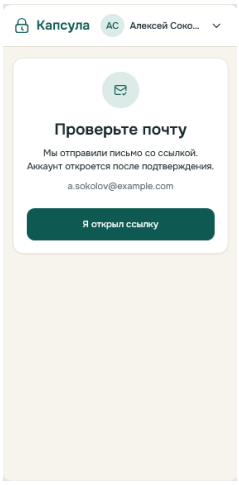
Scenario S1



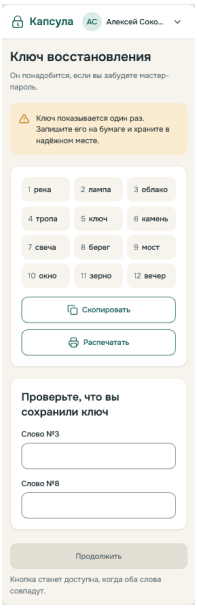
S1-1



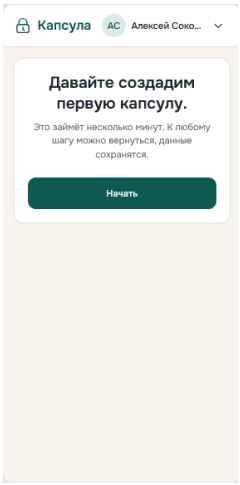
S1-2



S1-3

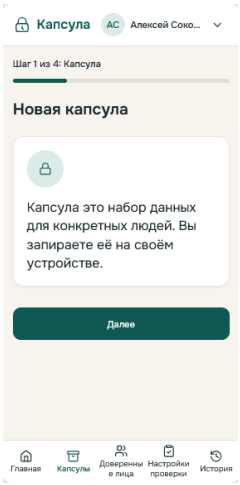


S1-4

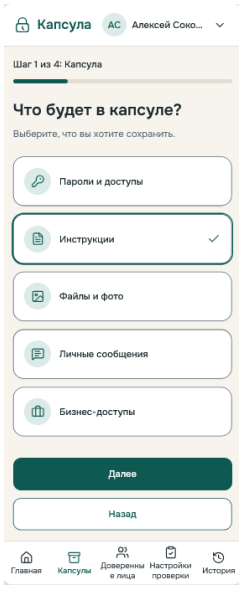


S1-5

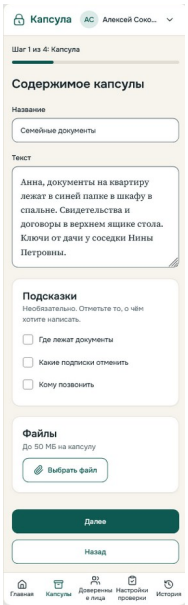
Scenario S2



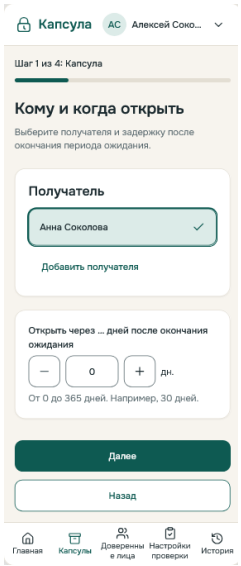
S2-1



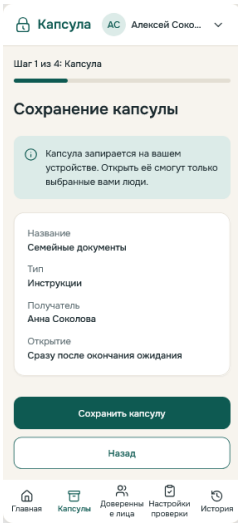
S2-2



S2-3

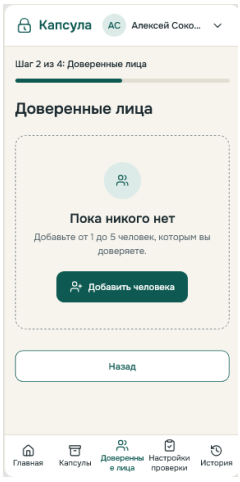


S2-4

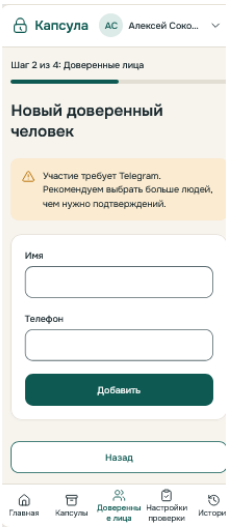


S2-5

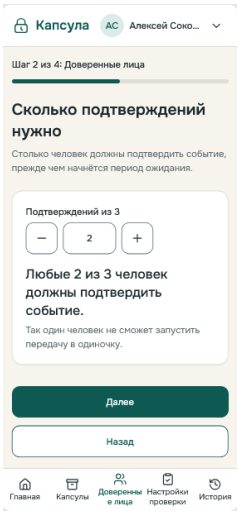
Scenario S3



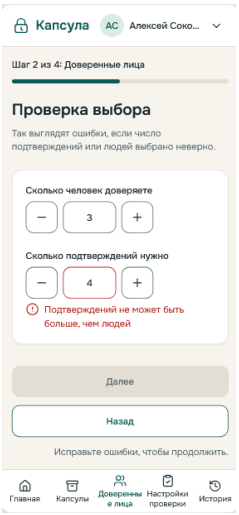
S3-1



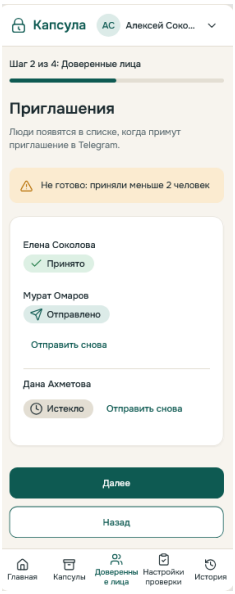
S3-2



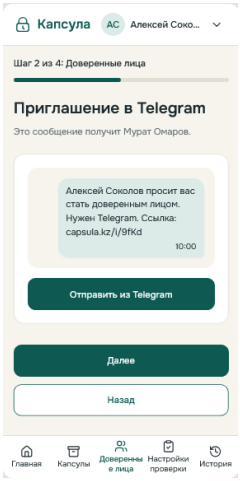
S3-3



S3-4

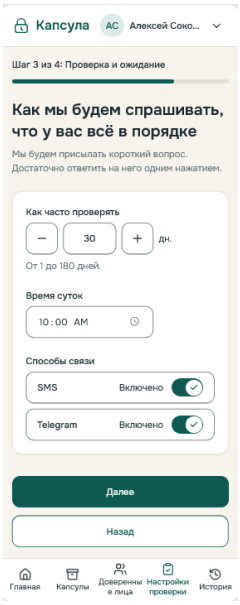


S3-5

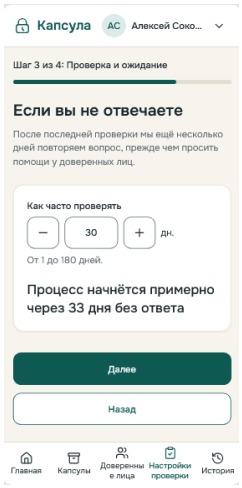


S3-6

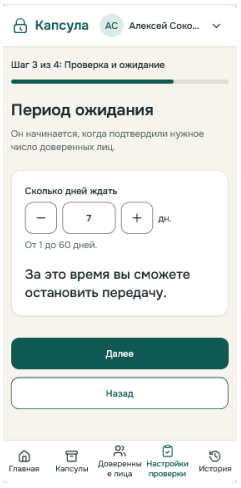
Scenario S4



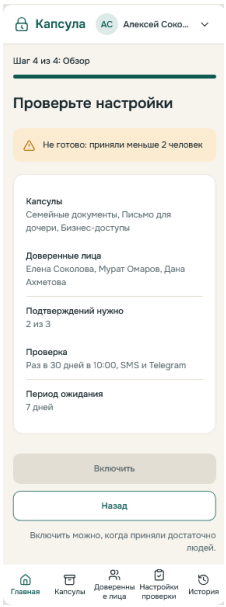
S4-1



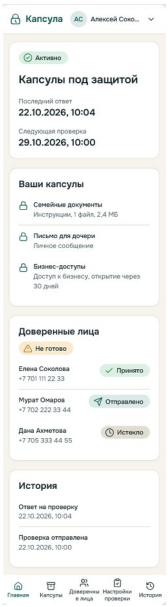
S4-2



S4-3

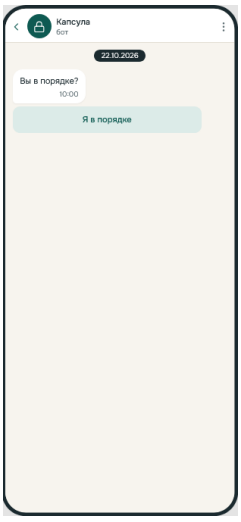


S4-4

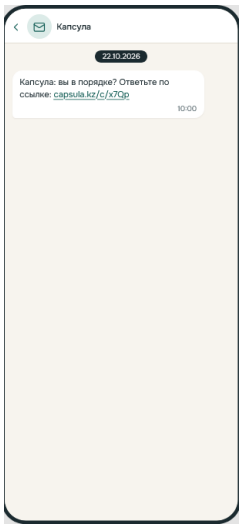


S4-5

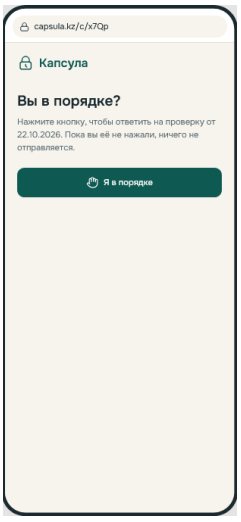
Scenario S5



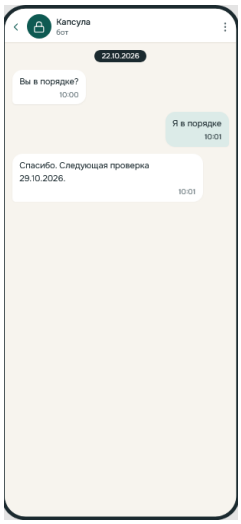
S5-1



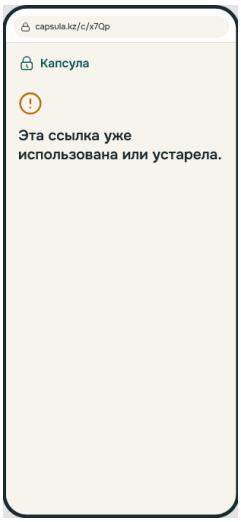
S5-2



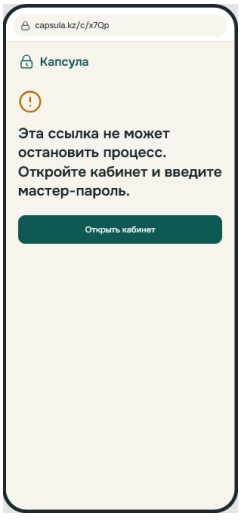
S5-3



S5-4

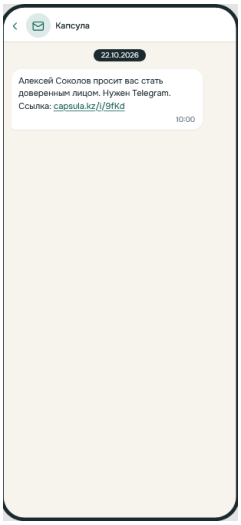


S5-5

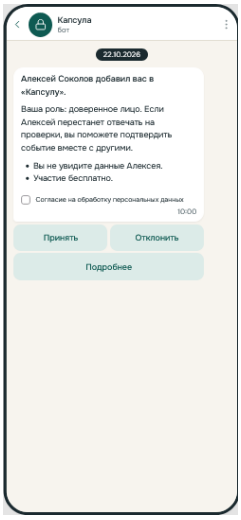


S5-6

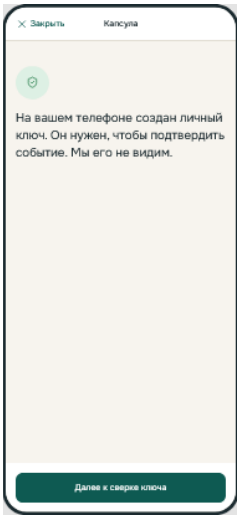
Scenario S6



S6-1



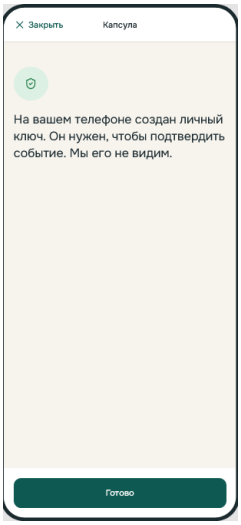
S6-2



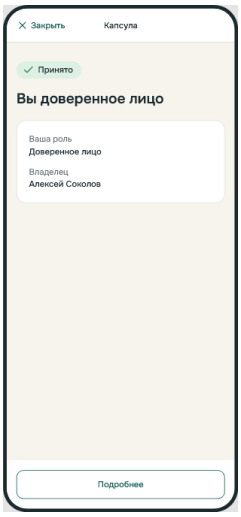
S6-3



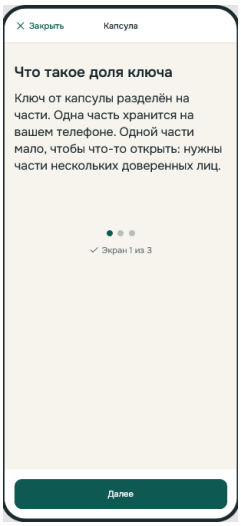
S6-4



S6-5

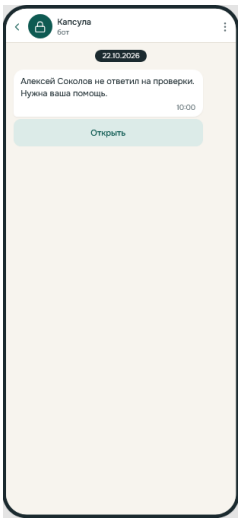


S6-6

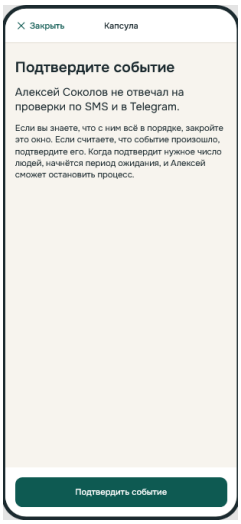


S6-7

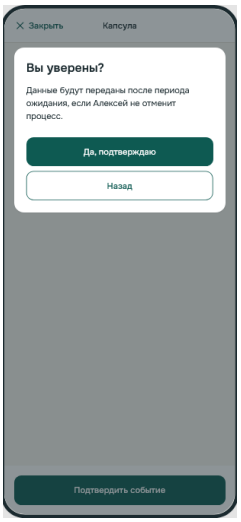
Scenario S7



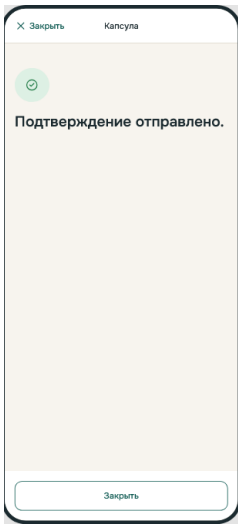
S7-1



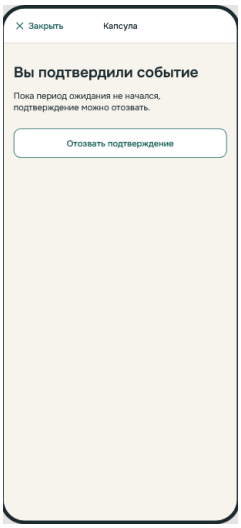
S7-2



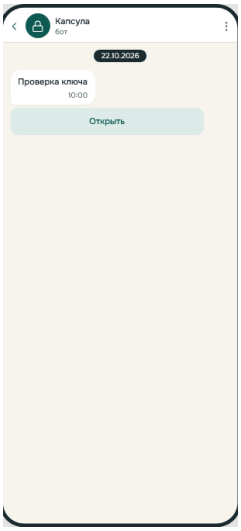
S7-3



S7-4

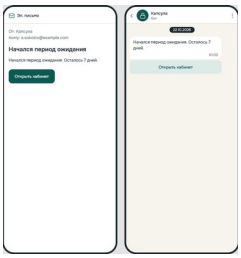


S7-5

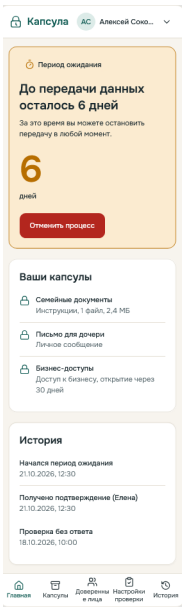


S7-6

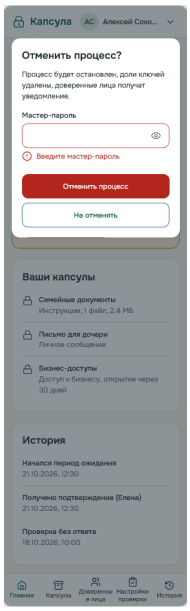
Scenario S8



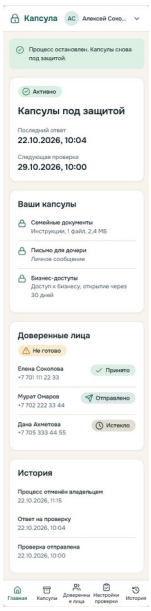
S8-1



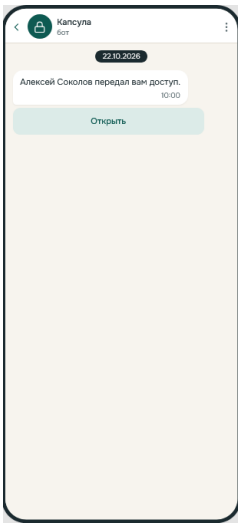
S8-2



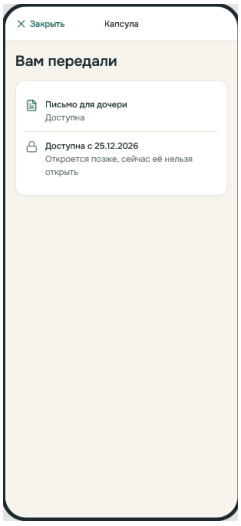
S8-3



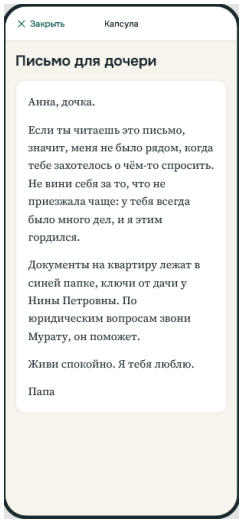
S8-4



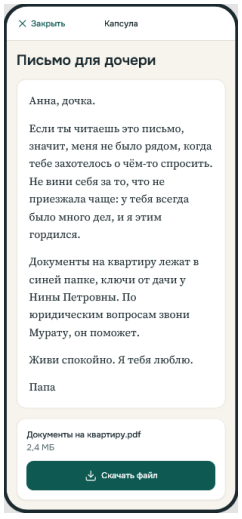
S8-5



S8-6



S8-7



S8-8

Appendix E. Pre-defense 1 Submission Summary

Item	Value
Project	Development of a Digital Legacy Platform with a Hybrid Activation Mechanism Based on Shamir's Secret Sharing
Repository	https://github.com/alishermede/Development-of-a-Digital-Legacy-Platform-with-a-Hybrid-Activation-Mechanism
Tags	`pre-defense-1` and `prob-period-1` on the same commit: the merge of the pull request that adds the formatted documentation
Tagged version	https://github.com/alishermede/Development-of-a-Digital-Legacy-Platform-with-a-Hybrid-Activation-Mechanism/tree/prob-period-1
Formatted documentation	`docs/submissions/Project-Documentation-pre-defense-1.docx` (built from the Markdown sources of this version)
Date	24.10.2026
Team	Alisher Medebaev (SE-2414), Aibyn Samat (SE-2415)
Supervisor	Tutkyshbayeva Sh.S.
Tracker	https://diplom-digital-legacy.youtrack.cloud/projects/DIP

Completed work

#	Component	Where	Result
1	Project proposal	`docs/01-proposal.md`	Aim, nine objectives with owners and evidence, scope, users, expected outcomes
2	Evidence of relevance	`docs/02-relevance-evidence/`	Interview guide, three anonymized interview notes (I-01 to I-03), findings table with verified findings and assumptions
3	Literature review	`docs/03-literature-review.md`	Critical review with an analysis table, comparison of approaches, research gap and limitations; 20 references
4	Comparison of existing systems	`docs/04-existing-systems.md`	Five systems compared by ten criteria; cryptographic criteria checked against vendor documents
5	Technology comparison	`docs/05-technology-comparison.md`	Backend, storage, cryptographic libraries, key storage, API style, timers, notification channels, frontend
6	Requirements	`docs/06-requirements.md`	103 requirements with priority, source and acceptance criteria
7	Architecture	`docs/07-architecture.md`, `diagrams/`	System context, use case (owner and system), component and activation state machine diagrams with editable sources
8	UX prototype and API examples	`docs/08-prototype.md`, `prototype/`	Eight scenarios with 48 mockup images, an additional AI-assisted interactive prototype, OpenAPI draft with 22 paths
9	Verification plan	`docs/09-verification-plan.md`, `docs/verification/`, `tests/simulation/`	Metrics M1 to M12, baseline, scenarios E1 to E11, usability plan; standalone design model with recorded results
10	Project management	`docs/10-project-management.md`	Responsibilities, task register DIP-1 to DIP-27, milestones M1 to M12, 15 risks, dependencies
11	Supervisor feedback	`docs/11-supervisor-feedback.md`	Round 1 (24.10.2026): five comments, each with a decision and a change
—	Legal analysis (DIP-26)	`docs/12-legal-analysis.md`	Norm-to-design table, Kazakhstan hosting decision, consent and transfer gates
—	Notification reliability (DIP-	`docs/13-notification-reliability.md`	Event, channel and fallback matrix, delivery semantics, retries, fail-closed guards, test cases NR-01 to NR-08

#	Component	Where	Result
	27)		

Work distribution and reviewers of every task: `docs/10-project-management.md`, section 10.1.1. Every document change went through a pull request reviewed by the other member; the history is in the repository.

Known limitations

- There is no application code. The only executable artifact is a standalone design model (`tests/simulation/pre-defense-model.cjs`). Its results validate the specified assumptions and guards, not an implementation. Metrics M2, M4, M5, M6, M8, M10 and M11 have not been run.
- Interviews: three respondents, all over 40, and no domain expert (risk R-01). The legal analysis is a requirements analysis of the official texts, not a legal opinion; no lawyer or notary interview has taken place. Civil Code articles 1038 to 1040 are to be rechecked against the official text (risk R-12).
- No hosting provider is contracted. The Kazakhstan storage requirement (NFR-LAW-01, Must) and the consent and transfer gates (NFR-LAW-02, NFR-LAW-04) must be evidenced before any real personal data is processed; demonstrations use synthetic data only. Risk R-06 stays open.
- The additional Figma Make prototype is a UI demonstration made with AI assistance. It is not evidence of encryption, legal compliance or reliable delivery.
- The usability test (section 9.5) is planned for February 2027 and has not been run.
- Some literature sources were read only in part (section 3.7).
- The formatted Word version is synchronized with the Markdown sources by Alisher; the revised aim and the objective table must be carried over.
- Supervisor review of sections 12 and 13 has not taken place; the feedback log contains round 1 only.

Outstanding tasks

Task	Responsible	When
Expert interview (notary or IT security) and update of risk R-06	Aibyn	November 2026 (M7)
Consent notice text, supplier and transfer assessment, hosting decision evidence	Aibyn, reviewer Alisher	Before any real-data pilot
Threat model (NFR-SEC-03) and TelegramBots / Spring Boot 4.1 compatibility spike	Alisher	November 2026 (M7)
Integration tests M6, M8, M12 against section 13	Alisher, specification Aibyn	Implementation (M8, M9)
Working core: client-side encryption, key splitting, activation state machine	Alisher	December 2026 (M8)
Usability test with eight participants	Aibyn	February 2027 (M10)
Supervisor feedback, next rounds	Alisher	As received (M6)